

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>

微信: "Examtopics"



Question #1

Topic 1

A security engineer is troubleshooting an AWS Lambda function that is named MyLambdaFunction. The function is encountering an error when the function attempts to read the objects in an Amazon S3 bucket that is named DOC-EXAMPLE-BUCKET. The S3 bucket has the following bucket policy:

```
{
  "Effect": "Allow",
  "Principal": {
    "Service": "lambda.amazonaws.com"
  },
  "Action": "s3:GetObject",
  "Resource": "arn:aws:s3:::DOC-EXAMPLE-BUCKET",
  "Condition": {
    "ArnLike": {
      "aws:SourceArn": "arn:aws:lambda:::function:MyLambdaFunction"
    }
  }
}
```

Which change should the security engineer make to the policy to ensure that the Lambda function can read the bucket objects?

一名安全工程师正在对一个名为 MyLambdaFunction 的 AWS Lambda 函数进行故障排查。当该函数尝试读取一个名为 DOC-EXAMPLE-BUCKET 的 Amazon S3 存储桶中的对象时，函数遇到了错误。该 S3 存储桶具有以下存储桶策略：

安全工程师应该对该策略进行哪项更改，以确保 Lambda 函数可以读取存储桶对象？

A. Remove the Condition element. Change the Principal element to the following:

```
{
  "AWS": "arn:aws:lambda:::function:MyLambdaFunction"
}
```

移除 Condition 元素。将 Principal 元素更改为以下内容：

B. Change the Action element to the following:

```
[
  "s3:GetObject*",
  "s3:GetBucket*"
]
```

将 Action 元素更改为以下内容：

C. Change the Resource element to "arn:aws:s3:::DOC-EXAMPLE- BUCKET/*".

将 Resource 元素更改为 "arn:aws:s3:::DOC-EXAMPLE- BUCKET/*".

D. Change the Resource element to "arn:aws:lambda:::function:MyLambdaFunction". Change the Principal element to the following:

```
"Service": "s3.amazonaws.com"
```

将 Resource 元素更改为 "arn:aws:lambda::function:MyLambdaFunction"。将 Principal 元素更改为以下内容：

Correct Answer: C

正确答案：C

题目解析：Lambda 读取 S3 对象被拒绝（Bucket Policy 修正）

1. 本题考察的知识点

S3 Bucket Policy 中 Resource ARN 的写法：s3:GetObject 必须授权到**对象级别 ARN** (bucket/*)，仅写 bucket ARN 不生效。

S3 权限评估逻辑：请求访问对象时，会同时匹配 Action/Resource/Principal/Condition；其中 Resource 不匹配会直接导致拒绝。

Lambda 访问 S3 的真实主体（Principal）：Lambda 访问 S3 时，通常以**Lambda 执行角色（IAM Role）**的身份签名请求，而不是以 lambda.amazonaws.com 这个服务主体发起请求（这一点是常见易错点）。

2. 独立思考（不参考官方答案）

当前策略的关键问题：**Action = s3:GetObject**，但 **Resource = arn:aws:s3::DOC-EXAMPLE-BUCKET** 只指向 bucket 级 ARN；读取对象需要匹配 **arn:aws:s3::DOC-EXAMPLE-BUCKET/***。

此外还存在潜在问题：

Principal 写成 Service: lambda.amazonaws.com：在“Lambda 主动读取 S3”场景下，S3 看到的调用方一般是 Lambda 执行角色，而不是 Lambda 服务主体。

Condition 的 aws:SourceArn 更常用于“某服务调用目标服务”的场景控制（例如 S3 触发 Lambda 的 invoke 权限、或某些服务对资源策略的 SourceArn 限制）。对“Lambda 调用 S3 GetObject”的访问控制通常不靠 SourceArn。

但题目问的是“确保 Lambda 能读对象”，在给定选项中最直接且必需的改动仍是把 Resource 改为对象 ARN (bucket/*)。

3. 逐个分析每个选项为什么正确或错误

A. Remove the Condition element. Change the Principal element...

即便移除 Condition，若仍未把 Resource 改成对象 ARN (bucket/*)，**s3:GetObject 仍然无法匹配到对象资源**，依旧会失败。

而且题干未给出 Principal 将被改成什么（不完整），无法保证一定正确。

结论：不能确保修复核心问题（Resource 对象级 ARN 缺失），因此不选。

B. Change the Action element...

无论 Action 改成什么（题干也未给出具体改法），如果仍然是 GetObject 之类的对象读取行为，**Resource 仍需要对象级 ARN**。仅改 Action 不能解决“资源不匹配”的根因。

结论：不选。

C. Change the Resource element to "arn:aws:s3::DOC-EXAMPLE-BUCKET/*".

正确点：对 **s3:GetObject** 必须授权到对象 ARN (bucket/*)，这是 S3 权限最关键且必需的匹配条件。

这样修改后，策略至少能够在 Resource 维度匹配到具体对象，从策略语义上“允许读取对象”。

潜在注意：如果真实调用方是 Lambda 执行角色，而此策略 Principal 仍是 lambda.amazonaws.com，则在真实系统里可能仍会失败；但在本题给定选项中，C 是唯一直接修复 s3:GetObject Resource 书写错误的选项，也是考试最常考的点。

结论：选 C。

D. Change the Resource element to "arn:aws:lambda::function:MyLambdaFunction". Change the Principal...

这是把 S3 bucket policy 的 Resource 改成 Lambda 函数 ARN，**资源类型完全不匹配**（S3 policy 的 Resource 应该是 S3 ARN）。该改动会导致策略语义错误/无效，无法授权 S3 对象读取。

结论：错误，不选。

4. 我选择的答案

C

5. 官方答案

C

6. 与官方答案比较 + 若不同则复盘原因

我的答案与官方答案一致：都是 C。

补充复盘（重要但不影响本题选项）：

在真实生产中，更推荐在 bucket policy 里把 Principal 设为 **Lambda 执行角色 ARN**（或其所在账号的特定角色/条件），而不是 `lambda.amazonaws.com` 服务主体。

但就本题而言，最确定、最直接的错误是 **GetObject 的 Resource 没有写到对象级（缺少 /*）**，因此选 C 符合考试意图。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #2

Topic 1

HOTSPOT -

A company is building a web application that needs to authenticate external users across multiple microservices that the company hosts on Amazon Elastic Container Service (Amazon ECS). The solution must use temporary credentials and minimize the management overhead required to maintain user databases.

Select and order the correct steps from the following list to implement a secure authentication strategy that meets these requirements. Select each step one time or not at all.

Configure Amazon Cognito user pools for user authentication.

Set up an IAM role for each microservice. Grant each role appropriate permissions.

Implement an Amazon API Gateway HTTP API with AWS Lambda authorizers to validate tokens before forwarding requests to microservices.

Create an Amazon DynamoDB table to store user credentials for each microservice.

Create an Amazon Cognito application client to interact with the web application.

Set up AWS IAM Identity Center to give users access to the microservices.

Step 1:

Configure Amazon Cognito user pools for user authentication.
Set up an IAM role for each microservice. Grant each role appropriate permissions.
Implement an Amazon API Gateway HTTP API with AWS Lambda authorizers to validate tokens before forwarding requests to microservices.
Create an Amazon DynamoDB table to store user credentials for each microservice.
Create an Amazon Cognito application client to interact with the web application.
Set up AWS IAM Identity Center to give users access to the microservices.

Step 2:

Configure Amazon Cognito user pools for user authentication.
Set up an IAM role for each microservice. Grant each role appropriate permissions.
Implement an Amazon API Gateway HTTP API with AWS Lambda authorizers to validate tokens before forwarding requests to microservices.
Create an Amazon DynamoDB table to store user credentials for each microservice.
Create an Amazon Cognito application client to interact with the web application.
Set up AWS IAM Identity Center to give users access to the microservices.

Step 3:

Configure Amazon Cognito user pools for user authentication.
Set up an IAM role for each microservice. Grant each role appropriate permissions.
Implement an Amazon API Gateway HTTP API with AWS Lambda authorizers to validate tokens before forwarding requests to microservices.
Create an Amazon DynamoDB table to store user credentials for each microservice.
Create an Amazon Cognito application client to interact with the web application.
Set up AWS IAM Identity Center to give users access to the microservices.

HOTSPOT -

一家公司正在构建一个 Web 应用程序，需要在该公司托管在 Amazon Elastic Container Service (Amazon ECS) 上的多个微服务之间对外部用户进行身份验证。该解决方案必须使用临时凭证，并将维护用户数据库所需的管理开销降到最低。

从以下列表中选择并按顺序排列正确的步骤，以实施满足这些要求的安全身份验证策略。每个步骤选择一次或完全不选。

配置 Amazon Cognito 用户池用于用户身份验证。

为每个微服务设置一个 IAM 角色。为每个角色授予适当的权限。
实现一个 Amazon API Gateway HTTP API，并使用 AWS Lambda 授权器在将请求转发到微服务之前验证令牌。
创建一个 Amazon DynamoDB 表，用于为每个微服务存储用户凭证。
创建一个 Amazon Cognito 应用程序客户端以与 Web 应用程序交互。
设置 AWS IAM Identity Center 以便让用户访问这些微服务。

Correct Answer:

Step 1:

Configure Amazon Cognito user pools for user authentication.

Set up an IAM role for each microservice. Grant each role appropriate permissions.

Implement an Amazon API Gateway HTTP API with AWS Lambda authorizers to validate tokens before forwarding requests to microservices.

Create an Amazon DynamoDB table to store user credentials for each microservice.

Create an Amazon Cognito application client to interact with the web application.

Set up AWS IAM Identity Center to give users access to the microservices.

Step 2:

Configure Amazon Cognito user pools for user authentication.

Set up an IAM role for each microservice. Grant each role appropriate permissions.

Implement an Amazon API Gateway HTTP API with AWS Lambda authorizers to validate tokens before forwarding requests to microservices.

Create an Amazon DynamoDB table to store user credentials for each microservice.

Create an Amazon Cognito application client to interact with the web application.

Set up AWS IAM Identity Center to give users access to the microservices.

Step 3:

Configure Amazon Cognito user pools for user authentication.

Set up an IAM role for each microservice. Grant each role appropriate permissions.

Implement an Amazon API Gateway HTTP API with AWS Lambda authorizers to validate tokens before forwarding requests to microservices.

Create an Amazon DynamoDB table to store user credentials for each microservice.

Create an Amazon Cognito application client to interact with the web application.

Set up AWS IAM Identity Center to give users access to the microservices.

正确答案：

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

面向外部用户 (customers/partners) 的身份认证：使用 Amazon Cognito User Pools 进行用户注册、登录、托管用户目录，减少自建用户数据库的运维。

微服务统一入口鉴权：使用 Amazon API Gateway + Lambda Authorizer (或JWT Authorizer) 在进入后端微服务前校验令牌，实现集中鉴权。

临时凭证/临时令牌思路：对Web应用外部用户，通常使用短期有效的 Token (JWT/Access Token) 作为“临时凭证”来访问API，从而避免长期静态凭证。

2. 独立思考 (不参考官方答案)

需求强调“外部用户”“跨多个微服务”“使用临时凭证”“最小化维护用户数据库的开销”。

最符合的是：**Cognito User Pools** 托管用户目录并签发JWT；Web应用通过 **Cognito App Client** 发起认证；所有微服务前置 **API Gateway + Lambda Authorizer** 校验JWT后再转发。

若题目严格要求“临时AWS访问密钥 (STS Credentials)”，通常还会涉及 **Cognito Identity Pools** 来换取AWS临时凭证，但本题选项中未提供该步骤；因此应将“临时凭证”理解为短期JWT令牌。

3. 逐个分析每个选项为什么正确或错误

Configure Amazon Cognito user pools for user authentication. 正确。原因：User Pools 提供托管用户目录与认证能力（注册/登录/MFA/密码策略/社交登录等），显著减少自建用户库的管理开销，并能为外部用户签发JWT Token用于访问后端服务。

Create an Amazon Cognito application client to interact with the web application. 正确。原因：Web应用需要通过 Cognito App Client (OAuth2/OIDC) 与 User Pool 交互，完成登录并获取 ID token / access token (短期有效)，以便后续调用API。

Implement an Amazon API Gateway HTTP API with AWS Lambda authorizers to validate tokens before forwarding

requests to microservices. 正确。原因：将鉴权集中在API入口，使用Lambda Authorizer校验来自Cognito的JWT（或执行更细粒度逻辑），校验通过后再转发到ECS上的各个微服务，满足“跨多个微服务”的统一认证策略并降低每个服务重复实现鉴权的成本。

Set up an IAM role for each microservice. Grant each role appropriate permissions. 不选（与题干核心目标不直接匹配）。原因：这是“微服务访问AWS资源的最小权限”（Task Role）的最佳实践，但题目要解决的是“外部用户认证 + 临时凭证 + 最小化用户数据库维护”。说明：在真实架构中通常也会做（每个ECS任务/服务配置Task Role），但它不属于本题“实现用户认证策略”的关键步骤集合，且题目限制“Select and order the correct steps”更像在考用户认证链路。

Create an Amazon DynamoDB table to store user credentials for each microservice. 错误。原因：违背“最小化管理开销”；还会引入自建凭证存储、密码安全（哈希、盐、轮换、审计）等复杂度与风险。Cognito User Pools就是为了避免这类自建用户库。

Set up AWS IAM Identity Center to give users access to the microservices. 错误。原因：IAM Identity Center（原SSO）主要用于组织内部员工/工作负载的身份联合与单点登录（workforce identity），并不适合面向外部互联网用户的大规模应用认证场景；也不直接用于给外部用户访问ECS微服务的API鉴权。

4. 我选择的答案（按正确顺序）

Step 1: Configure Amazon Cognito user pools for user authentication.

Step 2: Create an Amazon Cognito application client to interact with the web application.

Step 3: Implement an Amazon API Gateway HTTP API with AWS Lambda authorizers to validate tokens before forwarding requests to microservices.

5. 官方答案

Configure Amazon Cognito user pools for user authentication.

Create an Amazon Cognito application client to interact with the web application.

Implement an Amazon API Gateway HTTP API with AWS Lambda authorizers to validate tokens before forwarding requests to microservices.

6. 与官方答案对比与复盘

对比结果：我的答案与官方答案一致。

补充复盘：题干中的“temporary credentials”在此题选项语境下更合理地理解为**短期有效的JWT/OAuth2 Token**。如果考试想考“STS临时AWS凭证”，通常会在选项中出现 **Cognito Identity Pools / STS AssumeRole** 等步骤；但本题未提供，因此以“Token临时性”满足要求是最合理的解读。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #3

Topic 1

An AWS account administrator created an IAM group and applied the following managed policy to require that each individual user authenticate using multi-factor authentication:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "ec2:*",
      "Resource": "*"
    },
    {
      "Sid": "BlockAnyAccessUnlessSignedInWithMFA",
      "Effect": "Deny",
      "Action": "ec2:*",
      "Resource": "*",
      "Condition": {
        "BoolIfExists": {
          "aws:MultiFactorAuthPresent": false
        }
      }
    }
  ]
}
```

After implementing the policy, the administrator receives reports that users are unable to perform Amazon EC2 commands using the AWS CLI.

What should the administrator do to resolve this problem while still enforcing multi-factor authentication?

AWS 账户管理员创建了一个 IAM 组，并应用了以下托管策略，以要求每个单独的用户使用多因素身份验证进行身份验证：

在实施该策略后，管理员收到报告称，用户无法使用 AWS CLI 执行 Amazon EC2 命令。
管理员应采取什么措施来解决此问题，同时仍然强制执行多因素身份验证？

A. Change the value of `aws:MultiFactorAuthPresent` to true.

将 `aws:MultiFactorAuthPresent` 的值更改为 true。

B. Instruct users to run the `aws sts get-session-token` CLI command and pass the multi-factor authentication `--serial-number` and `-token-code` parameters. Use these resulting values to make API/CLI calls.

指示用户运行 `aws sts get-session-token` CLI 命令，并传递多因素身份验证的 `--serial-number` 和 `-token-code` 参数。使用这些生成的值来进行 API/CLI 调用。

C. Implement federated API/CLI access using SAML 2.0, then configure the identity provider to enforce multi-factor authentication.

使用 SAML 2.0 实现联合 API/CLI 访问，然后配置身份提供商以强制执行多因素身份验证。

D. Create a role and enforce multi-factor authentication in the role trust policy. Instruct users to run the `sts assume-role` CLI command and pass `--serial-number` and `--token-code` parameters. Store the resulting values in environment variables. Add `sts:AssumeRole` to `NotAction` in the policy.

创建一个角色，并在角色信任策略中强制执行多因素身份验证。指示用户运行 `sts assume-role` CLI 命令并传递 `--serial-number` 和 `--token-code` 参数。将生成的值存储在环境变量中。在策略的 `NotAction` 中添加 `sts:AssumeRole`。

Correct Answer: B

正确答案: B

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

IAM策略显式Deny的优先级: 即使有Allow, 只要命中Deny条件也会被拒绝。

aws:MultiFactorAuthPresent 条件键的含义: 请求上下文中是否“带着MFA认证”的会话 (通常是使用MFA获取的临时凭证)。

AWS CLI如何“携带MFA”访问AWS API: 需要通过STS获取临时凭证 (例如 `sts:GetSessionToken` 或 `sts:AssumeRole` + MFA)。

IAM用户长期访问密钥 (Access key) 默认不包含MFA上下文: 直接用长期AK/SK调用EC2会被策略拒绝。

2. 独立思考 (不参考官方答案)

该策略对 `ec2:*` 做了“允许”, 但又加了一条: 如果请求上下文中 `aws:MultiFactorAuthPresent=false` (或不存在时也按false处理, 因为用的是 `BoolIfExists`), 则对 `ec2:*` 显式Deny。

用户使用AWS CLI时, 若配置的是IAM用户的长期AK/SK, 调用EC2 API时通常不会带有“MFA已存在”的上下文, 因此会命中Deny。

解决方法应是: 让CLI请求使用“经过MFA验证的临时凭证”, 这样 `aws:MultiFactorAuthPresent` 才会为true, 从而不触发Deny。

最直接的做法是: 让用户用 `aws sts get-session-token` 搭配MFA设备 (serial-number + token-code) 获取临时凭证, 并用该临时凭证调用EC2。

3. 逐个选项分析

A. Change the value of aws:MultiFactorAuthPresent to true.

错误。

原因: `aws:MultiFactorAuthPresent` 是AWS在请求评估时提供的上下文条件键, 不是你在策略里“随意改成true”就能让请求变成MFA会话。

把条件写成true只会变成“当MFA存在时才Deny” (逻辑相反), 并不能正确“强制MFA”, 还可能导致更严重的策略错误。

B. Instruct users to run aws sts get-session-token ... Use these resulting values to make API/CLI calls.

正确。

原因: `sts:GetSessionToken` (配合MFA) 会签发一组临时凭证 (`AccessKeyId/SecretAccessKey/SessionToken`)。

用户用该临时凭证发起EC2 API调用时, 请求上下文会体现为“MFA已存在”, 从而 `aws:MultiFactorAuthPresent=true`, 不会命中显式Deny。

并且当前策略只Deny了 `ec2:*`, 并没有Deny `sts:GetSessionToken`, 所以用户仍然能先获取会话令牌。

C. Implement federated API/CLI access using SAML 2.0 ... enforce MFA.

不优 / 一般视为错误 (对该题场景属于过度设计)。

原因: SAML联合通常用于控制台或特定联邦到角色的访问形态; 虽然也可以通过联合拿到角色临时凭证, 但题目并未要求引入企业IdP或做联邦改造。

该方案改造成本高, 不是“解决现有CLI无法用EC2命令”的最直接方法。

D. Create a role and enforce MFA in the role trust policy... Add sts:AssumeRole to NotAction in the policy.

整体不推荐 / 本题语境下可判为错误。

原因1 (复杂度): 创建角色、配置信任策略MFA、再让用户AssumeRole是可行路线, 但题目问的是“管理员应该做什么来解决问题”, 最小改动是B。

原因2 (选项描述存在策略结构问题): 题干里的策略使用的是 **Action**, 并没有 **NotAction** 结构; “Add sts:AssumeRole to NotAction”与现有策略写法不匹配, 容易造成理解偏差。

原因3 (与题目直接症状的对应性): 用户当前问题是“CLI无法执行EC2命令”, 最直接是让现有用户凭证升级为MFA会话临时凭证 (`get-session-token`)。

补充: 在某些架构中“AssumeRole + MFA”确实是最佳实践之一, 但该选项混入了不严谨的策略修改表述, 因此不作为本题最佳答案。

4. 我选择的答案

B

5. 官方答案

B

6. 与官方答案对比与复盘

结论：一致（我选B，官方也选B）。

原因：要让 `aws:MultiFactorAuthPresent` 为true，CLI必须使用“通过MFA获取的临时凭证”。`sts get-session-token + MFA` 是最直接、最少改动、最贴合题干现状的做法。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #4

Topic 1

A company is using AWS Organizations with the default SCP. The company needs to restrict AWS usage for all AWS accounts that are in a specific OU.

Except for some desired global services, the AWS usage must occur only in the eu-west-1 Region for all accounts in the OU. A security engineer must create an SCP that applies the restriction to existing accounts and any new accounts in the OU.

Which SCP will meet these requirements?

一家企业正在使用带有默认 SCP 的 AWS Organizations。该企业需要对位于特定 OU 中的所有 AWS 账户限制 AWS 的使用。除了一些期望的全局服务之外，该 OU 中所有账户的 AWS 使用必须仅发生在 eu-west-1 区域。安全工程师必须创建一个 SCP，将该限制应用于现有账户以及该 OU 中的任何新账户。

哪个 SCP 将满足这些要求？

A.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyNonDefaultRegions",
      "Effect": "Deny",
      "NotAction": [
        <Desired Global Services> ],
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:RequestedRegion": [
            "eu-west-1"
          ]
        }
      }
    }
  ]
}
```

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyNonDefaultRegions",
      "Effect": "Allow",
      "Action": [
        <Desired Global Services> ],
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:RequestedRegion": [
            "eu-west-1"
          ]
        }
      }
    }
  ]
}

```

B.

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyNonDefaultRegions",
      "Effect": "Deny",
      "NotAction": [
        <Desired Global Services> ],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": [
            "eu-west-1"
          ]
        }
      }
    }
  ]
}

```

C.

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyNonDefaultRegions",
      "Effect": "Allow",
      "NotAction": [
        <Desired Global Services> ],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": [
            "eu-west-1"
          ]
        }
      }
    }
  ]
}

```

D.

Correct Answer: C

正确答案: C

题目解析 (AWS Organizations SCP 区域限制 + 例外全局服务)

1. 本题考察的知识点

AWS Organizations 的 SCP (Service Control Policy) : SCP 只定义“最大权限边界”, 显式 **Deny** 会覆盖任何 IAM Allow。

OU 级别绑定: 把 SCP 绑定到特定 OU, 可自动作用于 OU 内现有账号以及未来新加入/新建账号。

按 Region 限制: 使用条件键 **aws:RequestedRegion** 对除指定 Region (eu-west-1) 外的访问进行显式 Deny。

全局服务例外: 对不应受 Region 限制的服务 (如 IAM、Route 53、CloudFront、Organizations、Support、STS 等) 做例外放行, 避免管理能力/登录/角色切换等被误伤。

2. 独立思考 (不参考官方答案)

需求是: 对某个 OU 内所有账号 (现有 + 新增) 限制只能在 **eu-west-1** 使用 AWS 服务, 同时**保留某些全局服务**可用。

最稳妥的 SCP 设计是: 用一个 **Effect:Deny** 的语句, 在 **aws:RequestedRegion != eu-west-1** 时拒绝, 并通过 **NotAction** (或 Action + 明确 Allow 例外, 但 SCP 不支持显式 Allow 超越 Deny) 来排除“必须保留的全局服务”。

此模式能确保: 任何 IAM/资源策略给出的 Allow 都无法绕过在其他 Region 的操作, 同时 OU 绑定保证适用于现有与未来账号。

3. 逐个分析每个选项为什么正确或错误

选项 A: 题干未提供 A 的具体 SCP JSON/策略内容, 无法判断其是否满足“仅 eu-west-1 + 全局服务例外”的条件限制逻辑。

选项 B: 题干未提供 B 的具体 SCP JSON/策略内容, 无法判断其是否正确使用 **aws:RequestedRegion**、是否采用显式 Deny、是否正确处理全局服务例外、是否可绑定 OU 覆盖新老账号。

选项 C: 题干未提供 C 的具体 SCP JSON/策略内容, 无法逐条验证; 但从本题标准解法推断, 正确答案应当是“在非 eu-west-1 时 Deny (并排除部分全局服务)”的那份 SCP。

选项 D: 题干未提供 D 的具体 SCP JSON/策略内容, 无法判断。

重要说明: 当前题目未给出 A/B/C/D 的策略文本 (只有 “A.. B.. C.. D..”), 因此无法完成“逐选项逐条语句级”的严格判断。请补充每个选项的 SCP 内容后, 我可以按语句与条件逐项精确分析。

(参考) 满足需求的典型 SCP 写法

以下是符合题意的常见实现方式之一 (示例, 需要按公司“期望保留的全局服务”调整 NotAction 列表):

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyOutsideEUWest1ExceptGlobalServices",
      "Effect": "Deny",
      "NotAction": [
        "iam:*",
        "organizations:*",
        "route53:*",
        "cloudfront:*",
        "support:*",
        "sts:*"
      ],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": "eu-west-1"
        }
      }
    }
  ]
}
```

核心点: 在请求 Region 不是 eu-west-1 时, 对除 NotAction 之外的所有操作做显式 Deny。

NotAction：用于保留“全局服务/关键管理服务”，避免把账户管理、DNS、CDN、组织管理、支持、角色切换等能力一起封死。
把该 SCP 绑定到目标 OU，即可覆盖 OU 内现有与未来账号。

4. 我选择的答案

在缺少选项内容的前提下：我会选择“包含显式 Deny + aws:RequestedRegion 限制到 eu-west-1 + 对需要的全局服务做例外”的那个选项。

若必须在 A/B/C/D 中选一个且仅依据你给出的“官方答案是 C”，则我选择：C（假设 C 对应上述正确模式）。

5. 官方答案

C

6. 与官方答案对比与复盘

我的结论（在无法看到选项文本时的合理推断）与官方答案均为：C。

但需要强调：如果 C 的策略实际内容没有做到以下要点，则即便“官方选 C”，也可能不满足需求：

必须使用 **Effect:Deny**（SCP 通过 Deny 来限制）。

必须基于 **aws:RequestedRegion** 限制到 **eu-west-1**。

必须为“期望保留的全局服务”做例外（常用 NotAction 或其它等价方式）。

必须绑定到 **目标 OU**，才能覆盖现有与未来账号（题干要求）。

请把 A/B/C/D 的完整策略 JSON 粘贴出来，我可以按每条 Statement/Condition/NotAction 逐句验证 C 是否真正满足题意，并对 A/B/D 给出明确“错在哪里”。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #5

Topic 1

HOTSPOT -

A security engineer needs to implement AWS IAM Identity Center with an external identity provider (IdP).

Select and order the correct steps from the following list to meet this requirement. Select each step one time or not at all.

Configure the external IdP as the identity source in IAM Identity Center.

Create an IAM role that has a trust policy that specifies the IdP's API endpoint.

Enable automatic provisioning in IAM Identity Center settings

Enable automatic provisioning in the external IdP.

Obtain the SAML metadata from IAM Identity Center.

Obtain the SAML metadata from the external IdP.

Step 1:

	▼
Configure the external IdP as the identity source in IAM Identity Center. Create an IAM role that has a trust policy that specifies the IdP's API endpoint. Enable automatic provisioning in IAM Identity Center settings Enable automatic provisioning in the external IdP. Obtain the SAML metadata from IAM Identity Center. Obtain the SAML metadata from the external IdP.	

Step 2:

	▼
Configure the external IdP as the identity source in IAM Identity Center. Create an IAM role that has a trust policy that specifies the IdP's API endpoint. Enable automatic provisioning in IAM Identity Center settings Enable automatic provisioning in the external IdP. Obtain the SAML metadata from IAM Identity Center. Obtain the SAML metadata from the external IdP.	

Step 3:

	▼
Configure the external IdP as the identity source in IAM Identity Center. Create an IAM role that has a trust policy that specifies the IdP's API endpoint. Enable automatic provisioning in IAM Identity Center settings Enable automatic provisioning in the external IdP. Obtain the SAML metadata from IAM Identity Center. Obtain the SAML metadata from the external IdP.	

热点 -

一名安全工程师需要实施 AWS IAM Identity Center，并使用外部身份提供商（IdP）。

从以下列表中选择并按正确顺序排列步骤以满足此要求。每个步骤选择一次或不选。

将外部 IdP 配置为 IAM Identity Center 中的身份源。

创建一个 IAM 角色，并为其配置一个信任策略，该策略指定 IdP 的 API 端点。

在 IAM Identity Center 设置中启用自动预置。

在外部 IdP 中启用自动预置。

从 IAM Identity Center 获取 SAML 元数据。

从外部 IdP 获取 SAML 元数据。

Correct Answer:

Step 1:

Configure the external IdP as the identity source in IAM Identity Center.
Create an IAM role that has a trust policy that specifies the IdP's API endpoint.
Enable automatic provisioning in IAM Identity Center settings
Enable automatic provisioning in the external IdP.
Obtain the SAML metadata from IAM Identity Center.
Obtain the SAML metadata from the external IdP.

Step 2:

Configure the external IdP as the identity source in IAM Identity Center.
Create an IAM role that has a trust policy that specifies the IdP's API endpoint.
Enable automatic provisioning in IAM Identity Center settings
Enable automatic provisioning in the external IdP.
Obtain the SAML metadata from IAM Identity Center.
Obtain the SAML metadata from the external IdP.

Step 3:

Configure the external IdP as the identity source in IAM Identity Center.
Create an IAM role that has a trust policy that specifies the IdP's API endpoint.
Enable automatic provisioning in IAM Identity Center settings
Enable automatic provisioning in the external IdP.
Obtain the SAML metadata from IAM Identity Center.
Obtain the SAML metadata from the external IdP.

正确答案:

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

AWS IAM Identity Center 与外部身份提供商 (External IdP) 的 SAML 2.0 联邦集成流程

SAML 元数据 (Metadata) 的交换方向: IAM Identity Center (SP) 元数据提供给外部 IdP; 外部 IdP (IdP) 元数据回填到 IAM Identity Center

是否需要 **SCIM 自动预置 (Automatic Provisioning)**: 仅在需要从外部 IdP 自动同步用户/组到 IAM Identity Center 时才需要

2. 独立思考 (不参考官方答案)

题干只说“实现 IAM Identity Center + 外部 IdP”，并未明确要求“自动预置/SCIM”。因此，完成 SAML 联邦的关键是**双方元数据交换**并在 IAM Identity Center 中配置外部 IdP 作为 Identity source。

要让外部 IdP 能正确配置 SAML 应用，通常必须先拿到 IAM Identity Center (作为 SP) 的元数据 (包含 ACS URL、Entity ID、证书等)。所以“**从 IAM Identity Center 获取 SAML 元数据**”在真实实施中通常是必要步骤。

3. 逐个选项分析（为什么对/错）

Configure the external IdP as the identity source in IAM Identity Center. 结论：**正确且必要**。原因：需要在 IAM Identity Center 中选择 External IdP，并导入外部 IdP 的 SAML 元数据/完成信任配置，才能让用户通过外部 IdP 登录。

Create an IAM role that has a trust policy that specifies the IdP's API endpoint. 结论：**错误**。原因：IAM Identity Center 与外部 IdP 的集成是 SAML/OIDC 身份源配置，不是通过“IAM Role 信任某个 IdP API endpoint”来实现。IAM Role 的信任策略通常信任 SAML Provider (arn:aws:iam::...:saml-provider/...) 或 OIDC Provider，而不是“IdP API endpoint”。

Enable automatic provisioning in IAM Identity Center settings 结论：**有条件正确（非必需）**。原因：这是用于 SCIM 自动预置（同步用户/组）的步骤。只有在题目明确要求“自动同步用户/组（provisioning）”时才必选；否则仅做 SAML SSO 并不要求开启该功能。

Enable automatic provisioning in the external IdP. 结论：**有条件正确（非必需）**。原因：同上，属于 SCIM 配置的一部分。通常需要在 IAM Identity Center 先开启并生成 SCIM endpoint/token，然后回到外部 IdP 开启并填写这些信息。

Obtain the SAML metadata from IAM Identity Center. 结论：**正确且通常必要**。原因：IAM Identity Center 作为 Service Provider (SP)，其 SAML 元数据用于在外部 IdP 创建/配置 SAML 应用（设置 ACS URL、Entity ID、证书等）。没有这份元数据，外部 IdP 很难正确配置。

Obtain the SAML metadata from the external IdP. 结论：**正确且必要**。原因：IAM Identity Center 需要导入外部 IdP 的元数据（IdP entityID、SingleSignOnService URL、签名证书等），才能验证来自 IdP 的断言并完成联邦登录。

4. 我选择的答案（并给出顺序）

Step 1: Obtain the SAML metadata from IAM Identity Center.

Step 2: Obtain the SAML metadata from the external IdP.

Step 3: Configure the external IdP as the identity source in IAM Identity Center.

5. 官方答案

Obtain the SAML metadata from the external IdP.

Configure the external IdP as the identity source in IAM Identity Center.

Enable automatic provisioning in IAM Identity Center settings

6. 与官方答案对比与复盘

不同点 1：我包含“Obtain the SAML metadata from IAM Identity Center.”，官方没有。 复盘：在标准 SAML 对接流程里，外部 IdP 需要 SP 元数据来配置 SAML 应用（ACS/EntityID/证书）。因此我认为该步骤在“实现对接”层面是关键步骤之一；官方答案缺失该步会导致流程不完整。

不同点 2：官方包含“Enable automatic provisioning in IAM Identity Center settings”，我未包含。 复盘：自动预置是 SCIM（用户/组同步）能力，题干未要求同步用户/组，仅要求“实现 IAM Identity Center + 外部 IdP”。因此我认为不应强行加入该步骤。若题干是“需要自动预置用户/组”，那才应加入并且还应同时选择“Enable automatic provisioning in the external IdP.”（通常 IAM Identity Center 先开，拿到 SCIM endpoint/token，再到外部 IdP 开）。

重新思考后的结论：我仍坚持我的选择更符合“实现 SAML 联邦集成”的完整必要步骤；官方答案更像是在强调某个不完整/特定前提下的步骤组合（且开启预置却不包含外部 IdP 侧开启预置，也不完整）。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #6

Topic 1

What is the effect of the following AWS Key Management Service (AWS KMS) key policy that is attached to a customer managed key?

```
{
  "Effect": "Allow",
  "Principal": {
    "AWS": "arn:aws:iam::111122223333:role/ExampleRole"
  },
  "Action": [
    "kms:Encrypt",
    "kms:Decrypt",
    "kms:GenerateDataKey*",
    "kms:CreateGrant",
    "kms:ListGrants"
  ],
  "Resource": "*",
  "Condition": {
    "StringEquals": {
      "kms:ViaService": [
        "workmail.us-west-2.amazonaws.com",
        "ses.us-west-2.amazonaws.com"
      ]
    }
  }
}
```

以下附加到客户管理密钥的 AWS Key Management Service (AWS KMS) 密钥策略的效果是什么?

A. Amazon WorkMail and Amazon Simple Email Service (Amazon SES) have delegated KMS encrypt and decrypt permissions to the ExampleRole principal in the 111122223333 account.

Amazon WorkMail 和 Amazon Simple Email Service (Amazon SES) 已将 KMS 加密和解密权限委派给 111122223333 账户中的 ExampleRole 主体。

B. The ExampleRole principal can transparently encrypt and decrypt email exchanges specifically between ExampleRole and AWS.

ExampleRole 主体可以透明地加密和解密专门发生在 ExampleRole 与 AWS 之间的电子邮件交换。

C. The customer managed key can be used for encrypting and decrypting only when the principal is ExampleRole and when the request comes from Amazon WorkMail or Amazon Simple Email Service (Amazon SES) in the specified AWS Region. 只有当主体为 ExampleRole 且请求来自指定 AWS 区域中的 Amazon WorkMail 或 Amazon Simple Email Service (Amazon SES) 时，才能使用该客户管理密钥进行加密和解密。

D. The key policy allows Amazon WorkMail or Amazon Simple Email Service (Amazon SES) to encrypt or decrypt on behalf of the ExampleRole for any customer managed key in the account.

该密钥策略允许 Amazon WorkMail 或 Amazon Simple Email Service (Amazon SES) 代表 ExampleRole 为账户中的任何客户管理密钥进行加密或解密。

Correct Answer: C

正确答案: C

题目解析：AWS KMS Key Policy 中 kms:ViaService 条件的效果

1) 考察的知识点

AWS KMS Key Policy 的语义：Key policy 是 KMS 密钥的资源策略，决定谁能对该“特定密钥”执行哪些 KMS API。

Condition: kms:ViaService 的含义：只有当对 KMS 的调用是“通过指定的 AWS 服务”发起（即该服务代表调用方去调用 KMS，或请求上下文显示经由该服务）时才匹配。

Principal 为 IAM Role 时的授权效果：仅该 Role 作为调用主体时才会命中该语句。

区域性服务端点：workmail.us-west-2.amazonaws.com、ses.us-west-2.amazonaws.com 明确限制在 us-west-2 区域的对应服务。

Resource: "*" 在 KMS Key policy 语句中通常等价于“这把密钥本身”（该策略附着到哪把 CMK，就约束哪把 CMK），并不代表账户内所有 CMK。

2) 独立思考（不参考官方答案）的结论

该策略语句允许 111122223333 账户中的 **ExampleRole** 对“这把客户管理密钥”执行

Encrypt/Decrypt/GenerateDataKey*/CreateGrant/ListGrants。

但这个允许是有条件的：请求必须满足 **kms:ViaService** 为 **WorkMail(us-west-2)** 或 **SES(us-west-2)**。

因此效果是：**只有当主体是 ExampleRole 且请求通过指定区域的 WorkMail 或 SES 这个服务通道发起时，才能使用该 CMK 加解密/生成数据密钥/创建与列出 Grant。**

3) 逐个选项分析

A 错误 “WorkMail 和 SES 已将 KMS 加密和解密权限委派给 ExampleRole”这种表述不符合 KMS 授权模型：

这里的权限来源是 **KMS key policy** 对 ExampleRole 的授权，不是 WorkMail/SES “把权限委派给” Role。

kms:ViaService 表达的是“请求必须经由某服务”，不是“服务把权限授予某主体”。

另外该策略还包含 GenerateDataKey*、CreateGrant、ListGrants，不仅是加解密。

B 错误 “透明地加密和解密专门发生在 ExampleRole 与 AWS 之间的电子邮件交换”不准确：

Key policy 控制的是对 KMS API 的访问，而不是直接描述“ExampleRole 与 AWS 之间的邮件交换”。

kms:ViaService 限制的是调用路径（通过 WorkMail/SES），并非“通信双方是 ExampleRole 与 AWS”。

该策略也不限定“邮件交换”的具体范围或对象，仅限定服务入口与主体。

C 正确 该选项准确描述了关键点：

主体必须是 ExampleRole（Principal 明确指定）。

请求必须来自指定服务通道：kms:ViaService 为 workmail.us-west-2.amazonaws.com 或 ses.us-west-2.amazonaws.com。

区域限制：ViaService 值包含 us-west-2 端点，意味着仅允许经由该区域对应服务的请求上下文满足条件。

因此这把 CMK 仅能在满足上述条件时用于 Encrypt/Decrypt/GenerateDataKey*/CreateGrant/ListGrants。

D 错误 “允许 WorkMail/SES 代表 ExampleRole 为账户中任何客户管理密钥加解密”错在两点：

该策略是“附加在某一把客户管理密钥上”的 key policy，授权范围是 **这把密钥**，不是账户中所有 CMK。

Principal 是 **ExampleRole**，并不是 WorkMail/SES 服务主体（service principal）。kms:ViaService 只是条件约束，不会把 Principal 变成服务本身。

4) 我选择的答案

C

5) 官方答案

C

6) 与官方答案对比与复盘

我的答案与官方答案一致：都是 C。

原因：该 key policy 明确授权 ExampleRole，但通过 **kms:ViaService** 将可用场景限制为“经由 us-west-2 的 WorkMail 或 SES 发起的 KMS 调用”。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #7

Topic 1

A company wants to deny a specific federated user named Bob access to an Amazon S3 bucket named DOC-EXAMPLE-BUCKET. The company wants to meet this requirement by using a bucket policy. The company also needs to ensure that this bucket policy affects Bob's S3 permissions only. Any other permissions that Bob has must remain intact. Which policy should the company use to meet these requirements?

一家公司希望拒绝名为 Bob 的特定联合身份用户访问名为 DOC-EXAMPLE-BUCKET 的 Amazon S3 存储桶。公司希望通过使用存储桶策略来满足此要求。公司还需要确保该存储桶策略仅影响 Bob 的 S3 权限。Bob 拥有的任何其他权限都必须保持不变。公司应使用哪种策略来满足这些要求?

A.

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Principal": {"AWS": "arn:aws:sts::account-id:federated-user/Bob"},
    "Effect": "Allow",
    "Action": "s3:*",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET"
  }
}
```

B.

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Principal": {"AWS": "arn:aws:sts::account-id:federated-user/Bob"},
    "Effect": "Deny",
    "Action": "s3:*",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET"
  }
}
```

C.

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Principal": {"AWS": "arn:aws:iam::account-id:user/Bob"},
    "Effect": "Deny",
    "Action": "s3:*",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET"
  }
}
```

D.

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Principal": {"AWS": "arn:aws:sts::account-id:assumed-role/Bob/role-session-name"},
    "Effect": "Deny",
    "Action": "s3:*",
    "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET"
  }
}
```

Correct Answer: B

正确答案: B

题目解析 (AWS Certified Security – Specialty SCS-C03 做题教练)

1. 本题考察的知识点

S3 Bucket Policy 的显式拒绝 (Explicit Deny) 优先级: 资源策略中的 Deny 会覆盖任何 Allow (包括身份策略/IAM Policy 里的 Allow)。

仅影响特定资源上的权限: Bucket policy 只影响该 bucket (及其对象) 上的访问控制, 不会改变用户在其他 AWS 服务或其他 S3 bucket 的权限。

Federated user 的精准匹配方式: 联邦用户/STS 会话的 Principal 往往不是一个固定 IAM User, 需要用条件键 (例如 `aws:userid`、会话名、标签等) 来仅拒绝某一个会话/某一个人 (Bob)。

2. 独立思考 (不参考官方答案)

目标是: 用 **DOC-EXAMPLE-BUCKET** 的 **bucket policy** 拒绝名为 Bob 的特定 **federated user** 访问该 bucket。

且要求: **只影响 Bob 的 S3 权限**, Bob 的其他权限保持不变。

关键点: 如果 federated 用户是通过某个 IAM Role 假设 (AssumeRole) 进来的, 那么直接 Deny 该 Role 会误伤所有使用该 Role 的人; 因此通常需要用 **Condition** 精确到 Bob 的会话标识 (例如 `aws:userid` 末尾带 session name)。

3. 逐个分析每个选项为什么正确或错误

选项A: 题干未提供具体 policy 内容, 无法分析正确/错误原因。

选项B: 题干未提供具体 policy 内容, 无法分析正确/错误原因。

选项C: 题干未提供具体 policy 内容, 无法分析正确/错误原因。

选项D: 题干未提供具体 policy 内容, 无法分析正确/错误原因。

4. 我选择的答案

无法在未给出 A/B/C/D 的具体策略 JSON 文本的情况下选择 (因为本题是 "Which policy", 必须对照具体策略语句判断)。

(补充) 满足需求的典型 Bucket Policy 写法示例 (供你对照选项)

如果 Bob 是 federated/assumed-role 会话, 并且会话名为 Bob (常见于 SAML/STS 会话名), 可以用 `aws:userid` 精确匹配 "仅 Bob":

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyBobOnlyForThisBucket",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:*",
      "Resource": [
        "arn:aws:s3::DOC-EXAMPLE-BUCKET",
        "arn:aws:s3::DOC-EXAMPLE-BUCKET/*"
      ],
      "Condition": {
        "StringLike": {
          "aws:userid": "*:Bob"
        }
      }
    }
  ]
}
```

解释: Bucket policy 只作用于该 bucket; 显式 Deny 只会让 Bob 对该 bucket 的 S3 访问被拒绝, 不会 "删除/改变" 他在其他资源上的权限。

注意：不同 federation 方式下可用的精确条件键可能不同（例如会话标签 `aws:PrincipalTag`）。最终应以选项里的条件键是否能“只命中 Bob”作为判断标准。

5. 官方答案

B

6. 与官方答案比较与复盘

由于题目未给出选项 A/B/C/D 的具体策略内容，我无法核对 **B** 是否等价于“仅拒绝 Bob 且只作用于该 bucket”的正确策略，因此也无法进行有效对比与复盘。

请你把 A/B/C/D 四个选项的完整 bucket policy JSON（或关键 Statement）贴出来，我就能逐条解释并给出最终选择，以及与官方答案 B 的差异原因。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #8

Topic 1

HOTSPOT -

A company is designing its security monitoring strategy for an existing sensitive workload on AWS. The security team has identified several scenarios that require monitoring strategies.

Select the correct monitoring strategy from the following list for each monitoring scenario. Select each monitoring strategy one time.

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed.

Correlate security findings from multiple AWS detection services to identify multi-stage attacks.

Detect when privileged users perform an unusually high volume of resource deletion operations.

Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour.

Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours.

Configure VPC Flow Logs with Amazon CloudWatch Logs Insights queries to analyze traffic volume and destination patterns during specific time windows.

Configure VPC Flow Logs with Amazon CloudWatch Logs Insights queries to analyze traffic volume and destination patterns during specific time windows.

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed.
Correlate security findings from multiple AWS detection services to identify multi-stage attacks.
Detect when privileged users perform an unusually high volume of resource deletion operations.
Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour.
Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours.

Create Amazon CloudWatch metric filters on application logs to track authentication failure rates for each source IP address with hourly aggregation.

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed.
Correlate security findings from multiple AWS detection services to identify multi-stage attacks.
Detect when privileged users perform an unusually high volume of resource deletion operations.
Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour.
Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours.

Enable AWS CloudTrail Insights for API call rate analysis to establish baselines and then detect anomalous API activity patterns.

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed.
Correlate security findings from multiple AWS detection services to identify multi-stage attacks.
Detect when privileged users perform an unusually high volume of resource deletion operations.
Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour.
Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours.

Implement AWS Security Hub custom insights with Amazon EventBridge rules to invoke automated AWS Lambda functions for coordinated incident response.

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed.
Correlate security findings from multiple AWS detection services to identify multi-stage attacks.
Detect when privileged users perform an unusually high volume of resource deletion operations.
Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour.
Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours.

Configure VPC Flow Logs with Amazon CloudWatch Logs Insights queries to analyze traffic volume and destination patterns during specific time windows.

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed.
Correlate security findings from multiple AWS detection services to identify multi-stage attacks.
Detect when privileged users perform an unusually high volume of resource deletion operations.
Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour.
Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours.

HOTSPOT -

某公司正在为 AWS 上现有的敏感工作负载设计其安全监控策略。安全团队已识别出若干需要监控策略的场景。

针对每个监控场景，从以下列表中选择正确的监控策略。每个监控策略只能选择一次。

在确认恶意软件检测发现后，自动隔离 Amazon EC2 实例。

将来自多个 AWS 检测服务的安全发现进行关联，以识别多阶段攻击。

检测特权用户执行异常高数量的资源删除操作的情况。

识别在 1 小时内来自特定 IP 地址的超过 50 次失败身份验证尝试的模式。

监控网络流量模式，尤其是在非正常办公时间向外部 IP 地址进行的大量数据传输。

配置 VPC 流日志，并使用 Amazon CloudWatch Logs Insights 查询在特定时间窗口内分析流量规模与目标模式。

Correct Answer:

Configure VPC Flow Logs with Amazon CloudWatch Logs Insights queries to analyze traffic volume and destination patterns during specific time windows.

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed.
Correlate security findings from multiple AWS detection services to identify multi-stage attacks.
Detect when privileged users perform an unusually high volume of resource deletion operations.
Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour.
Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours.

Create Amazon CloudWatch metric filters on application logs to track authentication failure rates for each source IP address with hourly aggregation.

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed.
Correlate security findings from multiple AWS detection services to identify multi-stage attacks.
Detect when privileged users perform an unusually high volume of resource deletion operations.
Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour.
Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours.

Enable AWS CloudTrail Insights for API call rate analysis to establish baselines and then detect anomalous API activity patterns.

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed.
Correlate security findings from multiple AWS detection services to identify multi-stage attacks.
Detect when privileged users perform an unusually high volume of resource deletion operations.
Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour.
Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours.

Implement AWS Security Hub custom insights with Amazon EventBridge rules to invoke automated AWS Lambda functions for coordinated incident response.

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed.
Correlate security findings from multiple AWS detection services to identify multi-stage attacks.
Detect when privileged users perform an unusually high volume of resource deletion operations.
Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour.
Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours.

Configure VPC Flow Logs with Amazon CloudWatch Logs Insights queries to analyze traffic volume and destination patterns during specific time windows.

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed.
Correlate security findings from multiple AWS detection services to identify multi-stage attacks.
Detect when privileged users perform an unusually high volume of resource deletion operations.
Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour.
Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours.

正确答案:

题目解析 (SCS-C03 做题教练)

1. 本题考察的知识点

监控与检测: VPC Flow Logs、CloudWatch Logs Insights、CloudWatch Metric Filters、CloudTrail Insights

安全发现的聚合与关联: AWS Security Hub (Custom Insights) 用于跨服务发现聚合、筛选与关联

自动化响应/隔离: EventBridge 触发 Lambda/SSM Automation 对实例进行隔离 (如更换/附加隔离安全组、隔离子网、限制 egress)

暴力破解/认证失败监控: 基于应用日志的指标化与阈值告警

异常 API 行为检测: CloudTrail Insights 对 API 调用率建立基线并检测异常

2. 独立思考说明 (不依赖“官方答案”)

题目是典型的“场景 → 最合适的 AWS 监控/检测/响应手段”匹配题。

每个策略只能用一次，因此要避免一个策略同时被多个场景“勉强可用”但不是最优解的情况。

3. 逐个分析每个“监控策略选项”为何正确或错误 (适用场景)

选项A: Configure VPC Flow Logs with Amazon CloudWatch Logs Insights queries to analyze traffic volume and destination patterns during specific time windows.

正确适用: 网络流量行为分析 (流量大小、目的 IP/网段、时间窗口如“非办公时间”)。

不适用: 认证失败次数 (需要应用/身份日志)、API 删除行为 (需要 CloudTrail)、跨服务发现关联 (需要 Security Hub/Detective)。

选项B: Create Amazon CloudWatch metric filters on application logs to track authentication failure rates for each source IP address with hourly aggregation.

正确适用: 统计“某 IP 在 1 小时内认证失败次数 > 50”等阈值检测 (前提: 应用/认证日志进入 CloudWatch Logs)。

不适用: 网络大流量外传 (更适合 Flow Logs)、API 删除操作 (更适合 CloudTrail)、跨服务发现关联 (更适合 Security Hub)。

选项C: Enable AWS CloudTrail Insights for API call rate analysis to establish baselines and then detect anomalous API activity patterns.

正确适用: 特权用户/角色出现“异常 API 调用量”模式 (例如突然大量 Delete* / Terminate*)。CloudTrail Insights 偏“速率异常/突增”，符合“异常高频删除操作”的监控诉求。

边界点: 若题目要求“精确统计删除操作次数并按用户阈值告警”，也可用 CloudWatch Logs Insights/Metric Filter 对 CloudTrail 日志做精确计数；但在给定选项里，CloudTrail Insights 是最贴合“异常高频”语义的能力。

不适用: 网络大流量外传 (Flow Logs)、认证失败 (应用日志 metric filter)、跨服务发现关联 (Security Hub)。

选项D: Implement AWS Security Hub custom insights with Amazon EventBridge rules to invoke automated AWS Lambda functions for coordinated incident response.

正确适用 (两类): 1) **关联/汇总发现:** Security Hub 聚合 GuardDuty、Inspector、Macie 等 findings，再用 Custom Insights 做筛选/关联视图；2) **自动化响应:** 通过 EventBridge 订阅 Security Hub Findings (或 Insight 结果) 触发 Lambda 执行响应动作。

在本题最佳适用: 更偏向“跨服务发现关联、多阶段攻击识别”。因为题干明确提“Correlate security findings from multiple AWS detection services”。

不适用: 纯网络流量统计、认证失败计数、API 速率异常检测 (各有更直接服务)。

选项E (用于补齐隔离场景的典型策略): Use EventBridge to react to GuardDuty malware detection findings and invoke Lambda/SSM Automation to quarantine/isolate the EC2 instance (e.g., replace security groups, restrict egress, isolate subnet).

正确适用: 当“恶意软件检测发现确认”后，自动执行隔离 (准实时响应、最小人工介入)。

说明: 题干场景是“malware detection findings confirmed”，最常见来源是 GuardDuty (含 Malware Protection for EC2 相关发现) 或 Inspector 相关发现进入 Security Hub 后自动化处理。

不适用: 跨服务发现关联 (Security Hub Insight 更合适)、网络流量统计 (Flow Logs)、认证失败 (Metric Filter)、API 异常 (CloudTrail Insights)。

4. 我选择的答案 (按“监控场景 → 监控策略”逐一匹配)

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed. → **选项E** (EventBridge + Lambda/SSM Automation 基于 GuardDuty/恶意软件发现自动隔离实例)

Correlate security findings from multiple AWS detection services to identify multi-stage attacks. → **选项D** (Security Hub Custom Insights + EventBridge (可联动自动化))

Detect when privileged users perform an unusually high volume of resource deletion operations. → **选项C** (CloudTrail Insights 异常 API 调用率/模式)

Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour. → **选项B** (CloudWatch Metric Filters 基于应用日志按 IP 做小时聚合)

Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours. → **选项A** (VPC Flow Logs + CloudWatch Logs Insights 按时间窗口分析目的地址与流量)

5. 题目中给出的“官方正确答案” (原样列出)

Monitor network traffic patterns especially large data transfers to external IP addresses outside normal office hours.

Identify patterns of more than 50 failed authentication attempts from specific IP addresses in 1 hour.

Detect when privileged users perform an unusually high volume of resource deletion operations.

Automatically isolate Amazon EC2 instances when malware detection findings are confirmed.

Correlate security findings from multiple AWS detection services to identify multi-stage attacks.

6. 与“官方答案”对比与复盘

对比结果: 不一致。

原因: 你提供的“官方正确答案”列表本身是**5个监控场景** (题干左侧要匹配的对象)，而不是“5个监控策略”。

因此该“官方答案”无法用于校验“场景 → 策略”的匹配是否正确，属于**答案内容类型放错**。

重新思考结论: 在不依赖该“官方答案”的前提下，我给出的匹配是各场景在 AWS 上最直接、最常用、且与选项语义最贴合的实现路径。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #9

Topic 1

A company needs a solution to protect critical data from being permanently deleted. The data is stored in Amazon S3 buckets. The company needs to replicate the S3 objects from the company's primary AWS Region to a secondary Region to meet disaster recovery requirements. The company must also ensure that users who have administrator access cannot permanently delete the data in the secondary Region.

Which solution will meet these requirements?

一家公司需要一个解决方案来保护关键数据，使其不会被永久删除。数据存储在 Amazon S3 存储桶中。

公司需要将 S3 对象从公司的主 AWS 区域复制到次要区域，以满足灾难恢复要求。公司还必须确保即使拥有管理员访问权限的用户也无法在次要区域永久删除数据。

哪种解决方案将满足这些要求？

A. Configure AWS Backup to perform cross-Region S3 backups. Select a backup vault in the secondary Region. Enable AWS Backup Vault Lock in governance mode for the backups in the secondary Region.

配置 AWS Backup 执行跨区域的 S3 备份。选择次要区域中的备份保管库。为次要区域中的备份启用 AWS Backup Vault Lock 的治理模式。

B. Implement S3 Object Lock in compliance mode in the primary Region. Configure S3 replication to replicate the objects to an S3 bucket in the secondary Region.

在主区域中以合规模式实施 S3 Object Lock。配置 S3 复制，将对象复制到次要区域中的一个 S3 存储桶。

C. Configure S3 replication to replicate the objects to an S3 bucket in the secondary Region. Create an S3 bucket policy to deny the s3:ReplicateDelete action on the S3 bucket in the secondary Region.

配置 S3 复制，将对象复制到次要区域中的一个 S3 存储桶。创建一个 S3 存储桶策略，以拒绝在次要区域的 S3 存储桶上执行 s3:ReplicateDelete 操作。

D. Configure S3 replication to replicate the objects to an S3 bucket in the secondary Region. Configure S3 object versioning on the S3 bucket in the secondary Region.

配置 S3 复制，将对象复制到次要区域中的一个 S3 存储桶。在次要区域的 S3 存储桶上配置 S3 对象版本控制。

Correct Answer: A

正确答案: A

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

Amazon S3 跨区域复制 (CRR) 用于灾备 (DR)

防止永久删除 (Immutability/WORM) 的手段对比: S3 Object Lock vs S3 Versioning vs AWS Backup Vault Lock

治理模式 (Governance) 与 **合规模式 (Compliance)** 在“管理员是否仍可删除/绕过”方面的差异

S3 删除语义：删除标记（Delete Marker）、删除版本（Delete Version）与“永久删除”

2. 独立思考（不参考官方答案）

题目要求两件事：(1) 将主区域 S3 对象复制到次区域满足灾备；(2) 次区域中即使是管理员也**不能永久删除**数据。

要满足“管理员也不能永久删除”，一般需要**不可变存储（WORM）**能力：

S3 Object Lock（Compliance 模式）：在保留期内任何人（包括管理员）都不能删除受保护对象版本。

AWS Backup Vault Lock（Compliance 模式）：在保留期内任何人不能删除恢复点。

仅用 S3 Versioning 或 Bucket Policy 通常无法做到“管理员也不能永久删除”，因为管理员可修改策略/权限并删除对象版本。

3. 逐个选项分析

A. AWS Backup 跨区域 S3 备份 + 次区域 Vault Lock（governance mode）

优点：AWS Backup 支持 S3 备份并可跨区域复制到次区域的 Backup Vault，用于灾备是可行思路。

关键问题：题干要求“管理员也不能永久删除”。Vault Lock 的 **Governance mode（治理模式）** 并不是“任何人都不能删”，它允许具备特定权限的主体绕过保留限制（例如授予相关绕过能力时）。因此治理模式无法严格满足“管理员不能永久删除”的强约束（更符合的是 **Compliance mode**）。

结论：不满足题干“管理员也不能永久删除”的强要求（因为是 governance mode）。

B. 主区域 S3 Object Lock（compliance mode）+ 复制到次区域 Bucket

优点：Object Lock 的 **Compliance mode** 是典型的 WORM 机制，在保留期内可防止任何用户（包括管理员）永久删除受保护对象版本。

需要注意的实现点（题目未写全但现实中必须）：

目标（次区域）Bucket 必须在创建时启用 **Object Lock** 且必须启用 **Versioning**。

CRR 需要正确配置，且需要考虑是否复制 Object Lock 的保留信息/法律保全（实际服务能力支持，但配置与前提要满足）。

对题干匹配度：

跨区域复制：满足。

管理员不可永久删除：在采用 Object Lock Compliance 的前提下满足（WORM）。

结论：在给定选项中，**最符合**“管理员也不能永久删除”的要求。

C. CRR + Bucket Policy 拒绝 s3:ReplicateDelete

该策略的作用：阻止复制过程把“源桶删除”同步为“目标桶删除”（即阻止 replication 端执行 ReplicateDelete）。

关键问题：题干要求阻止的是**管理员**在次区域永久删除数据，而不是阻止“复制删除”动作。管理员仍可直接在次区域对对象版本执行删除（或先改策略再删）。

结论：不满足“管理员也不能永久删除”。

D. CRR + 次区域开启 Versioning

优点：Versioning 能缓解“误删”，因为普通删除会产生 Delete Marker，可回滚。

关键问题：管理员可以删除特定版本（DeleteObjectVersion）从而实现**永久删除**；也可清理所有版本。

结论：不满足“管理员也不能永久删除”。

4. 我选择的答案

B

5. 官方答案

A

6. 与官方答案对比与复盘

结论：我与官方答案不同（我选 B，官方选 A）。

重新思考关键点：题干的硬约束是“用户即使有管理员访问权限也不能永久删除次区域数据”。

A 使用的是 **Vault Lock governance mode**，治理模式通常允许具备特定权限的主体绕过保留限制，因此不满足“管理员也不能永久删除”的绝对约束。

若 A 改成 **Vault Lock compliance mode** 才更严格符合题意，但选项明确写的是 governance mode。

B 使用 **S3 Object Lock compliance mode** 是典型的不可变方案，更贴合“管理员也不能永久删除”。虽然选项没有显式写明次区域桶也要启用 Object Lock（现实中必须），但在四个选项里，只有 B 的技术方向能实现“管理员也无法永久删除”。

因此我仍维持选择 B，并认为官方给的 A（governance mode）与题干“管理员不能永久删除”的强约束不一致；更可能是官方题目/答案在 governance vs compliance 模式上出现偏差或简化。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #10

Topic 1

A security engineer is responding to an incident that is affecting an AWS account. The ID of the account is 1234156789012. The attack created workloads that are distributed across multiple AWS Regions.

The security engineer contains the attack. The security engineer removes all compute and storage resources from all affected Regions. However, the attacker also created an AWS KMS key. The key policy on the KMS key explicitly allows IAM principal kms:* permissions.

The key was scheduled to be deleted the previous day. However, the key is still enabled and usable. The key has an ARN of `arn:aws:kms:us-east-2:123456789012:key/mrk-0bb0212cd9864fdea0dcamzo26efb5670`. The security engineer must delete the key as quickly as possible.

Which solution will meet this requirement?

一名安全工程师正在响应一起影响某个 AWS 账户的事件。该账户的 ID 为 1234156789012。此次攻击创建了分布在多个 AWS 区域中的工作负载。

安全工程师已遏制了攻击。安全工程师从所有受影响的区域中移除了所有计算和存储资源。然而，攻击者还创建了一个 AWS KMS 密钥。该 KMS 密钥上的密钥策略显式允许 IAM 主体拥有 kms:* 权限。

该密钥在前一天已被计划删除。但是，该密钥仍处于启用状态且可用。该密钥的 ARN 为 `arn:aws:kms:us-east-2:123456789012:key/mrk-0bb0212cd9864fdea0dcamzo26efb5670`。安全工程师必须尽快删除该密钥。

哪种解决方案将满足此要求？

A. Log in to the account by using the account root user credentials. Re-issue the deletion request for the KMS key with a waiting period of 7 days.

使用账户根用户凭证登录该账户。以 7 天等待期重新发起对该 KMS 密钥的删除请求。

B. Identify the other Regions where the KMS key ID is present and schedule the key for deletion in 7 days.

识别其他存在该 KMS 密钥 ID 的区域，并将该密钥安排在 7 天后删除。

C. Update the IAM principal to allow kms:* permissions on the KMS key ARN. Re-issue the deletion request for the KMS key with a waiting period of 7 days.

更新 IAM 主体以允许其在该 KMS 密钥 ARN 上拥有 kms:* 权限。以 7 天等待期重新发起对该 KMS 密钥的删除请求。

D. Disable the KMS key. Re-issue the deletion request for the KMS key in 30 days.

禁用该 KMS 密钥。以 30 天等待期重新发起对该 KMS 密钥的删除请求。

Correct Answer: B

正确答案: B

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

AWS KMS Multi-Region Key (MRK, 多区域密钥) 的行为: ARN/KeyId 以 **mrk-** 开头表示这是多区域密钥 (Multi-Region key)。

ScheduleKeyDeletion 的等待期机制: KMS 密钥删除必须设置等待期, 最短 **7 天**, 最长 **30 天**; 在等待期内密钥仍可能可用 (不会立即删除)。

MRK 的删除是“按区域分别进行”的: 主密钥与每个区域的副本 (replica) 都需要分别执行删除计划; 删除某一个区域并不会自动删除其他区域的副本。

2. 独立思考 (不参考官方答案)

题目给出的 Key ARN: `arn:aws:kms:us-east-2:123456789012:key/mrk-0bb0212cd9864fdea0dcamzo26efb5670` (虽然分隔符写成了分号, 但关键信息是 **mrk-** 前缀)。

“The key was scheduled to be deleted the previous day. However, the key is still enabled and usable.” 这在 KMS 是正常现象: 即使已请求删除, 仍需等待至少 7 天, 在等待期内密钥仍可能保持可用。

攻击在多个 Region 创建了工作负载; 如果这是 MRK, 则很可能还存在其他 Region 的 replica key。要“尽快删除该密钥”, 就必须确保所有区域的 MRK 实例都进入删除流程, 否则其他区域的副本仍可被使用。

3. 逐个选项分析

A. 以根用户登录并以 7 天等待期重新发起删除请求

优点: 7 天是最短等待期, 符合“尽快删除”的时间下限。

问题 1 (关键): 该选项只处理了**单一 Region 的该 Key**; 对 MRK 而言, 其他 Region 的 replica 不会因此删除, 仍可能可用。

问题 2: 题目并未表明当前删除等待期不是 7 天; 如果昨天已经以 7 天发起删除, 那么“重新发起”并不一定更快。

结论: 不能确保“尽快删除”覆盖多 Region 的 MRK 全部实例, 因此不选。

B. 找出其他存在该 KMS Key ID 的 Region, 并将该密钥安排在 7 天后删除

优点 1 (命中核心): MRK 的主密钥/副本密钥是按 Region 存在的, 要尽快彻底删除, 必须在**每个存在该 MRK 的 Region 分别 Schedule deletion**。

优点 2: 7 天等待期是最短值, 满足“尽快”。

注意点: 该选项文字强调“其他 Regions”, 而题干已经说明“该 key 昨天已被 schedule 删除”, 因此当前 Region (us-east-2) 可能已在删除队列中; 此时剩余工作就是处理其他 Region 的 replica。

结论: 最符合“多 Region 分布 + 尽快删除”的真实需求, 因此选择。

C. 更新 IAM 主体允许其对该 Key ARN 拥有 kms:*, 然后以 7 天等待期重新发起删除请求

问题 1: 题干已说明“key policy 显式允许某 IAM principal kms:*”, 这通常是攻击者主体; 此选项是“允许某 IAM 主体 kms:*”, 方向上更像是**扩大权限**, 并不能直接解决“删除 MRK 的所有区域实例”。

问题 2 (机制): KMS 授权是**Key policy + IAM policy 共同作用**; 单纯“更新 IAM 主体”并不等于能获得对 KMS Key 的管理权 (若 Key policy 不授予你, 仍可能无权)。

问题 3: 同 A 一样仅处理单区域描述, 未解决 MRK 多区域副本删除。

结论: 不选。

D. 禁用该 KMS Key, 并以 30 天等待期重新发起删除请求

问题 1: 等待期 30 天不是“尽快”, 与要求相反 (最短应为 7 天)。

问题 2: 即使禁用, 也未解决 MRK 在其他 Region 的副本问题。

结论: 不选。

4. 我选择的答案

B

5. 官方答案

B

6. 与官方答案对比与复盘

我的答案 = 官方答案: B。

原因复盘: 题目关键线索是 KeyId 前缀 **mrk-** (Multi-Region Key) + 攻击影响多个 Region。要“尽快删除”必须对所有存在该 MRK 的 Region 分别发起最短等待期 (7 天) 的删除计划; 否则其他 Region 的 replica 仍可继续被使用。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #11

Topic 1

A company has installed a third-party application that is distributed on several Amazon EC2 instances and on-premises servers. Occasionally, the company's IT team needs to use SSH to connect to each machine to perform software maintenance tasks. Outside these time slots, the machines must be completely isolated from the rest of the network. The company does not want to maintain any SSH keys. Additionally, the company wants to pay only for machine hours when there is an SSH connection. Which solution will meet these requirements?

一家公司已安装一个第三方应用程序，该应用程序分布在多台 Amazon EC2 实例和本地服务器上。公司 IT 团队偶尔需要使用 SSH 连接到每台机器以执行软件维护任务。在这些时间段之外，机器必须与网络的其余部分完全隔离。公司不想维护任何 SSH 密钥。此外，公司希望仅在存在 SSH 连接时为机器小时付费。哪种解决方案将满足这些要求？

A. Create a bastion host with port forwarding to connect to the machines.

创建一个堡垒主机并使用端口转发连接到这些机器。

B. Set up AWS Systems Manager Session Manager to allow temporary connections.

配置 AWS Systems Manager Session Manager 以允许临时连接。

C. Use AWS CloudShell to create serverless connections.

使用 AWS CloudShell 创建无服务器连接。

D. Set up an interface VPC endpoint for each machine for private connection.

为每台机器设置一个接口 VPC 端点以进行私有连接。

Correct Answer: B

正确答案: B

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

AWS Systems Manager Session Manager: 无须开放入站端口、无须管理SSH密钥、基于IAM的临时运维访问。

网络隔离与最小暴露面: 在不需要运维时将实例从网络层面“隔离”(至少不对其他网络开放管理入口)。

混合环境管理 (Hybrid Activations / Managed Instances): 同时管理EC2与本地服务器，通过SSM Agent进行受控连接。

按需付费思路: 运维时间才需要实例运行 (EC2可停止/启动)，从而只为运行小时付费；运维连接本身不引入额外的“按连接计费”的SSH跳板成本。

2. 独立思考 (不参考官方答案)

题目核心约束是：**偶尔需要SSH运维、其余时间机器必须隔离、不维护SSH密钥**，并希望成本尽量与“需要连接的时间”对齐。

在AWS上满足“无SSH密钥 + 不开入站SSH + 临时访问”的标准做法是**SSM Session Manager** (含端口转发/SSH over SSM能力)。

对“完全隔离”的理解：在典型考试语境中是指**不对网络开放SSH等管理入口**，而不是字面意义“断网”。Session Manager仍需要主机通过SSM通道出站（可走VPC Endpoint以避免公网）。

3. 逐个选项分析

A. Create a bastion host with port forwarding 错误。 原因：

堡垒机方案通常仍依赖SSH密钥/账号管理（题目明确“不想维护任何SSH keys”）。

需要开放网络路径（至少到堡垒机的22端口或其他入站），与“其余时间完全隔离”的目标相违背（你可以关端口/改安全组，但仍在维护SSH体系与入口面）。

堡垒机本身是长期资源，增加运维与攻击面；也不满足“只在SSH连接时才产生机器小时费用”的直觉诉求（堡垒机通常需要常驻或至少额外管理启停）。

B. Set up AWS Systems Manager Session Manager to allow temporary connections 正确。 原因：

无需SSH密钥：通过IAM权限控制会话建立，不需要分发/轮换SSH key。

无需开放入站SSH端口：Session Manager不要求对实例开放22端口入站，显著降低暴露面，满足“非维护时隔离/不暴露”。

可覆盖EC2与本地服务器：本地服务器安装SSM Agent并注册为Managed Instance即可统一用Session Manager运维。

临时访问：可用IAM、Session Manager偏好设置、会话日志审计（CloudTrail/CloudWatch Logs/S3）实现强管控与审计。

费用诉求：Session Manager本身不要求持续运行额外跳板机；EC2可在维护窗口才启动（只产生运行小时费用）。

网络隔离强化（常见最佳实践）：在VPC内用**VPC Interface Endpoints**访问SSM相关服务（ssm、ssmmessages、ec2messages），做到不经公网也可会话连接，同时仍不开放任何入站SSH。

C. Use AWS CloudShell to create serverless connections 错误。 原因：

CloudShell是AWS控制台内的临时Shell环境，并不是一种“免密、免网络暴露地SSH进每台机器”的连接通道。

即使从CloudShell发起SSH，也仍然需要目标可达（网络路由/安全组/NACL/入站端口）以及凭据（密钥或口令），不满足“不维护SSH keys”。

CloudShell无法解决“非维护时机器完全隔离但仍可随时临时进入”的受控通道问题。

D. Set up an interface VPC endpoint for each machine for private connection 错误。 原因：

Interface VPC Endpoint是**针对AWS服务**（如SSM、S3、KMS等）而不是“给每台机器建一个endpoint”。概念不成立。

VPC Endpoint本身不提供SSH会话能力；即便使用endpoint实现私网访问，也需要上层方案（如SSM Session Manager）来达成“免密临时运维”。

对本地服务器也不适用“为每台机器建VPC endpoint”的说法。

4. 我选择的答案

B

5. 官方答案

B

6. 与官方答案比较与复盘

我的答案：**B**；官方答案：**B**；结论：**一致**。

补充说明：题干“完全隔离”若被极端理解为“主机完全无任何网络出站”，则任何远程管理（包括Session Manager）都无法建立；但在AWS考试语境中通常指**不开放入站管理端口/不与其他网络互通**，允许仅通过受控管理通道（SSM）实现临时访问，因此B最符合题意。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #12

Topic 1

A company runs several applications on Amazon Elastic Kubernetes Service (Amazon EKS). The company needs a solution to detect any Kubernetes security risks by monitoring Amazon EKS audit logs in addition to operating system, networking, and file events. The solution must send email alerts for any identified risks to a mailing list that is associated with a security team. Which solution will meet these requirements?

一家公司在 Amazon Elastic Kubernetes Service (Amazon EKS) 上运行多个应用程序。该公司需要一种解决方案，通过监控 Amazon EKS 审计日志以及操作系统、网络和文件事件，来检测任何 Kubernetes 安全风险。该解决方案必须针对任何已识别的风险向与安全团队关联的邮件列表发送电子邮件告警。
哪种解决方案将满足这些要求？

A. Deploy AWS Security Hub and enable security standards that contain EKS controls. Create an Amazon Simple Notification Service (Amazon SNS) topic and set the security team's mailing list as a subscriber. Use an Amazon EventBridge rule to send relevant Security Hub events to the SNS topic.

部署 AWS Security Hub 并启用包含 EKS 控制项的安全标准。创建一个 Amazon Simple Notification Service (Amazon SNS) 主题，并将安全团队的邮件列表设置为订阅者。使用 Amazon EventBridge 规则将相关的 Security Hub 事件发送到该 SNS 主题。

B. Enable Amazon Inspector container image scanning. Configure Amazon Detective to analyze EKS security logs. Create Amazon CloudWatch log groups for EKS audit logs. Use an AWS Lambda function to process the logs and to send email alerts to the security team.

启用 Amazon Inspector 容器镜像扫描。配置 Amazon Detective 来分析 EKS 安全日志。为 EKS 审计日志创建 Amazon CloudWatch 日志组。使用 AWS Lambda 函数处理这些日志并向安全团队发送电子邮件告警。

C. Enable Amazon GuardDuty. Enable EKS Protection and Runtime Monitoring for Amazon EKS in GuardDuty. Create an Amazon Simple Notification Service (Amazon SNS) topic and set the security team's mailing list as a subscriber. Use an Amazon EventBridge rule to send relevant GuardDuty events to the SNS topic.

启用 Amazon GuardDuty，在 GuardDuty 中为 Amazon EKS 启用 EKS 保护和运行时监控。创建一个 Amazon Simple Notification Service (Amazon SNS) 主题，并将安全团队的邮件列表设置为订阅者。使用 Amazon EventBridge 规则将相关的 GuardDuty 事件发送到该 SNS 主题。

D. Install the AWS Systems Manager Agent (SSM Agent) on all EKS nodes. Configure Amazon CloudWatch Logs to collect EKS audit logs. Create an Amazon Simple Notification Service (Amazon SNS) topic and set the security team's mailing list as a subscriber. Configure a CloudWatch alarm to publish a message to the SNS topic when new audit logs are generated.

在所有 EKS 节点上安装 AWS Systems Manager Agent (SSM Agent)。配置 Amazon CloudWatch Logs 以收集 EKS 审计日志。创建一个 Amazon Simple Notification Service (Amazon SNS) 主题，并将安全团队的邮件列表设置为订阅者。配置一个 CloudWatch 告警，在生成新的审计日志时向该 SNS 主题发布一条消息。

Correct Answer: C

正确答案: C

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

Amazon GuardDuty for EKS能力边界：EKS Protection（基于Kubernetes审计日志发现威胁）与 Runtime Monitoring（基于运行时/主机层面的行为事件：进程、网络、文件等）。

Amazon EKS audit logs与威胁检测：如何将审计日志用于安全风险识别（不是“有日志就告警”，而是“识别风险事件再告警”）。

告警通知链路：EventBridge 规则捕获安全服务（GuardDuty/Security Hub）发现（Findings）→ SNS → Email订阅。

区分：Security Hub（聚合/合规控制/Findings汇总）vs GuardDuty（威胁检测）vs Detective（调查分析）vs Inspector（漏洞/镜像扫描）vs CloudWatch Alarm（指标阈值告警）。

2. 独立思考（不参考官方答案）

题目要求同时覆盖：**Kubernetes安全风险（通过EKS审计日志） + 操作系统、网络、文件事件**，并对识别出的风险发送邮件告警。在AWS原生服务中，同时具备“EKS审计日志威胁检测”与“运行时OS/网络/文件级行为监控”的核心服务是 **GuardDuty 的 EKS Protection + Runtime Monitoring** 组合。

告警发送到邮件列表，最标准路径是 **EventBridge → SNS (Email订阅)**。

3. 逐个选项分析

A. Security Hub + 标准控制项 + EventBridge → SNS Email 结论：不满足（偏合规/控制，不等同于审计日志+运行时事件威胁检测）。 原因：

Security Hub 的 EKS 相关内容主要是**安全最佳实践/合规控制检查**与聚合Findings，不是专门做“监控EKS审计日志以发现Kubernetes攻击行为”的引擎。

题干明确要求“通过监控 EKS audit logs 检测 Kubernetes security risks”，以及“额外监控 OS、networking、file events”。Security Hub本身不提供这类运行时行为检测能力。

通知链路（EventBridge→SNS）是对的，但检测能力不匹配题意。

B. Inspector 镜像扫描 + Detective 分析EKS安全日志 + CloudWatch Logs + Lambda发邮件 结论：不满足（服务能力组合不成立，Detective不用于“配置分析EKS日志进行检测”，且缺少运行时OS/文件事件检测闭环）。 原因：

Amazon Inspector 容器镜像扫描属于**漏洞管理（CVEs）**，不等同于“通过审计日志与运行时事件检测攻击风险”。

Amazon Detective 的定位是**安全调查与溯源分析**（通常基于GuardDuty/Security Hub等信号进行图谱关联调查），并非用于“配置它去分析EKS审计日志并产生检测告警”的主要检测引擎。

即使把审计日志送到CloudWatch Logs，再用Lambda自己写规则检测并发送邮件，理论上可行，但题目更偏向考察**AWS托管威胁检测服务**的正确选择；同时该选项并未解决“操作系统、网络、文件事件”这一运行时监控的完整数据源与检测能力（仅提到audit logs）。

整体是“拼凑方案”，但与AWS产品标准能力叙述不吻合，风险点多。

C. GuardDuty + 启用 EKS Protection 和 Runtime Monitoring + EventBridge → SNS Email 结论：满足（最贴合题干的原生托管检测与告警链路）。 原因：

EKS Protection：用于检测Kubernetes层面的可疑行为/风险，核心数据源之一就是**EKS audit logs**（满足“监控EKS审计日志识别Kubernetes安全风险”）。

Runtime Monitoring：覆盖运行时层面的**操作系统/进程、网络连接、文件活动**等信号（满足“additional to operating system, networking, and file events”）。

GuardDuty 产生 Findings 后，通过 **EventBridge 规则**筛选并投递到 **SNS topic**，SNS 订阅邮件列表即可实现**Email告警**。

整体为标准AWS安全检测→事件总线→通知的最佳实践链路。

D. SSM Agent + CloudWatch Logs收集审计日志 + CloudWatch Alarm对“新日志生成”告警 + SNS Email 结论：不满足（只能对“有新日志”告警，不能对“识别出的风险”告警；也不覆盖OS/网络/文件风险检测）。 原因：

题目要的是**检测Kubernetes security risks**，不是“只要有新审计日志就发邮件”。新日志生成是常态，会造成大量无意义告警。

CloudWatch Alarm主要基于**指标阈值**，对日志的“安全语义检测”需要额外的日志分析/检测服务（如GuardDuty等）或复杂的日志度量过滤与规则体系；该选项未提供“风险识别”的机制。

SSM Agent的安装与题意（EKS审计日志+运行时事件威胁检测）无直接对应；且无法自然满足“networking、file events”的风险检测闭环。

4. 我选择的答案

C

5. 官方答案

C

6. 与官方答案对比与复盘

对比结果：一致（我选C，官方也为C）。

复盘原因：

题干关键词“EKS audit logs + OS/Network/File events + 发现风险后邮件告警”几乎直接指向 GuardDuty 的 **EKS Protection** 与 **Runtime Monitoring** 组合，以及 EventBridge→SNS 的通知路径。

其他选项要么是合规聚合（Security Hub），要么是漏洞扫描/调查工具（Inspector/Detective），要么是“有日志就告警”的错误告警模型（CloudWatch Alarm）。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #13

Topic 1

A company allows users to download its mobile app onto their phones. The app is MQTT based and connects to AWS IoT Core to subscribe to specific client-related topics.

Recently, the company discovered that some malicious attackers have been trying to get a Trojan horse onto legitimate mobile phones. The Trojan horse poses as the authentic application and uses a client ID with injected special characters to gain access to topics outside the client's privilege scope.

Which combination of actions should the company take to prevent this threat? (Choose two.)

一家公司允许用户将其移动应用下载到手机上。该应用基于 MQTT，并连接到 AWS IoT Core 来订阅特定的与客户端相关的主题。最近，该公司发现一些恶意攻击者一直试图在合法的手机上植入特洛伊木马。该特洛伊木马伪装成正版应用，并使用带有注入特殊字符的客户端 ID，以获取对超出该客户端权限范围的主题的访问权限。

公司应采取哪组措施来防止此威胁？（选择两项。）

A. In the application, use an IoT thing name as the client ID to connect the device to AWS IoT Core.

在应用中，使用 IoT thing 名称作为客户端 ID，将设备连接到 AWS IoT Core。

B. In the application, add a client ID check. Disconnect from the server if any special character is detected.

在应用中，添加客户端 ID 检查。如果检测到任何特殊字符，则从服务器断开连接。

C. Apply an AWS IoT Core policy that allows "AWSIoTWirelessDataAccess" with the principal set to

"client/\${iot:Connection.Thing.ThingName}"

应用一个 AWS IoT Core 策略，允许 "AWSIoTWirelessDataAccess"，并将主体（principal）设置为

"client/\${iot:Connection.Thing.ThingName}"

D. Apply an AWS IoT Core policy to the device to allow "iot:Connect" with the resource set to "client/\${iot:ClientId}".

对设备应用一个 AWS IoT Core 策略，允许 "iot:Connect"，并将资源（resource）设置为 "client/\${iot:ClientId}"。

E. Apply an AWS IoT Core policy to the device to allow "iot:Connect" with the resource set to

"client/\${iot:Connection.Thing.ThingName}".

对设备应用一个 AWS IoT Core 策略，允许 "iot:Connect"，并将资源（resource）设置为

"client/\${iot:Connection.Thing.ThingName}"。

Correct Answer: AE

正确答案: AE

题目解析 (AWS Certified Security - Specialty SCS-C03 | 做题教练)

1. 本题考察的知识点

AWS IoT Core MQTT 连接鉴权: 通过 IoT policy 控制客户端是否能执行 iot:Connect。

Client ID (MQTT ClientId) 与权限边界：攻击者通过构造特殊字符/注入式 ClientId，尝试“越权”访问不属于自己的 Topic（常见于把 ClientId 拼进 Topic 或策略变量使用不当）。

IoT policy 变量的正确使用：`{iot:ClientId}` vs `{iot:Connection.Thing.ThingName}` 的差异与安全含义。

将身份绑定到受控实体：用证书映射到 Thing（ThingName）并强制连接时 ClientId 与 ThingName 一致，从源头消除“自选 ClientId”带来的注入/冒用风险。

2. 独立思考（不参考官方答案）

攻击本质：恶意程序伪装成合法 App，使用“带特殊字符的 ClientId”来突破原有的按 ClientId/Topic 隔离的设计。

要有效防御，应在**服务端（IoT Core policy）**强制约束：连接时的 ClientId 必须与该证书所关联的 ThingName 一致（或至少限定在可控集合）。

仅在客户端做校验（如检测特殊字符）不可靠：恶意程序不会遵守你的客户端逻辑。

3. 逐个选项分析

A. 在应用中使用 IoT thing name 作为 client ID

结论：正确（需要与服务端策略配合）

原因：将 ClientId 选择权从“任意字符串”收敛到“受 AWS IoT 管控的 ThingName”。若再配合策略要求“ClientId 必须等于该连接对应 ThingName”，即可阻止攻击者通过构造特殊字符 ClientId 来制造越权路径。

B. 应用中检测 client ID 特殊字符，检测到就断开

结论：错误

原因：这是**客户端自律**，对恶意 Trojan 无效（攻击者可以绕过/不实现该检查）。安全控制应落在 IoT policy（服务端强制）上。最多属于“额外加固”，但不能作为防止该威胁的关键措施。

C. 允许 “AWSIoTWirelessDataAccess” 且 principal 为 “client/{iot:Connection.Thing.ThingName}”

结论：错误

原因1：**AWSIoTWirelessDataAccess** 是与 AWS IoT Wireless（LoRaWAN/Sidewalk 等）数据面相关的受管策略/权限概念，和题目描述的 MQTT ClientId 注入导致的 topic 越权不匹配。

原因2：IoT Core policy 的关键动作应是 `iot:Connect` / `iot:Subscribe` / `iot:Receive` / `iot:Publish`，并用 resource/condition 绑定身份与主题范围。

D. 允许 `iot:Connect`，resource 为 “client/{iot:ClientId}”

结论：错误

原因：`{iot:ClientId}` 取值来自“连接请求里客户端自己声明的 ClientId”。这条策略的效果等价于：“**你想用什么 ClientId 连接都行**”（只要该证书能用这条 policy）。它并没有把 ClientId 绑定到受控身份（ThingName），无法防止攻击者构造带特殊字符的 ClientId。

E. 允许 `iot:Connect`，resource 为 “client/{iot:Connection.Thing.ThingName}”

结论：正确

原因：`{iot:Connection.Thing.ThingName}` 来自**当前证书认证后所关联的 Thing**（通过证书与 Thing 的关联/Principal attachment）。这样就能强制：**只有当连接时使用的 ClientId 等于该 ThingName 时，才允许 `iot:Connect`**。攻击者即便注入特殊字符，也无法通过 `iot:Connect` 的授权检查。

4. 我选择的答案（Choose two）

A

E

5. 官方答案

A、E

6. 与官方答案对比与复盘

对比结果：一致（我选 AE，官方也为 AE）

原因总结：A 负责让客户端使用可控且规范的 ClientId（ThingName）；E 负责在服务端用 IoT policy 强制绑定“证书所属 ThingName”与“连接时 ClientId”，从而阻断恶意构造 ClientId（含特殊字符/注入）的越权路径。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #14

Topic 1

A security engineer wants to evaluate configuration changes to a specific AWS resource to ensure that the resource meets compliance standards. However, the security engineer is concerned about a situation in which several configuration changes are made to the resource in quick succession. The security engineer wants to record only the latest configuration of that resource to indicate the cumulative impact of the set of changes.

Which solution will meet this requirement in the MOST operationally efficient way?

一名安全工程师想要评估对特定 AWS 资源的配置更改, 以确保该资源满足合规标准。但是, 该安全工程师担心一种情况: 在短时间内对该资源进行了多次配置更改。该安全工程师希望仅记录该资源的最新配置, 以表明这一组更改的累积影响。哪种解决方案能够以最高的运营效率满足此要求?

A. Use AWS CloudTrail to detect the configuration changes by filtering API calls to monitor the changes. Use the most recent API call to indicate the cumulative impact of multiple calls.

使用 AWS CloudTrail 通过筛选 API 调用来检测配置更改并监控这些更改。使用最新的 API 调用来表示多次调用的累积影响。

B. Use AWS Config to detect the configuration changes and to record the latest configuration in case of multiple configuration changes.

使用 AWS Config 来检测配置更改, 并在发生多次配置更改时记录最新配置。

C. Use Amazon CloudWatch to detect the configuration changes by filtering API calls to monitor the changes. Use the most recent API call to indicate the cumulative impact of multiple calls.

使用 Amazon CloudWatch 通过筛选 API 调用来检测配置更改并监控这些更改。使用最新的 API 调用来表示多次调用的累积影响。

D. Use AWS Cloud Map to detect the configuration changes. Generate a report of configuration changes from AWS Cloud Map to track the latest state by using a sliding time window.

使用 AWS Cloud Map 来检测配置更改。从 AWS Cloud Map 生成配置更改报告, 通过使用滑动时间窗口来跟踪最新状态。

Correct Answer: B

正确答案: B

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

AWS Config 的能力边界: 持续记录资源配置 (Configuration Item, CI)、提供配置历史与当前配置、支持合规评估。

配置变更频繁场景下的“最终状态/最新状态”: 当短时间内发生多次变更时, 如何以资源的**最新配置**代表一系列变更的累计影响, 而不是逐条事件推导。

CloudTrail vs AWS Config 的定位差异: CloudTrail侧重“谁在何时调用了什么API” (事件审计); AWS Config侧重“资源最终是什么配置” (状态记录与合规)。

2. 独立思考（不参考官方答案）

题目要求是：检测配置变更，同时当快速连续变更发生时，只需要记录该资源的**最新配置**来体现累计影响，并且要**最省运维**。
要满足“最新配置”这一点，最直接的是使用**AWS Config**，因为它以资源配置状态为核心，天然可提供资源的当前配置与配置历史；相比之下，CloudTrail是API事件流，想得到最终状态需要额外聚合/重放/推导。

3. 逐个选项分析

A. CloudTrail + 过滤API调用 + 用最新API表示累计影响

问题1：CloudTrail记录的是事件而非资源最终配置状态。单靠“最后一条API调用”并不一定能代表资源最终状态（例如有多个属性分别通过不同API修改；或者一次API只改变部分字段）。

问题2：需要自建逻辑去关联/聚合。要可靠得到“最新配置”，通常要解析事件、按资源ID聚合、处理乱序/重试、并可能需要再调用Describe类API获取真实状态，运维成本更高。

结论：不满足“最省运维”且“最新API=最终配置”假设不可靠，因此错误。

B. AWS Config 检测变更，并在多次变更时记录最新配置

符合点1：AWS Config专门用于记录资源配置与变更，可以持续记录配置项（CI），并提供资源的当前配置与历史。

符合点2：能以“最新配置状态”表达累计影响。即使短时间多次修改，AWS Config最终会记录资源在该时间点的最新配置（同时也可保留历史，便于审计/回溯）。题目要求“只记录最新配置以表示累计影响”，用AWS Config获取“最新一次记录的配置项”即可满足。

符合点3：最省运维。无需自建事件聚合推导逻辑，直接使用托管的配置记录与查询能力。

结论：正确。

C. CloudWatch + 过滤API调用 + 用最新API表示累计影响

CloudWatch不是配置管理/配置快照服务。即使通过日志/指标/事件规则去捕获API调用，本质仍是“事件流”，与A类似，需要自建逻辑推导最终状态。

“过滤API调用”本身也更贴近CloudTrail/ EventBridge的事件源，CloudWatch并不直接提供“资源配置最新状态”的权威记录。

结论：不如AWS Config省运维，也不保证准确表达最终配置，错误。

D. AWS Cloud Map 检测配置变更 + 滑动窗口报告

AWS Cloud Map用于服务发现（命名空间、服务、实例注册与健康检查），并非通用资源配置变更记录服务。

无法作为AWS资源配置合规与变更记录的标准方案，更无法覆盖“特定AWS资源配置”的全面字段。

结论：与题意不相关，错误。

4. 我选择的答案

B

5. 官方答案

B

6. 与官方答案对比与复盘

我的答案与官方答案一致：B

原因：题目要“记录最新配置来反映快速连续变更的累计影响”，最贴合“资源配置状态记录/合规评估”的托管服务是**AWS Config**；其他方案均偏事件审计或非相关服务，运维成本更高且准确性更难保证。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #15

Topic 1

A security engineer needs to implement a solution to create and control the keys that a company uses for cryptographic operations. The security engineer must create symmetric keys in which the key material is generated and used within a custom key store that is backed by an AWS CloudHSM cluster.

The security engineer will use symmetric and asymmetric data key pairs for local use within applications. The security engineer also must audit the use of the keys.

How can the security engineer meet these requirements?

一名安全工程师需要实施一个解决方案，用于创建和控制公司用于加密操作的密钥。安全工程师必须创建对称密钥，其中密钥材料在由 AWS CloudHSM 集群支持的自定义密钥存储中生成并使用。

安全工程师将在应用程序内本地使用对称和非对称数据密钥对。安全工程师还必须审计密钥的使用情况。

安全工程师如何才能满足这些要求？

A. To create the keys, use AWS Key Management Service (AWS KMS) and the custom key stores with the CloudHSM cluster. For auditing, use Amazon Athena.

要创建密钥，使用 AWS Key Management Service (AWS KMS) 以及结合 CloudHSM 集群的自定义密钥存储。对于审计，使用 Amazon Athena。

B. To create the keys, use Amazon S3 and the custom key stores with the CloudHSM cluster. For auditing, use AWS CloudTrail.

要创建密钥，使用 Amazon S3 以及结合 CloudHSM 集群的自定义密钥存储。对于审计，使用 AWS CloudTrail。

C. To create the keys, use AWS Key Management Service (AWS KMS) and the custom key stores with the CloudHSM cluster. For auditing, use Amazon GuardDuty.

要创建密钥，使用 AWS Key Management Service (AWS KMS) 以及结合 CloudHSM 集群的自定义密钥存储。对于审计，使用 Amazon GuardDuty。

D. To create the keys, use AWS Key Management Service (AWS KMS) and the custom key stores with the CloudHSM cluster. For auditing, use AWS CloudTrail.

要创建密钥，使用 AWS Key Management Service (AWS KMS) 以及结合 CloudHSM 集群的自定义密钥存储。对于审计，使用 AWS CloudTrail。

Correct Answer: D

正确答案: D

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

AWS KMS 自定义密钥存储 (Custom Key Store)：使用由 **AWS CloudHSM Cluster** 支撑的自定义密钥存储，使 **KMS 对称主密钥 (KMS key)** 的密钥材料在 CloudHSM 中生成并使用 (受客户控制的HSM)。

KMS 数据密钥 / 数据密钥对：通过 KMS 生成用于应用本地加解密的 **对称数据密钥 (GenerateDataKey)** 与 **非对称数据密钥对 (GenerateDataKeyPair)**。

密钥使用审计：用 **AWS CloudTrail** 记录 KMS API 调用（如 Encrypt/Decrypt/GenerateDataKey/GenerateDataKeyPair 等）以满足审计要求。

2. 独立思考（不参考官方答案的推导）

题目明确要求：创建并控制密钥；对称密钥的密钥材料必须在 **custom key store + CloudHSM** 内生成和使用。

这对应的服务组合是：**AWS KMS + Custom Key Store (CloudHSM-backed)** 来创建/管理 KMS keys。

题目还要求：应用需要在本地使用 **对称和非对称数据密钥对**。这最贴合 KMS 的 **GenerateDataKey** 与 **GenerateDataKeyPair**（返回可在本地使用的明文数据密钥/密钥对，及其被 KMS key 加密后的密文副本）。

审计“密钥的使用”最标准是 **CloudTrail** 记录 KMS 调用事件。

因此，最佳方案应为：**KMS + CloudHSM 自定义密钥存储** 创建密钥，**CloudTrail** 审计使用。

3. 逐个分析每个选项为什么正确或错误

A. KMS + Custom Key Store (CloudHSM) 创建密钥；Athena 审计

创建密钥部分：正确。KMS 可以在 CloudHSM-backed custom key store 中创建对称 KMS key（密钥材料在 HSM 中生成与使用）。

审计部分：不准确/不完整。Athena 是查询服务，本身不产生审计日志；审计来源通常是 **CloudTrail**（把日志放到 S3 后可用 Athena 查询）。

如果题目问“如何审计”，标准答案应直接是 **CloudTrail**，而不是 Athena。

结论：整体错误（审计组件选择不符合题意表达的“审计使用”的直接服务）。

B. S3 + Custom Key Store (CloudHSM) 创建密钥；CloudTrail 审计

创建密钥部分：错误。Amazon S3 不是密钥管理/生成服务，无法在 CloudHSM-backed custom key store 中创建和控制用于加密操作的主密钥材料。

审计部分：正确但无意义。CloudTrail 可以审计 API 调用，但前提是你使用了正确的密钥管理服务（如 KMS）。

结论：错误。

C. KMS + Custom Key Store (CloudHSM) 创建密钥；GuardDuty 审计

创建密钥部分：正确。同 A、D。

审计部分：错误。GuardDuty 是威胁检测服务（基于 CloudTrail 事件、VPC Flow Logs、DNS 日志等做异常检测），不是合规审计“记录谁在何时调用了哪些 KMS API”的权威审计日志系统。

结论：错误。

D. KMS + Custom Key Store (CloudHSM) 创建密钥；CloudTrail 审计

创建密钥部分：正确。使用 KMS 在 CloudHSM-backed custom key store 中创建对称 KMS key，满足“密钥材料在自定义密钥存储（HSM）内生成并使用”。

数据密钥/数据密钥对本地使用：匹配。KMS 可通过 **GenerateDataKey** 生成对称数据密钥，通过 **GenerateDataKeyPair** 生成非对称数据密钥对，供应用本地使用（同时返回密文版本便于后续解密/恢复）。

审计部分：正确。CloudTrail 记录对 KMS 的 API 调用事件，实现对密钥使用的审计追踪。

结论：正确。

4. 我选择的答案

D

5. 官方答案

D

6. 与官方答案比较与复盘

我的答案与官方答案一致：D。

原因：只有 D 同时满足

在 **CloudHSM-backed custom key store** 内生成并使用对称 KMS key 的密钥材料（KMS + Custom Key Store）。

通过 KMS 生成对称数据密钥与非对称数据密钥对用于本地应用（GenerateDataKey / GenerateDataKeyPair）。

用 **CloudTrail** 对 KMS 密钥使用进行可审计记录。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #16

Topic 1

A company is running an application on Amazon EC2 instances in an Auto Scaling group. The application stores logs locally. A security engineer noticed that logs were lost after a scale-in event. The security engineer needs to recommend a solution to ensure the durability and availability of log data. All logs must be kept for a minimum of 1 year for auditing purposes. What should the security engineer recommend?

一家公司在 Auto Scaling 组中的 Amazon EC2 实例上运行一个应用程序。该应用程序将日志存储在本地。一名安全工程师注意到，在一次扩容 (scale-in) 事件后日志丢失了。安全工程师需要推荐一种解决方案，以确保日志数据的持久性和可用性。出于审计目的，所有日志必须至少保留 1 年。
安全工程师应该推荐什么？

A. Within the Auto Scaling lifecycle, add a hook to create and attach an Amazon Elastic Block Store (Amazon EBS) log volume each time an EC2 instance is created. When the instance is terminated, the EBS volume can be reattached to another instance for log review.

在 Auto Scaling 生命周期中，添加一个钩子，在每次创建 EC2 实例时创建并挂载一个 Amazon Elastic Block Store (Amazon EBS) 日志卷。当实例终止时，可以将该 EBS 卷重新挂载到另一台实例上进行日志审查。

B. Create an Amazon Elastic File System (Amazon EFS) file system and add a command in the user data section of the Auto Scaling launch template to mount the EFS file system during EC2 instance creation. Configure a process on the instance to copy the logs once a day from an instance Amazon Elastic Block Store (Amazon EBS) volume to a directory in the EFS file system.

创建一个 Amazon Elastic File System (Amazon EFS) 文件系统，并在 Auto Scaling 启动模板的用户数据 (user data) 部分添加一条命令，以在创建 EC2 实例期间挂载该 EFS 文件系统。在实例上配置一个进程，每天将日志从实例的 Amazon Elastic Block Store (Amazon EBS) 卷复制到 EFS 文件系统目录中的某个目录。

C. Add an Amazon CloudWatch agent into the AMI used in the Auto Scaling group. Configure the CloudWatch agent to send the logs to Amazon CloudWatch Logs for review.

在 Auto Scaling 组使用的 AMI 中添加一个 Amazon CloudWatch 代理。配置 CloudWatch 代理将日志发送到 Amazon CloudWatch Logs 以供审查。

D. Within the Auto Scaling lifecycle, add a lifecycle hook at the terminating state transition and alert the engineering team by using a lifecycle notification to Amazon Simple Notification Service (Amazon SNS). Configure the hook to remain in the Terminating:Wait state for 1 hour to allow manual review of the security logs prior to instance termination.

在 Auto Scaling 生命周期中，在终止状态转换时添加一个生命周期钩子，并通过向 Amazon Simple Notification Service (Amazon SNS) 发送生命周期通知来告警工程团队。将该钩子配置为在 Terminating:Wait 状态停留 1 小时，以便在实例终止之前允许对安全日志进行人工审查。

Correct Answer: C

正确答案: C

题目解析 (SCS-C03 做题教练)

1. 本题考察的知识点

Auto Scaling 伸缩导致本地磁盘日志丢失 (实例终止后本地存储/实例存储/EBS随实例删除等风险)

日志集中化与持久化: 将日志从EC2本地转移到托管服务 (如 CloudWatch Logs / S3 等) 以保证可用性与耐久性

合规留存: 日志需至少保留1年 (CloudWatch Logs 可配置 retention policy)

2. 独立思考 (不参考官方答案)

需求核心是: 实例 scale-in 终止后, 日志不能丢; 且需要**至少保留 1 年**, 并且应具备高可用与高耐久。

最直接、AWS 原生且与Auto Scaling天然兼容的做法是: **把日志实时/准实时发送到集中日志服务**, 而不是依赖“终止前拷贝”或“复用磁盘”。

3. 逐个选项分析

A 选项: 生命周期钩子创建并挂载EBS日志卷, 终止后再挂载到其他实例 问题点:

EBS卷本身是AZ级资源, 虽然具备一定耐久性, 但把日志“长期留存+可用”寄托在“可重新挂载某个卷”上, 运维复杂且不符合日志最佳实践。

需要确保终止时**不删除卷**、处理并发、卷的生命周期、权限、以及多个实例写入同一卷的设计问题 (容易产生一致性/锁/吞吐问题)。

审计要求“至少1年”意味着还要考虑EBS快照/归档、成本与管理; EBS并非典型的审计日志留存介质。

无法很好解决“日志可用性” (要靠挂载到实例上才能查看), 且对检索分析不友好。

结论: 不推荐, 不能算最佳的耐久+可用的集中日志方案。

B 选项: 挂载EFS, 每天从EBS拷贝日志到EFS目录 优点:

EFS是托管NFS, 可跨多台实例共享; 实例终止不影响文件系统本身, 日志不会随实例消失。

问题点:

题目说“scale-in后日志丢失”, 而B是**每天拷贝一次**: 如果实例在当天拷贝前被终止, 仍会丢失当日未拷贝的日志 (不满足耐久性目标)。

EFS并非专门的审计日志平台: 缺少原生日志检索/查询能力; 要满足审计通常还需额外流程 (备份、归档、权限隔离、不可篡改等)。

“至少保留1年”可以做到, 但需要额外治理 (例如EFS生命周期管理转IA、备份、访问控制), 且仍不如日志服务直接。

结论: 比A好, 但“每天拷贝”导致仍可能丢日志, 不满足题意中的“确保耐久性/可用性”。

C 选项: 在AMI中加入CloudWatch Agent, 把日志发送到CloudWatch Logs 优点:

集中化: 实例随时终止不影响已发送到CloudWatch Logs的日志。

高可用/高耐久: CloudWatch Logs是托管服务, 适合日志持久化与跨实例汇聚。

可配置保留期: 可在CloudWatch Logs中对Log Group设置**Retention = 365天或更久**以满足“至少1年”。

支持权限控制 (IAM)、审计 (CloudTrail记录配置变更)、以及与报警/洞察/订阅 (subscription filters) 等集成。

解决“scale-in丢日志”的根因: 不依赖实例生命周期, 不依赖终止前操作。

潜在注意:

需正确配置agent为“持续推送” (接近实时), 并确保网络出口与IAM权限。

若要更强审计 (不可篡改/WORM), 可能还会进一步导出到S3+Object Lock, 但题目未要求不可篡改, 仅要求保留1年与耐久可用。

结论: 最符合“耐久性+可用性+1年留存”的标准做法。

D 选项: 终止钩子+SNS通知, 停留1小时供人工审查 问题点:

这不是“确保持久性”的方案, 只是延迟终止给人工看一眼; 实例最终仍会被终止, 日志仍在本地, 仍可能丢失。

人工审查无法满足“所有日志保留至少1年”的合规要求 (缺乏集中留存与可检索性)。

不可扩展: Auto Scaling频繁伸缩会造成大量人工流程与风险。

结论: 不满足需求。

4. 我选择的答案

C

5. 官方答案

C

6. 与官方答案对比与复盘

我的答案 = 官方答案 (均为C) , 一致。

原因总结: C是唯一一个把日志从“会消失的实例本地”迁移到“托管的集中日志系统”的选项, 并且可直接设置保留期满足1年合规;
其他选项要么仍可能丢日志 (B)、要么运维复杂且不符合日志最佳实践 (A)、要么根本不解决留存与耐久性 (D)。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #17

Topic 1

A company is using AWS to run a long-running analysis process on data that is stored in Amazon S3 buckets. The process runs on a fleet of Amazon EC2 instances that are in an Auto Scaling group. The EC2 instances are deployed in a private subnet of a VPC that does not have internet access. The EC2 instances and the S3 buckets are in the same AWS account.

The EC2 instances access the S3 buckets through an S3 gateway endpoint that has the default access policy. Each EC2 instance is associated with an instance profile role that has a policy that explicitly allows the `s3:GetObject` action and the `s3:PutObject` action for only the required S3 buckets.

The company learns that one or more of the EC2 instances are compromised and are exfiltrating data to an S3 bucket that is outside the company's organization in AWS Organizations. A security engineer must implement a solution to stop this exfiltration of data and to keep the EC2 processing job functional.

Which solution will meet these requirements?

一家公司正在使用 AWS 对存储在 Amazon S3 存储桶中的数据运行一个长时间运行的分析流程。该流程在一个 Amazon EC2 实例队列上运行，这些实例位于一个 Auto Scaling 组中。EC2 实例部署在一个没有互联网访问的 VPC 私有子网中。EC2 实例和 S3 存储桶位于同一个 AWS 账户中。

EC2 实例通过一个具有默认访问策略的 S3 网关终端节点访问 S3 存储桶。每个 EC2 实例都关联了一个实例配置文件角色，该角色具有一个策略，明确允许仅对所需的 S3 存储桶执行 `s3:GetObject` 操作和 `s3:PutObject` 操作。

公司得知一个或多个 EC2 实例已被攻破，并且正在将数据外泄到一个位于公司在 AWS Organizations 中的组织之外的 S3 存储桶。安全工程师必须实施一个解决方案来阻止这种数据外泄，并保持 EC2 处理作业正常运行。

哪种解决方案将满足这些要求？

A. Update the policy on the S3 gateway endpoint to allow the S3 actions only if the values of the `aws:ResourceOrgID` and `aws:PrincipalOrgID` condition keys match the company's values.

更新 S3 网关终端节点上的策略，仅当 `aws:ResourceOrgID` 和 `aws:PrincipalOrgID` 条件键的值与公司的值匹配时才允许这些 S3 操作。

B. Update the policy on the instance profile role to allow the S3 actions only if the value of the `aws:ResourceOrgID` condition key matches the company's value.

更新实例配置文件角色上的策略，仅当 `aws:ResourceOrgID` 条件键的值与公司的值匹配时才允许这些 S3 操作。

C. Add a network ACL rule to the subnet of the EC2 instances to block outgoing connections on port 443.

向 EC2 实例所在子网添加一条网络 ACL 规则，以阻止在 443 端口上的出站连接。

D. Apply an SCP on the AWS account to allow the S3 actions only if the values of the `aws:ResourceOrgID` and `aws:PrincipalOrgID` condition keys match the company's values.

在 AWS 账户上应用一个 SCP，仅当 `aws:ResourceOrgID` 和 `aws:PrincipalOrgID` 条件键的值与公司的值匹配时才允许这些 S3 操作。

Correct Answer: B

正确答案: B

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

数据外泄 (Data Exfiltration) 防护：受感染EC2实例利用其AWS权限将数据写入外部S3桶。

S3 访问控制的多层防护：IAM身份策略 (Instance Profile Role)、VPC Endpoint Policy (S3 Gateway Endpoint)、SCP (Service Control Policy) 的边界与适用场景。

AWS Organizations 条件键：使用 `aws:ResourceOrgID` (资源所属组织) 与 `aws:PrincipalOrgID` (主体所属组织) 限制跨组织访问。

在无公网的私有子网中访问S3：通过 **S3 Gateway Endpoint**，不依赖Internet/NAT。

2. 独立思考 (不参考官方答案)

目标是：**阻止被攻陷EC2向组织外S3桶写入数据**，同时**不影响现有EC2处理作业对组织内S3桶的正常读写**。

最精确、最小影响面的方法，是在**该EC2实例角色 (instance profile role) 的权限上**增加“只能访问本组织S3资源”的条件，这样即使实例被攻陷，其凭证也无法对组织外S3桶执行Put/Get。

使用 `aws:ResourceOrgID` 限制资源必须属于本组织即可达成：组织内桶不受影响，组织外桶被拒绝。

3. 逐个选项分析

A. 更新S3 Gateway Endpoint策略：仅当 `aws:ResourceOrgID` 和 `aws:PrincipalOrgID` 匹配公司值时允许

优点：从网络路径层面 (Endpoint) 卡住通过该Endpoint去访问组织外S3桶的请求；如果所有S3流量都必须走该Endpoint，则可有效阻断外泄。

问题1 (影响面更大)：Endpoint Policy是**VPC级/Endpoint级**控制，可能影响同VPC内其他工作负载通过该Endpoint访问S3的能力 (不如只改该ASG角色精确)。

问题2 (冗余条件)：`aws:PrincipalOrgID` 对本题场景通常恒成立 (这些EC2与其角色在本组织内)，真正关键是 `aws:ResourceOrgID`；加上PrincipalOrgID并不提升对“被攻陷实例”的防护强度。

结论：可行但不是最小权限/最小影响面的最佳答案。

B. 更新实例配置文件角色策略：仅当 `aws:ResourceOrgID` 匹配公司值时允许S3操作

优点1 (最小影响面)：只约束**该ASG实例所使用的IAM Role**，不会误伤VPC内其他主体或其他S3访问路径。

优点2 (直击外泄路径)：外泄到组织外S3桶的关键在于“目标桶不属于本组织”，用`aws:ResourceOrgID`即可阻断。

优点3 (保持作业功能)：现有需要访问的S3桶在本组织内时，条件通过，作业继续正常Get/Put。

注意：该方案的前提是“所需S3桶确实属于本组织”。题干描述为公司自有桶 (同账号/组织)，符合。

结论：满足“阻止外泄 + 保持功能”的最优解。

C. 在子网NACL中阻止出站443端口

错误原因1 (会破坏作业)：访问S3 (即使通过Gateway Endpoint) 也会使用HTTPS/443进行API调用；阻断443将导致EC2无法正常与S3通信，处理作业会中断。

错误原因2 (控制粒度不对)：外泄问题是“允许写到组织外桶”，应当用IAM/组织条件键控制“允许访问哪些S3资源”，而不是粗暴断网。

结论：不满足“保持EC2处理作业功能”。

D. 在账户上应用SCP：仅当 `aws:ResourceOrgID` 和 `aws:PrincipalOrgID` 匹配公司值时允许S3操作

潜在可行：SCP作为组织级护栏，理论上能限制该账号内所有主体对组织外S3资源的访问。

问题1 (影响面过大)：SCP对**整个账号**生效，可能影响该账号内其他角色/用户/服务访问S3的既有业务 (例如需要访问第三方桶、跨组织共享桶、日志投递到外部安全账号等)。

问题2 (实现方式风险)：SCP是权限边界，常见做法是用**显式Deny**来阻断不合规访问；题目选项描述为“allow only if...”，在实际落地需要非常小心，否则可能导致意外的默认拒绝范围扩大。

结论：可能阻止外泄，但不如B精确，且更容易对业务造成附带影响。

4. 我选择的答案

B

5. 官方答案

B

6. 与官方答案比较与复核

对比结果：我的答案 **B** 与官方答案 **B** 一致。

复核结论：B通过在实例角色的身份策略中使用 **aws:ResourceOrgID** 将S3访问限定在本组织资源内，能精准阻断向组织外S3桶的 Put/Get，同时不影响对组织内所需S3桶的正常访问，满足题目“阻止外泄 + 保持作业功能”的双重要求。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #18

Topic 1

A company recently experienced a malicious attack on its cloud-based environment. The company successfully contained and eradicated the attack. A security engineer is performing incident response work. The security engineer needs to recover an Amazon RDS database cluster to the last known good version. The database cluster is configured to generate automated backups with a retention period of 14 days. The initial attack occurred 5 days ago at exactly 3:15 PM. Which solution will meet this requirement?

一家公司最近在其基于云的环境中遭受了一次恶意攻击。公司成功遏制并根除了该攻击。一名安全工程师正在执行事件响应工作。该安全工程师需要将一个 Amazon RDS 数据库集群恢复到最后一个已知良好版本。该数据库集群被配置为生成自动备份，保留期为 14 天。最初的攻击发生在 5 天前的下午 3:15，精确到分钟。哪种解决方案将满足此要求？

A. Identify the Regional cluster ARN for the database. Use the ARN to restore the Regional cluster by using the Restore to point in time feature. Set a target time 5 days ago at 3:14 PM.

识别该数据库的区域集群 ARN。使用该 ARN 通过“恢复到某个时间点”(Restore to point in time) 功能来恢复该区域集群。将目标时间设置为 5 天前的下午 3:14。

B. Identify the Regional cluster ARN for the database. List snapshots that have been taken of the cluster. Restore the database by using the snapshot that has a creation time that is closest to 5 days ago at 3:14 PM.

识别该数据库的区域集群 ARN。列出对该集群拍摄的快照。使用创建时间最接近 5 天前下午 3:14 的快照来恢复数据库。

C. List all snapshots that have been taken of all the company's RDS databases. Identify the snapshot that was taken closest to 5 days ago at 3:14 PM and restore it.

列出公司所有 RDS 数据库拍摄的所有快照。识别在 5 天前下午 3:14 最近拍摄的快照并将其恢复。

D. Identify the Regional cluster ARN for the database. Use the ARN to restore the Regional cluster by using the Restore to point in time feature. Set a target time 14 days ago.

识别该数据库的区域集群 ARN。使用该 ARN 通过“恢复到某个时间点”(Restore to point in time) 功能来恢复该区域集群。将目标时间设置为 14 天前。

Correct Answer: A

正确答案: A

题目解析 (AWS Certified Security - Specialty SCS-C03 做题教练)

1. 考察的知识点

Amazon RDS (尤其是RDS/Aurora DB Cluster) 自动备份 (Automated backups) 与保留期 (Retention period)

时间点恢复 (Point-in-Time Restore, PITR / Restore to point in time) : 可在备份保留期内将数据库恢复到某一秒级时间点 (通常以最近的可恢复时间为准)

事件响应/勒索或入侵后恢复策略：恢复到“攻击发生之前的最后已知良好状态”（last known good）以避免带入恶意变更
快照恢复 vs PITR：快照恢复通常只能恢复到“快照创建时间点”，而PITR可更精确地回退到指定时间

2. 独立思考（不参考官方答案）

需求是：把RDS数据库集群恢复到**攻击发生前**的最后已知良好版本。

已知：攻击发生于**5天前 3:15 PM**；自动备份保留期**14天**，所以**5天前**在保留窗口内，具备PITR条件。

要确保“攻击尚未发生”，最合理做法是用PITR恢复到**3:15 PM之前**，例如3:14 PM（甚至3:14:59更严谨，但题目给到3:14）。

使用“快照时间最接近”并不保证在攻击前（可能是攻击后生成的快照），且精度不如PITR。

3. 逐个选项分析

A：识别区域集群ARN，通过**Restore to point in time**恢复到**5天前 3:14 PM** **判断：正确** 原因：

在自动备份保留期14天内，5天前可进行PITR。

恢复到3:14 PM可确保在3:15 PM攻击发生之前，符合“last known good”。

PITR是满足“精确回退到攻击前”的标准方案，优于依赖快照创建时间。

B：列出集群快照，选创建时间最接近**5天前 3:14 PM**的快照恢复 **判断：错误** 原因：

“最接近”不等于“早于攻击发生时间”。最接近的快照可能在3:15之后（攻击后）才生成，恢复会把污染/恶意改动带回。

快照恢复通常只能恢复到快照创建时刻，无法像PITR一样精确到攻击前一分钟的目标点。

题目已给自动备份与保留期，暗示应使用PITR而非“碰运气找快照”。

C：列出公司所有RDS数据库的所有快照，找最接近时间的快照恢复 **判断：错误** 原因：

范围扩大到“所有数据库”不必要且增加误选风险，不符合最小化操作与明确恢复目标的最佳实践。

与B同样的问题：最接近的快照不保证在攻击前，且不如PITR精确。

D：使用PITR但目标时间设为**14天前** **判断：错误** 原因：

需求是恢复到“攻击发生前的最后已知良好版本”，攻击发生在5天前，没必要回退到14天前，会造成不必要的数据丢失。

14天前只是保留期上限，并非“最后已知良好”的合理目标。

4. 我选择的答案

A

5. 官方答案

A

6. 与官方答案对比与复盘

我的答案：A

官方答案：A

结论：一致

原因复盘：

题干明确给出自动备份保留期（14天）与攻击发生精确时间（5天前3:15 PM），这就是典型的**PITR场景**。

恢复到攻击发生前1分钟（3:14 PM）符合“last known good”的要求。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #19

Topic 1

A security engineer for a company needs to design an incident response plan that addresses compromised IAM user account credentials. The company uses an organization in AWS Organizations and AWS IAM Identity Center to manage user access. The company uses a delegated administrator account to implement AWS Security Hub. The delegated administrator account contains an organizational trail in AWS CloudTrail that logs all events to an Amazon S3 bucket. The company has also configured an organizational event data store that captures all events from the trail.

The incident response plan must provide steps that the security engineer can take to immediately disable any compromised IAM user when the security engineer receives a notification of a security incident.

The plan must prevent the IAM user from being used in any AWS account. The plan must also collect all AWS actions that the compromised IAM user performed across all accounts in the previous 7 days.

Which solution will meet these requirements?

某公司的安全工程师需要设计一个事件响应计划，以应对 IAM 用户账户凭证被泄露的情况。该公司在 AWS Organizations 中使用一个组织，并使用 AWS IAM Identity Center 来管理用户访问。该公司使用一个委派管理员账户来实施 AWS Security Hub。该委派管理员账户在 AWS CloudTrail 中包含一个组织级追踪（organizational trail），该追踪会将所有事件记录到一个 Amazon S3 存储桶中。该公司还配置了一个组织级事件数据存储（organizational event data store），用于捕获来自该追踪的所有事件。

事件响应计划必须提供一些步骤，使安全工程师在收到安全事件通知时，能够立即禁用任何已被攻陷的 IAM 用户。

该计划必须防止该 IAM 用户在任何 AWS 账户中被使用。该计划还必须收集该被攻陷的 IAM 用户在过去 7 天内跨所有账户执行的所有 AWS 操作。

哪个解决方案将满足这些要求？

A. Disable the compromised IAM user in the organization management account. Use Amazon Athena to query the organizational CloudTrail logs in the S3 bucket for actions that the IAM user performed in the previous 7 days.

在组织管理账户中禁用被攻陷的 IAM 用户。使用 Amazon Athena 查询 S3 存储桶中的组织级 CloudTrail 日志，以获取该 IAM 用户在过去 7 天内执行的操作。

B. Remove all IAM policies that are attached to the IAM user in the organization management account. Use Security Hub to query the CloudTrail logs for actions that the IAM user performed in the previous 7 days.

移除在组织管理账户中附加到该 IAM 用户的所有 IAM 策略。使用 Security Hub 查询 CloudTrail 日志，以获取该 IAM 用户在过去 7 天内执行的操作。

C. Remove any permission sets that are assigned to the IAM user in IAM Identity Center. Use Amazon CloudWatch Logs Insights to directly query the organizational CloudTrail logs in the S3 bucket for actions that the IAM user performed in the previous 7 days.

移除在 IAM Identity Center 中分配给该 IAM 用户的所有权限集（permission sets）。使用 Amazon CloudWatch Logs Insights 直接查询 S3 存储桶中的组织级 CloudTrail 日志，以获取该 IAM 用户在过去 7 天内执行的操作。

D. Disable the IAM user's access in IAM Identity Center. Use CloudTrail to query the organizational event data store for actions that the IAM user performed in the previous 7 days.

在 IAM Identity Center 中禁用该 IAM 用户的访问。使用 CloudTrail 查询组织级事件数据存储，以获取该 IAM 用户在过去 7 天内执行的操作。

Correct Answer: D

正确答案: D

题目解析 (SCS-C03 做题教练)

1. 本题考察的知识点

跨账户立即阻断访问：在使用 AWS Organizations + AWS IAM Identity Center (原 AWS SSO) 统一管理访问时，如何“一处禁用，全组织生效”。

CloudTrail 组织级集中审计：组织 Trail (Organizational trail) 覆盖所有账号事件采集与集中存储。

CloudTrail Lake 事件数据存储 (Event data store) 查询：在过去 N 天内跨账户检索某个主体 (用户/角色) 的所有 API 行为的最佳方式。

工具适配性：Athena vs CloudWatch Logs Insights vs CloudTrail Lake vs Security Hub 在“查询 CloudTrail 数据”方面各自能否直接满足需求。

2. 独立思考 (不参考官方答案)

题目要求两个核心点：(1) **立即禁用被攻陷用户，并且该用户不能在任何 AWS 账号中继续被使用** (2) **收集该用户过去 7 天在所有账号的所有操作**

公司“使用 AWS IAM Identity Center 管理用户访问”，意味着用户大概率通过 Identity Center 被授予多账号权限 (permission sets -> account assignments -> role)，所以要做到“全组织不可再用”，最直接的是在 **Identity Center/Identity Source 中禁用该用户** (或移除其访问)。

审计层面已配置了 **组织 Trail**，并且还配置了 **组织 event data store** (CloudTrail Lake)。若要在 7 天内跨账号快速汇总该用户行为，**CloudTrail Lake 查询 event data store** 是最贴切的。

3. 逐个选项分析

A. 在组织管理账户中禁用被攻陷的 IAM 用户 + Athena 查 S3 日志

禁用方式问题 (关键不满足)：“在组织管理账户中禁用 IAM 用户”只会影响该 **管理账户内** 的那个 IAM 用户实体。IAM 用户是 **账号级** 资源，不会因为你在管理账户禁用，就自动在所有成员账户失效。因此无法保证“该 IAM 用户不能在任何 AWS 账号被使用”。

取证查询部分：Athena 确实可对 S3 中的 CloudTrail 日志进行查询 (需建表/分区等)。但题目强调“立即”且已经有 event data store，更贴合用 CloudTrail Lake。

结论：取证可行但阻断不满足全账号范围要求，因此错误。

B. 移除管理账户中该 IAM 用户所有策略 + Security Hub 查询 CloudTrail

阻断方式问题：同样仅影响管理账户中的该 IAM 用户；并且“移除策略”未必能立即彻底阻断 (还可能存在群组策略、权限边界、资源策略、或者仍可调用无需权限/已存在的会话等)，且无法跨账号。

查询方式问题 (明显错误)：Security Hub 是安全态势管理/告警聚合服务，不是用来“查询 CloudTrail 原始日志”的检索引擎。它不会提供对组织 CloudTrail 日志的通用查询能力来列出某 IAM 用户过去 7 天所有 API 操作。

结论：阻断与查询两部分都不满足，错误。

C. 在 IAM Identity Center 移除该用户所有 permission sets + CloudWatch Logs Insights 直接查 S3 的 CloudTrail

阻断方式部分 (部分可行但不够“立即/彻底”)：移除 permission sets (本质是移除 account assignments) 可以让用户无法再通过 Identity Center 获取对应账号的角色权限。但题目要求“立即禁用任何被攻陷用户”，更直接、操作更少且语义更符合的是 **直接禁用该用户** (使其无法登录/获取新会话)，而不是逐一移除权限集分配。

查询方式部分 (错误)：CloudWatch Logs Insights 只能查询 **CloudWatch Logs** 中的数据。题干明确组织 Trail 记录到 **S3 bucket**，CloudWatch Logs Insights **不能直接查询 S3 里的 CloudTrail 日志**。(除非额外把 CloudTrail 投递到 CloudWatch Logs log group，但题目没有这样配置。)

结论：查询方式不成立，且阻断不如“禁用用户”直接，错误。

D. 在 IAM Identity Center 禁用该用户访问 + CloudTrail 查询组织 event data store (过去 7 天)

阻断方式（满足）： 公司使用 IAM Identity Center 管理用户访问时，**禁用该用户**（在 Identity Center 内部目录置为 inactive，或在外部 IdP 禁用/阻断该用户）可以立即阻止其再通过 Identity Center 获取任何账号权限，从而实现“在任何 AWS 账号不能再使用该用户访问”。这与题目“必须防止该用户在任何 AWS account 被使用”最匹配。

取证查询（满足）： CloudTrail Lake 的 **event data store** 支持用 SQL 查询过去 7 天、跨组织账号的事件。题目已说明“已配置组织 event data store 捕获 trail 的所有事件”，因此可以直接在 CloudTrail 中对 event data store 执行查询，快速汇总该用户在所有账号的操作。

结论： 阻断 + 跨账号 7 天取证查询都满足，**正确**。

4. 我选择的答案

D

5. 官方答案

D

6. 与官方答案对比与复盘

我的答案与官方答案**一致**：都是 **D**。

原因总结：Identity Center 负责“统一身份与访问分配”，要全组织立刻阻断应从 Identity Center/IdP 侧禁用用户；CloudTrail Lake event data store 负责“跨账号集中可查询审计”，要拉取过去 7 天全组织行为用 event data store 查询最直接。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #20

Topic 1

A security engineer is designing security controls for a fleet of Amazon EC2 instances that run sensitive workloads in a VPC. The security engineer needs to implement a solution to detect and mitigate software vulnerabilities on the EC2 instances. Which solution will meet this requirement?

一名安全工程师正在为一组在 VPC 中运行敏感工作负载的 Amazon EC2 实例设计安全控制。该安全工程师需要实施一种解决方案，用于检测并缓解 EC2 实例上的软件漏洞。
哪种解决方案将满足此要求？

A. Scan the EC2 instances by using Amazon Inspector. Apply security patches and updates by using AWS Systems Manager Patch Manager.
使用 Amazon Inspector 扫描 EC2 实例。使用 AWS Systems Manager Patch Manager 应用安全补丁和更新。

B. Install host-based firewall and antivirus software on each EC2 instance. Use AWS Systems Manager Run Command to update the firewall and antivirus software.
在每个 EC2 实例上安装基于主机的防火墙和防病毒软件。使用 AWS Systems Manager Run Command 更新防火墙和防病毒软件。

C. Install the Amazon CloudWatch agent on the EC2 instances. Enable detailed logging. Use Amazon EventBridge to review the software logs for anomalies.
在 EC2 实例上安装 Amazon CloudWatch 代理。启用详细日志记录。使用 Amazon EventBridge 审查软件日志以查找异常。

D. Scan the EC2 instances by using Amazon GuardDuty Malware Protection. Apply security patches and updates by using AWS Systems Manager Patch Manager.
使用 Amazon GuardDuty Malware Protection 扫描 EC2 实例。使用 AWS Systems Manager Patch Manager 应用安全补丁和更新。

Correct Answer: A

正确答案: A

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

EC2 主机漏洞管理 (Vulnerability Management) : 如何在 EC2 实例上进行软件漏洞检测与修复闭环。

Amazon Inspector 的用途: 用于自动化发现 EC2 (以及容器/镜像等) 中的已知漏洞与暴露 (CVE) 及相关风险评估。

AWS Systems Manager Patch Manager 的用途: 用于在受管实例上进行补丁基线、补丁部署、合规性报告, 实现漏洞修复 (mitigation) 。

区分“漏洞 (vulnerability)”与“恶意软件 (malware)” : 漏洞扫描/评估与恶意软件检测是不同控制面。

2. 独立思考 (不参考官方答案)

题目要求是：**detect and mitigate software vulnerabilities**（检测并缓解软件漏洞）。

要满足“检测漏洞”：优先想到 **Amazon Inspector**（典型的 AWS 原生漏洞发现服务）。

要满足“缓解漏洞”：通常是**打补丁/更新**，最标准的是 **Systems Manager Patch Manager**。

因此，一个完整闭环应是：**Inspector 扫描发现漏洞 + Patch Manager 打补丁修复**。

3. 逐个分析每个选项为什么正确或错误

A. Inspector 扫描 + Patch Manager 打补丁

正确点 (Detect)：Amazon Inspector 可对 EC2 进行持续/周期性扫描，识别操作系统与应用依赖中的已知漏洞（CVE）并给出严重性与可操作建议。

正确点 (Mitigate)：Patch Manager 通过补丁基线与维护窗口对实例进行系统与安全更新，形成修复闭环，并可做合规性跟踪。

结论：完整覆盖“漏洞检测+缓解”。

B. 安装主机防火墙/杀毒 + Run Command 更新

问题1：与“漏洞”不完全匹配：防火墙/杀毒主要针对网络访问控制与恶意软件，不能系统性地做“软件漏洞识别与评估”。

问题2：缺少标准漏洞扫描能力：Run Command 只是执行命令的通道，本身不提供漏洞发现、CVE 评估、风险分级等能力。

问题3：缓解方式不够直接：即使更新杀毒/防火墙，也不等于修复 OS/库/应用漏洞。

结论：不满足“检测并缓解软件漏洞”的核心诉求。

C. CloudWatch Agent 日志 + EventBridge 查异常

问题1：偏向检测运行异常/事件：日志分析更适合安全监控/审计/异常行为检测，不是漏洞扫描。

问题2：缺少漏洞识别：无法直接映射到 CVE、缺失补丁、依赖漏洞等“软件漏洞”清单。

问题3：缓解缺失：即使发现异常，也没有提供补丁修复机制。

结论：不满足。

D. GuardDuty Malware Protection 扫描 + Patch Manager 打补丁

问题1：检测对象不对：GuardDuty Malware Protection 的重点是**恶意软件检测**（例如对 EBS 快照/卷进行恶意软件扫描与告警），不是通用的“软件漏洞扫描”。

问题2：漏洞检测缺口：即便搭配 Patch Manager 能“打补丁”，但题目首先要求“detect software vulnerabilities”，该项能力更明确由 Inspector 提供。

结论：不满足“漏洞检测”这一关键要求（或至少不是最匹配的方案）。

4. 我选择的答案

A

5. 官方答案

A

6. 与官方答案对比与复盘

对比结果：我的答案与官方答案一致（A）。

原因总结：题目关键词是“软件漏洞（vulnerabilities）检测与缓解”。Inspector 对应“漏洞检测与评估”，Patch Manager 对应“补丁修复与合规”，两者组合是 AWS 上最标准的漏洞管理闭环；而 GuardDuty Malware Protection 更偏恶意软件检测，不是漏洞扫描主力。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #21

Topic 1

A security engineer uses Amazon Macie to scan a company's Amazon S3 buckets for sensitive data. The company has many S3 buckets and many objects stored in the S3 buckets. The security engineer must identify S3 buckets that contain sensitive data and must perform additional scanning on those S3 buckets.

Which solution will meet these requirements with the LEAST administrative overhead?

一名安全工程师使用 Amazon Macie 扫描公司在 Amazon S3 存储桶中的敏感数据。该公司有许多 S3 存储桶，并且在这些 S3 存储桶中存储了许多对象。安全工程师必须识别包含敏感数据的 S3 存储桶，并且必须对这些 S3 存储桶执行额外的扫描。哪种解决方案能够以最少的管理开销满足这些要求？

A. Configure S3 Cross-Region Replication (CRR) on the S3 buckets to replicate the objects to a second AWS Region. Configure Macie in the second Region to scan the replicated objects daily.

在这些 S3 存储桶上配置 S3 跨区域复制 (CRR)，将对象复制到第二个 AWS 区域。在第二个区域中配置 Macie 每日扫描复制的对象。

B. Create an AWS Lambda function as an S3 event destination for the S3 buckets. Configure the Lambda function to start a Macie scan of an object when the object is uploaded to an S3 bucket.

为这些 S3 存储桶创建一个 AWS Lambda 函数作为 S3 事件目标。配置该 Lambda 函数在对象上传到 S3 存储桶时启动对该对象的 Macie 扫描。

C. Configure Macie automated discovery to continuously sample data from the S3 buckets. Perform full scans of the S3 buckets where Macie discovers sensitive data.

配置 Macie 自动化发现，持续从 S3 存储桶中抽样数据。对 Macie 发现敏感数据的 S3 存储桶执行全量扫描。

D. Configure Macie scans to run on the S3 buckets. Aggregate the results of the scans in an Amazon DynamoDB table. Use the DynamoDB table for queries.

配置 Macie 扫描在 S3 存储桶上运行。将扫描结果聚合到一个 Amazon DynamoDB 表中。使用该 DynamoDB 表进行查询。

Correct Answer: C

正确答案: C

题目解析：Amazon Macie 扫描大量 S3 存储桶，识别含敏感数据的桶并进行二次深度扫描（最少运维开销）

1. 本题考察的知识点

Amazon Macie 的两类核心能力：自动化敏感数据发现 (Automated sensitive data discovery/自动发现) 与按需/计划的敏感数据分类作业 (Sensitive data discovery jobs / 分类扫描)。

规模化场景下的运维最小化：面对“很多桶、很多对象”，优先使用托管的持续发现能力来缩小范围，再对命中的桶做更深度的全量扫描。

事件触发逐对象扫描的可行性与代价：是否支持、是否会引入大量自建组件与权限/错误处理成本。

避免无意义的架构复杂化：为扫描而跨区域复制、或把结果落到自建数据库通常不属于“最少管理开销”。

2. 独立思考（不参考官方答案）

需求拆解：1) 先识别哪些 S3 桶含敏感数据；2) 再对这些桶做**额外扫描（更深、更全）**；3) 要求**最少管理开销**。

最符合思路的是：用 Macie 的**自动化发现**持续抽样/发现，先圈定“高风险桶”，再对这些桶发起**全量分类作业**。

3. 逐个选项分析

A. 配置 CRR 复制到第二个区域，再在第二个区域用 Macie 每日扫描 问题点：

运维开销大：需要为“很多桶”逐个配置 CRR、处理 IAM、KMS（若 SSE-KMS）、复制状态监控、失败重试等。

成本高：跨区域复制带来额外存储与跨区域数据传输费用；仅为扫描目的而复制通常不合理。

不直接提升“识别含敏感数据的桶”的效率：反而把数据面扩大到第二个区域。

结论：不满足“最少管理开销”，不是最佳方案。

B. 用 S3 事件触发 Lambda，在对象上传时启动 Macie 扫描该对象 问题点：

运维开销很高：需要为大量桶配置事件通知、Lambda 并发/失败处理、幂等、权限、成本控制。

与 Macie 工作方式不匹配：Macie 通常以“桶/范围”为目标进行敏感数据发现与分类作业，而不是为每个对象做“即时逐对象扫描”的事件驱动模式（即便能间接实现，也会非常复杂）。

无法覆盖存量对象：只对新上传触发；题目强调“很多对象”，显然包含大量已存在对象，需要更系统化的发现。

结论：管理复杂且不符合题意的“最少管理开销”。

C. 配置 Macie 自动化发现持续抽样；对发现敏感数据的桶做全量扫描 优点：

最符合两阶段目标：自动发现先筛出“可能含敏感数据的桶”，再对命中的桶做更深入的全量分类。

托管能力，管理开销最低：不需要自建事件系统、复制链路、或额外数据库来归集结果。

可扩展性强：适合“很多桶、很多对象”的规模化场景。

可能的注意点：

自动化发现是持续抽样/持续分析的思路，作为“初筛”非常合适；随后用全量扫描（分类作业）对命中的桶做更严格确认与覆盖。

结论：最符合题意且管理开销最低。

D. 对桶配置 Macie 扫描，并把结果聚合到 DynamoDB 供查询 问题点：

额外组件增加管理开销：需要设计数据模型、写入管道（EventBridge/Lambda/Step Functions）、权限、吞吐与成本管理。

不是识别桶与二次扫描的关键路径：Macie 本身就能在控制台/Findings/集成 Security Hub 等位置查看与聚合发现结果；为“查询”单独落 DynamoDB 通常是过度设计。

没有体现“先筛选再加扫”的最小化策略：反而可能对所有桶做扫描并维护外部系统。

结论：不满足“最少管理开销”。

4. 我选择的答案

C

5. 官方答案

C

6. 与官方答案比较与复盘

我的答案与官方答案一致：都是 C。

原因总结：题目强调“很多桶/很多对象”且要“先识别含敏感数据桶，再对这些桶做额外扫描”，最省管理成本的方式就是用 Macie 托管的自动化发现先做范围收敛，再对命中的桶做全量分类作业；其余选项要么引入跨区域复制、要么引入事件驱动自建扫描管道、要么引入额外数据库归集，都显著增加运维与复杂度。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #22

Topic 1

A company sends Amazon RDS snapshots to two accounts as part of its disaster recovery (DR) plan. The snapshots must be encrypted. However, each account needs to be able to decrypt the snapshots in case of a DR event. Which solution will meet these requirements?

一家公司将 Amazon RDS 快照发送到两个账户，作为其灾难恢复（DR）计划的一部分。这些快照必须加密。但是，每个账户都需要能够在发生 DR 事件时解密这些快照。
哪种解决方案将满足这些要求？

A. Use the default AWS Key Management Service (AWS KMS) key to generate the snapshots. Create an AWS Lambda function that copies the KMS encryption key to the two accounts.

使用默认的 AWS Key Management Service (AWS KMS) 密钥来生成快照。创建一个 AWS Lambda 函数，将 KMS 加密密钥复制到这两个账户中。

B. Use an AWS Key Management Service (AWS KMS) customer managed key to generate the snapshots. Create an AWS Lambda function that imports the KMS key in the two accounts.

使用 AWS Key Management Service (AWS KMS) 客户管理密钥来生成快照。创建一个 AWS Lambda 函数，将 KMS 密钥导入到这两个账户中。

C. Use the default AWS Key Management Service (AWS KMS) key to generate the snapshots. Share the KMS key with the two accounts by using an IAM principal that has the proper KMS permissions in each account.

使用默认的 AWS Key Management Service (AWS KMS) 密钥来生成快照。通过在每个账户中使用具有适当 KMS 权限的 IAM 主体，与这两个账户共享该 KMS 密钥。

D. Use an AWS Key Management Service (AWS KMS) customer managed key to generate the snapshots. Share the KMS key with the two accounts by using an IAM principal that has the proper KMS permissions in each account.

使用 AWS Key Management Service (AWS KMS) 客户管理密钥来生成快照。通过在每个账户中使用具有适当 KMS 权限的 IAM 主体，与这两个账户共享该 KMS 密钥。

Correct Answer: D

正确答案: D

题目解析：跨账号加密RDS快照用于灾备（DR）

1. 本题考察的知识点

RDS加密快照的跨账号共享与恢复：接收方账号要能在DR时解密并使用快照（拷贝/还原）。

AWS KMS密钥类型差异：AWS managed key（默认/服务托管密钥）vs Customer managed key（客户自管KMS密钥）。

KMS跨账号授权方式：通过**Key policy / Grants**允许其他账号的IAM主体使用该CMK进行Decrypt/Encrypt/GenerateDataKey等操作。

KMS密钥不可“复制/导入到另一个账号”：KMS Key Material与Key本体不支持跨账号复制；导入密钥材料也不等于“把同一把Key搬到另一个账号”。

2. 独立思考（不参考官方答案）

需求是：RDS快照已发送到两个账号（跨账号复制/共享/分发），且**必须加密**；同时两个账号在DR时**必须能解密**。

跨账号解密的关键在于：**加密快照所用的KMS密钥必须允许目标账号使用**。

AWS managed key（默认KMS密钥）通常不能跨账号共享使用；要实现跨账号可解密，通常必须使用**customer managed KMS key**并在key policy中授权目标账号主体。

3. 逐个选项分析

A 选项错误

默认KMS密钥（AWS managed key）不适合跨账号共享：RDS使用的默认aws/rds（或服务默认KMS密钥）通常不能通过key policy授权给外部账号来完成跨账号解密使用。

“复制KMS加密密钥到两个账号”不可行：KMS Key不是可导出、可复制到其他账号的对象；Lambda无法“复制”一把KMS Key到另一个账号。

B 选项错误

使用customer managed key这点方向正确，但后半句错误。

“把KMS key导入到两个账号”不成立：KMS的“导入（import key material）”是把你自带的密钥材料导入到某个KMS Key中，并不是把同一把KMS Key跨账号导入/复制。

即使两个账号都导入相同材料，也会是**两个不同的KMS Key（不同KeyId/ARN）**，不能直接用于解密对方账号用另一把Key加密的数据。

C 选项错误

核心问题仍然是**默认KMS密钥无法按需求进行跨账号共享使用**。

此外，表述“通过IAM principal共享KMS key”也不严谨：KMS跨账号使用依赖**Key policy（资源策略）+ IAM权限（或grant）**。对AWS managed key通常无法满足这种跨账号授权场景。

D 选项正确

使用customer managed KMS key加密RDS快照：满足“快照必须加密”。

通过Key policy（或grants）授权两个目标账号的IAM主体使用该CMK：使目标账号在DR时能够执行解密相关操作（例如复制快照、从快照还原实例时所需的KMS权限）。

这是AWS跨账号共享加密资源（含快照/备份）的一般正确做法：**用CMK + 跨账号授权**。

4. 我选择的答案

D

5. 官方答案

D

6. 与官方答案比较与复盘

我的答案与官方答案一致：D。

原因：只有**customer managed KMS key**能通过key policy/grant进行跨账号授权，从而让两个账号在DR时具备解密与使用快照的能力；默认KMS密钥不能满足此跨账号共享解密需求，且“KMS key复制/导入到其他账号”的说法本身不可行。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #23

Topic 1

A company has a compliance requirement to encrypt all data in transit. The company recently discovered an Amazon Aurora cluster that does not meet this requirement.

How can the company enforce encryption for all connections to the Aurora cluster?

一家公司的合规要求是对所有传输中的数据进行加密。该公司最近发现一个不符合此要求的 Amazon Aurora 集群。公司如何能够对连接到 Aurora 集群的所有连接强制执行加密？

A. In the Aurora cluster configuration, set the `require_secure_transport` DB cluster parameter to ON.

在 Aurora 集群配置中，将 `require_secure_transport` DB 集群参数设置为 ON。

B. Use AWS Directory Service for Microsoft Active Directory to create a user directory and to enforce Kerberos authentication with Aurora.

使用 AWS Directory Service for Microsoft Active Directory 创建用户目录，并使用 Aurora 强制执行 Kerberos 身份验证。

C. Configure the Aurora cluster to use AWS Certificate Manager (ACM) to provide encryption certificates.

将 Aurora 集群配置为使用 AWS Certificate Manager (ACM) 来提供加密证书。

D. Create an Amazon RDS proxy. Connect the proxy to the Aurora cluster to enable encryption.

创建一个 Amazon RDS 代理。将该代理连接到 Aurora 集群以启用加密。

Correct Answer: A

正确答案: A

题目解析：强制 Aurora 集群所有连接加密 (In Transit Encryption Enforcement)

1. 本题考察的知识点

Aurora/RDS 传输中加密 (TLS/SSL)：如何在数据库端强制客户端必须使用加密连接，而不是“可选支持”。

参数组 (DB Cluster Parameter Group / DB Parameter Group) 控制连接策略：通过数据库参数强制拒绝非加密连接。

区分“提供证书/支持SSL”与“强制使用SSL”：支持不等于强制，合规要求通常需要强制。

2. 独立思考 (不参考官方答案)

要“强制所有连接加密”，关键在于：数据库服务端必须拒绝明文连接。

在 Aurora (尤其是 Aurora MySQL) 中，可以通过参数 `require_secure_transport` 强制所有客户端必须使用 TLS/SSL，否则连接被拒绝。

因此，最直接、最符合“强制执行”的方法是修改对应参数组并启用强制安全传输。

3. 逐个选项分析

A. 将 `require_secure_transport` DB 集群参数设置为 ON 为什么正确：

require_secure_transport=ON（常见于 MySQL/Aurora MySQL 兼容环境）会**强制要求**客户端使用 TLS/SSL 加密连接。

未使用 SSL/TLS 的连接会被数据库端拒绝，从而满足“加密所有传输中数据”的合规要求。

这是典型的“在数据库侧强制执行”的做法，而不是依赖客户端自觉。

注意点（考试易混）：

具体参数名称依引擎而异：例如 Aurora PostgreSQL 通常用 **rds.force_ssl**（本题选项未给出）。题目给出的参数名与 MySQL 体系一致，因此更指向 Aurora MySQL。

B. 使用 Directory Service 强制 Kerberos 认证 为什么错误：

Kerberos 认证解决的是“身份认证/单点登录”，并不等价于强制所有连接使用 TLS/SSL。

即便启用 Kerberos/IAM/密码等认证方式，若不强制 TLS，仍可能存在未加密传输的连接路径（取决于配置）。

题目要求是“encrypt all data in transit”，核心是**传输加密强制**，不是认证机制升级。

C. 配置 Aurora 使用 ACM 提供加密证书 为什么错误：

Aurora/RDS 的数据库 TLS 证书通常由 AWS/RDS 体系管理（例如使用 RDS CA），并不是让你“把 ACM 证书挂到数据库引擎上”来实现客户端连接加密。

更关键的是：**即便有证书，也只是“支持 TLS”，并不自动“强制所有连接必须 TLS”。**

因此该选项既不符合 Aurora 常规做法，也不满足“强制执行”的目标。

D. 创建 RDS Proxy 并连接到 Aurora 以启用加密 为什么错误（或不充分）：

RDS Proxy 主要解决连接池、故障转移、凭证管理等问题；它可以使用 TLS 与客户端/数据库通信，但这不等于从数据库端**强制拒绝**明文直连。

即使通过 Proxy 实现加密，仍可能有人绕过 Proxy 直接连接数据库实例/集群端点（若网络可达且未强制 TLS）。

题目要“enforce encryption for all connections to the Aurora cluster”，最佳实践是在数据库参数层面强制。

4. 我选择的答案

A

5. 官方答案

A

6. 与官方答案对比与复盘

结论：一致（我选 A，官方也是 A）。

复盘原因：本题的“enforce”关键词决定必须用数据库端强制策略（拒绝非 TLS 连接），而不是仅提供证书、仅改善认证、或通过中间层尝试覆盖。

补充辨析：若题目明确是 Aurora PostgreSQL，引擎侧常见参数会是 **rds.force_ssl=1**（本题未提供该选项），因此在给定选项下 A 仍是最合理且唯一满足“强制 TLS”的答案。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #24

Topic 1

A company's public website consists of an Application Load Balancer (ALB), a set of Amazon EC2 instances that run a stateless application behind the ALB, and an Amazon DynamoDB table from which the application reads data. The company is concerned about malicious scanning and DDoS attacks. The company wants to impose a restriction in which each client IP address can read the data only 3 times in any 5-minute period.

Which solution will meet this requirement with the LEAST effort?

一家公司的公共网站由一个 Application Load Balancer (ALB)、一组在 ALB 后面运行无状态应用程序的 Amazon EC2 实例, 以及一个应用程序从中读取数据的 Amazon DynamoDB 表组成。该公司担心恶意扫描和 DDoS 攻击。公司希望施加一项限制: 每个客户端 IP 地址在任意 5 分钟周期内只能读取数据 3 次。

哪种解决方案能以最少的工作量满足此要求?

A. Set up AWS WAF in front of the ALB. Create a rule that blocks requests that exceed the limit of 3 requests in any 5-minute period for each IP address.

在 ALB 前面设置 AWS WAF。创建一条规则, 对每个 IP 地址在任意 5 分钟周期内超过 3 次请求限制的请求进行阻止。

B. Create an AWS Lambda function based on an Amazon CloudWatch request. Configure the Lambda function to count the requests for each IP address in rolling 5-minute intervals and to provide notification if the count exceeds 3.

基于 Amazon CloudWatch 请求创建一个 AWS Lambda 函数。将该 Lambda 函数配置为以滚动的 5 分钟时间窗口统计每个 IP 地址的请求次数, 并在计数超过 3 时提供通知。

C. Modify the EC2 application to count the source IP address of requests and calculate a rolling 5-minute sum. Return an error message if the count sum is greater than 3.

修改 EC2 应用程序以统计请求的源 IP 地址并计算滚动的 5 分钟总和。如果计数总和大于 3, 则返回错误消息。

D. Add source IP address and request time to the DynamoDB table. Add a 5-minute TTL setting based on request time. Change the read capacity of the DynamoDB table throughput to 3.

向 DynamoDB 表中添加源 IP 地址和请求时间。基于请求时间添加 5 分钟的 TTL 设置。将 DynamoDB 表的吞吐量读取容量更改为 3。

Correct Answer: A

正确答案: A

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

AWS WAF 速率限制 (Rate-based rule): 按源 IP 在固定时间窗口内限制请求次数, 适用于缓解恶意扫描与一定程度的 DDoS/应用层洪泛。

在 ALB 前集成 WAF 的安全控制点: 在进入应用与后端之前拦截流量, 减少对 EC2/DynamoDB 的压力。

“最小工作量 (LEAST effort)”的方案选择：优先选托管服务原生能力，避免改代码/自建统计系统。

2. 独立思考（不参考官方答案）

需求是：每个客户端 IP 在任意 5 分钟内最多读取 3 次数据，且要应对恶意扫描与 DDoS。

在 ALB 前放置 AWS WAF 的 Rate-based rule 可按 IP 限速并直接阻断请求，是最贴合“每 IP、固定时间窗、限制次数”的托管能力。

其他方案要么只是告警不拦截，要么需要改应用/自建计数逻辑，要么误用 DynamoDB 吞吐概念，均不符合“最小工作量”。

3. 逐个选项分析

A 选项：在 ALB 前面设置 AWS WAF，创建规则阻止 5 分钟超过 3 次的 IP

正确性：正确。

原因：AWS WAF 支持 Rate-based rule（速率限制规则），可按源 IP 聚合，在指定时间窗口内超过阈值就阻断（或执行其他动作）。

与场景匹配：在到达 EC2/DynamoDB 之前拦截，能减少后端压力，符合“恶意扫描/DDoS”的关注点。

工作量：最小，无需改代码，无需自建状态存储与计数。

B 选项：用 CloudWatch 触发 Lambda 统计 5 分钟滚动窗口并通知

正确性：错误。

原因：该方案描述的是通知（notification），并没有实现“超过 3 次就阻止读取”。

实现难点：要做到按 IP 的实时阻断，还需额外把阻断策略回写到 WAF/IPSet 或在应用侧实时查询计数；同时 CloudWatch 指标/日志到 Lambda 的链路通常有延迟，不适合严格的实时限流。

工作量：明显高于直接用 WAF 速率规则。

C 选项：修改 EC2 应用统计每个源 IP 的滚动 5 分钟总和并超限返回错误

正确性：错误（就“最小工作量”而言不满足；且实现复杂）。

原因：应用是无状态（stateless），在多台 EC2 实例后面需要共享状态存储（如 ElastiCache/Redis、DynamoDB 计数表等）才能正确统计“每 IP 5 分钟 3 次”。否则每台实例各算各的会绕过限制。

安全效果：请求仍会打到 ALB/EC2，无法在边界处减压，不如 WAF。

工作量：改代码 + 可能新增存储/同步机制，工作量大。

D 选项：把源 IP 和请求时间写入 DynamoDB，设置 5 分钟 TTL，把表读吞吐改为 3

正确性：错误。

原因 1：把 DynamoDB 表的读容量（RCU）改为 3 限制的是“表整体吞吐”，不是“每个客户端 IP 3 次/5 分钟”。不同 IP 会互相影响，完全不符合需求。

原因 2：TTL 只是过期清理机制（且清理并非精确到秒），并不能直接实现强一致的实时限流；仍需额外逻辑检查计数并拒绝请求。

原因 3：该方案还会增加 DynamoDB 写入（记录请求）成本与复杂度，且无法在 ALB 前阻断。

4. 我选择的答案

A

5. 官方答案

A

6. 与官方答案对比与复盘

对比结果：我的答案与官方答案一致（A）。

原因总结：本题核心是“每 IP 在 5 分钟内限制请求次数”且“最小工作量”，WAF Rate-based rule 正是为此设计，并且能在 ALB 前拦截流量，兼顾恶意扫描与应用层 DDoS 的缓解。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #25

Topic 1

A public subnet contains two Amazon EC2 instances. The subnet has a custom network ACL. A security engineer is designing a solution to improve the subnet security.

The solution must allow outbound traffic to an internet service that uses TLS through port 443. The solution also must deny inbound traffic that is destined for MySQL port 3306.

Which network ACL rule set meets these requirements?

一个公有子网包含两台 Amazon EC2 实例。该子网具有自定义网络 ACL。安全工程师正在设计一种解决方案来提高子网安全性。该解决方案必须允许通过 443 端口使用 TLS 的互联网服务的出站流量。该解决方案还必须拒绝目标为 MySQL 端口 3306 的入站流量。

哪一组网络 ACL 规则集满足这些要求?

A. Use inbound rule 100 to allow traffic on TCP port 443. Use inbound rule 200 to deny traffic on TCP port 3306. Use outbound rule 100 to allow traffic on TCP port 443.

使用入站规则 100 允许 TCP 端口 443 上的流量。使用入站规则 200 拒绝 TCP 端口 3306 上的流量。使用出站规则 100 允许 TCP 端口 443 上的流量。

B. Use inbound rule 100 to deny traffic on TCP port 3306. Use inbound rule 200 to allow traffic on TCP port range 1024-65535. Use outbound rule 100 to allow traffic on TCP port 443.

使用入站规则 100 拒绝 TCP 端口 3306 上的流量。使用入站规则 200 允许 TCP 端口范围 1024-65535 上的流量。使用出站规则 100 允许 TCP 端口 443 上的流量。

C. Use inbound rule 100 to allow traffic on TCP port range 1024-65535. Use inbound rule 200 to deny traffic on TCP port 3306. Use outbound rule 100 to allow traffic on TCP port 443.

使用入站规则 100 允许 TCP 端口范围 1024-65535 上的流量。使用入站规则 200 拒绝 TCP 端口 3306 上的流量。使用出站规则 100 允许 TCP 端口 443 上的流量。

D. Use inbound rule 100 to deny traffic on TCP port 3306. Use inbound rule 200 to allow traffic on TCP port 443. Use outbound rule 100 to allow traffic on TCP port 443.

使用入站规则 100 拒绝 TCP 端口 3306 上的流量。使用入站规则 200 允许 TCP 端口 443 上的流量。使用出站规则 100 允许 TCP 端口 443 上的流量。

Correct Answer: B

正确答案: B

题目解析: NACL规则设计 (出站HTTPS + 入站拒绝MySQL)

1. 本题考察的知识点

Network ACL (NACL) 是无状态 (stateless) : 入站与出站必须分别显式放行返回流量。

NACL规则按编号从小到大匹配，命中即停止（first match wins）。

出站访问互联网HTTPS (TLS/443)：需要允许出站目的端口443；同时需要在入站方向允许返回流量的目标端口（临时端口 ephemeral ports，通常1024-65535）。

拒绝入站到MySQL 3306：如果同时存在“允许较大端口范围（如1024-65535）”的规则，必须确保**拒绝3306的规则编号更小**，否则会被先放行。

2. 独立思考（不参考官方答案）的结论

实例作为客户端访问互联网服务（目的端口443）时：**出站：**目的端口443需要允许。**入站：**返回包的**目的端口**是客户端临时端口（1024-65535），因此需要允许入站1024-65535（或更精确的临时端口范围）。

同时要**拒绝入站目的端口3306**，且3306属于1024-65535范围内，因此必须把拒绝3306放在允许1024-65535之前（更小的规则号）。

3. 逐个选项分析

选项 A

入站100允许TCP 443：不满足“出站访问HTTPS所需的返回流量”放行要求。出站访问HTTPS的返回流量入站时目的端口是**临时端口**，不是443。

入站200拒绝TCP 3306：能拒绝3306本身，但整体仍会导致HTTPS会话返回流量被拦。

出站100允许TCP 443：正确，允许客户端向外访问目的端口443。

结论：错误。缺少允许入站临时端口（1024-65535）用于TLS返回流量。

选项 B

入站100拒绝TCP 3306：正确。明确拒绝入站目的端口3306。

入站200允许TCP 1024-65535：正确。用于允许出站HTTPS连接的返回流量（入站目的端口为临时端口）。

规则顺序正确：先拒绝3306（100），再允许1024-65535（200）。因为3306属于1024-65535，必须先拒绝，否则会被放行。

出站100允许TCP 443：正确。允许访问互联网服务的目的端口443。

结论：正确。满足“允许出站TLS/443”与“拒绝入站3306”。

选项 C

入站100允许TCP 1024-65535：表面上可允许返回流量，但会**同时放行**目的端口3306（因为3306在该范围内）。

入站200拒绝TCP 3306：由于NACL先匹配先停止，3306流量会先命中入站100的允许规则，导致拒绝规则200**不会生效**。

出站100允许TCP 443：正确，但无法弥补入站3306未被拒绝的问题。

结论：错误。规则顺序导致3306未被拒绝。

选项 D

入站100拒绝TCP 3306：正确。

入站200允许TCP 443：对“出站访问HTTPS”的返回流量无帮助；返回流量入站时目的端口通常是临时端口，不是443。

出站100允许TCP 443：正确。

结论：错误。缺少允许入站临时端口（1024-65535）以放行TLS返回流量。

4. 我选择的答案

B

5. 官方答案

B

6. 与官方答案比较与复盘

我的答案与官方答案一致：B。

原因总结：NACL无状态 + 规则按序匹配。为保证出站HTTPS成功，必须允许出站目的端口443，并允许入站返回流量的目的临时端口（1024-65535）。同时因为3306在1024-65535范围内，必须先拒绝3306再允许大范围端口。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #26

Topic 1

A company is using Amazon Elastic Container Service (Amazon ECS) to deploy an application that deals with sensitive data. During a recent security audit, the company identified a security issue in which Amazon RDS credentials were stored with the application code in the company's source code repository.

A security engineer needs to develop a solution to ensure that database credentials are stored securely and rotated periodically. The credentials should be accessible to the application only. The engineer also needs to prevent database administrators from sharing database credentials as plaintext with other teammates. The solution must also minimize administrative overhead. Which solution meets these requirements?

一家公司正在使用 Amazon Elastic Container Service (Amazon ECS) 来部署一个处理敏感数据的应用程序。在最近的一次安全审计中，公司发现了一个安全问题：Amazon RDS 凭证与应用程序代码一起存储在公司的源代码存储库中。

一名安全工程师需要开发一个解决方案，以确保数据库凭证被安全存储并定期轮换。凭证应仅可被该应用程序访问。工程师还需要防止数据库管理员以明文形式与其他队友共享数据库凭证。该解决方案还必须将管理开销降至最低。

哪种解决方案满足这些要求？

A. Use the AWS Systems Manager Parameter Store to generate database credentials. Use an IAM profile for ECS tasks to restrict access to database credentials to specific containers only.

使用 AWS Systems Manager Parameter Store 生成数据库凭证。为 ECS 任务使用 IAM 配置文件，将对数据库凭证的访问限制为仅特定容器可访问。

B. Use AWS Secrets Manager to store database credentials. Use an IAM inline policy for ECS tasks to restrict access to database credentials to specific containers only.

使用 AWS Secrets Manager 存储数据库凭证。为 ECS 任务使用 IAM 内联策略，将对数据库凭证的访问限制为仅特定容器可访问。

C. Use the AWS Systems Manager Parameter Store to store database credentials. Use IAM roles for ECS tasks to restrict access to database credentials to specific containers only.

使用 AWS Systems Manager Parameter Store 存储数据库凭证。为 ECS 任务使用 IAM 角色，将对数据库凭证的访问限制为仅特定容器可访问。

D. Use AWS Secrets Manager to store database credentials. Use IAM roles for ECS tasks to restrict access to database credentials to specific containers only.

使用 AWS Secrets Manager 存储数据库凭证。为 ECS 任务使用 IAM 角色，将对数据库凭证的访问限制为仅特定容器可访问。

Correct Answer: D

正确答案: D

题目解析 (AWS Certified Security - Specialty SCS-C03 做题教练)

1. 本题考察的知识点

敏感凭证的安全存储：避免将RDS用户名/密码硬编码在代码库中。

凭证轮换 (Rotation)：周期性自动轮换数据库密码，降低泄露风险。

ECS访问控制：使用ECS Task Role (**任务IAM角色**) 实现“只有应用 (任务/容器) 能读到凭证”的最小权限。

防止明文传播：通过集中式密钥/凭证服务 + IAM权限控制，减少DBA以明文方式共享密码的可能性。

降低运维开销：优先选用原生支持自动轮换、与RDS集成良好的托管服务 (Secrets Manager)。

2. 独立思考 (不参考官方答案)

题目明确要求：**安全存储 + 定期轮换 + 仅应用可访问 + 防止DBA明文共享 + 最小管理开销。**

在AWS中，**AWS Secrets Manager**是针对“密钥/口令类机密信息”的专用服务，并且**原生支持RDS凭证轮换** (通过Lambda rotation)。

对ECS应用侧，最佳实践是使用**ECS taskRoleArn (任务角色)** 授予容器内应用访问Secrets Manager的权限，而不是依赖实例角色或人工分发。

3. 逐个分析每个选项为什么正确或错误

A. 使用 Parameter Store 生成数据库凭证 + ECS任务IAM profile限制访问

错误点1：Parameter Store并不负责“生成”数据库凭证。Parameter Store主要是存储参数 (可加密SecureString)，不是凭证生成/轮换服务。

错误点2：轮换能力不匹配。Parameter Store没有像Secrets Manager那样的一体化凭证轮换能力 (通常需要自建流程/Lambda/脚本协调更新RDS与Parameter Store)。与“最小管理开销”冲突。

错误点3：ECS任务的“IAM profile”表述不准确。ECS常用的是**Task Role (任务角色)** 为任务授予权限；“instance profile”更偏向EC2实例角色概念。选项描述不符合常见ECS权限模型表述。

结论：不满足“定期轮换 + 最小开销”。

B. 使用 Secrets Manager 存储凭证 + ECS任务使用IAM inline policy限制访问

正确点1：Secrets Manager适合存储RDS凭证，并支持自动轮换 (满足核心需求)。

正确点2：可以通过IAM策略 (包括inline policy) 限制ECS任务访问特定secret，实现“仅应用可访问”。

主要问题：inline policy并非最佳实践且增加管理复杂度。inline policy绑定在单一角色实体上，不利于复用、审计与集中治理；题目强调“最小管理开销”，通常更倾向使用可复用的managed policy或标准任务角色权限配置。

次要问题：题干说“restrict access...to specific containers only”。在ECS中权限边界主要落在**任务角色 (task role)** 层级，而不是在同一个task definition里对“某个container”单独绑不同IAM角色 (除非拆分为不同task/服务)。选项虽然能表达“应用侧最小权限”，但表述不如“使用IAM roles for ECS tasks”标准。

结论：方向对，但不是最佳/最贴合要求的表达。

C. 使用 Parameter Store 存储凭证 + ECS任务IAM角色限制访问

正确点1：ECS任务角色限制访问是对的，可以做到只有应用任务能读取参数。

错误点1：轮换不够原生。Parameter Store存储凭证可以，但要实现“周期轮换并同步更新RDS用户密码”通常需要自建轮换机制；相比Secrets Manager管理开销更高。

错误点2：与题目“最小管理开销”冲突。题目明确要求周期轮换，Parameter Store并不是为此设计的首选方案。

结论：不满足“最小管理开销 + 原生轮换”期望。

D. 使用 Secrets Manager 存储凭证 + ECS任务IAM角色限制访问

正确点1：Secrets Manager满足安全存储 (加密、审计、细粒度访问控制)。

正确点2：Secrets Manager满足周期轮换 (与RDS集成的Rotation方案最常见、最贴题)。

正确点3：ECS任务角色满足“仅应用可访问”。通过task role仅允许特定任务 (应用) 调用secretsmanager:GetSecretValue，并限定到特定Secret ARN。

正确点4：减少DBA明文共享。DBA可以被限制不具备读取secret的权限；应用通过IAM取用，避免团队成员通过聊天/邮件传播明文密码。

正确点5：最小运维开销。Secrets Manager原生轮换与集中管理优于自建轮换流程。

结论：最符合全部要求。

4. 我选择的答案

D

5. 官方答案

D

6. 与官方答案比较与复盘

对比结果：一致（我选D，官方也选D）。

原因总结：只有Secrets Manager能在“凭证安全存储 + 原生轮换 + 与ECS task role最小权限集成 + 降低明文传播风险 + 最小管理开销”上同时满足题目所有约束；Parameter Store在“原生轮换/低开销”上明显不如Secrets Manager。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #27

Topic 1

A corporate cloud security policy states that communications between the company's VPC and KMS must travel entirely within the AWS network and not use public service endpoints.

Which combination of the following actions MOST satisfies this requirement? (Choose two.)

某企业云安全策略规定，公司 VPC 与 KMS 之间的通信必须完全在 AWS 网络内传输，并且不得使用公有服务端点。以下哪些操作组合最能满足此要求？（选择两项。）

A. Add the `aws:sourceVpce` condition to the AWS KMS key policy referencing the company's VPC endpoint ID.

在 AWS KMS 密钥策略中添加 `aws:sourceVpce` 条件，引用公司的 VPC 端点 ID。

B. Remove the VPC internet gateway from the VPC and add a virtual private gateway to the VPC to prevent direct, public internet connectivity.

从 VPC 中移除 VPC Internet 网关，并向 VPC 添加虚拟私有网关，以防止直接的公有互联网连接。

C. Create a VPC endpoint for AWS KMS with private DNS enabled.

为 AWS KMS 创建一个 VPC 端点，并启用私有 DNS。

D. Use the KMS Import Key feature to securely transfer the AWS KMS key over a VPN.

使用 KMS Import Key 功能，通过 VPN 安全传输 AWS KMS 密钥。

E. Add the following condition to the AWS KMS key policy: `"aws:SourceIp": "10.0.0.0/16"`.

在 AWS KMS 密钥策略中添加以下条件: `"aws:SourceIp": "10.0.0.0/16"`。

Correct Answer: AC

正确答案: AC

题目解析：VPC 与 AWS KMS 通信必须全程走 AWS 内网、不能使用公有服务端点（选择两项）

1) 本题考察的知识点

AWS PrivateLink / Interface VPC Endpoint: 通过为 KMS 创建 **Interface VPC Endpoint**，让对 KMS 的 API 调用在 AWS 网络内完成，而不是走公网的 KMS Public Endpoint。

Private DNS: 启用后，访问标准域名（如 `kms.<region>.amazonaws.com`）会被解析到 VPC Endpoint 的私有地址，从而避免“误走公网端点”。

KMS Key Policy 条件限制: 用 `aws:sourceVpce`（或相关条件）约束只有来自指定 VPC Endpoint 的请求才允许使用该 CMK，从策略层面强制“必须经由 VPC Endpoint”。

2) 独立思考（不参考官方答案）

要求是：VPC 与 KMS 的通信必须完全在 AWS 网络内，并且不能使用公有服务端点。

要做到“网络路径在 AWS 内网”，关键是为 KMS 配置 **VPC Endpoint (Interface Endpoint)**。

要做到“不能用公有端点”，最好同时做到两层控制：

解析层面：启用 **Private DNS**，让常用 KMS 域名自动走 Endpoint。

授权层面：在 **KMS Key Policy** 中限制仅允许来自该 **Vpce** 的请求。

3) 逐个选项分析

A. 在 KMS 密钥策略中添加 aws:sourceVpce 条件，引用公司的 VPC 端点 ID。结论：正确。原因：

这会在 **KMS Key Policy** 层面强制：只有通过指定的 **VPC Endpoint (vpce-...)** 发起的 KMS 请求才被允许。

即使有人故意尝试走公网 KMS Endpoint（或从其他网络路径访问），也会因为不满足 **aws:sourceVpce** 条件而被拒绝，从而满足“不能使用公有服务端点”的合规要求。

B. 移除 Internet Gateway 并添加 Virtual Private Gateway 防止直接公网连接。结论：错误/不最符合。原因：

移除 IGW 会影响实例访问互联网，但并不能直接证明或保证对 KMS 的调用“只能走私有端点”。

VPC 里仍可能通过其他出口（如 NAT、其他网络路径、代理/中转、或未来网络变更）访问公有服务端点；而且题目重点是“KMS 访问路径”，最佳实践是用 **VPC Endpoint + Key Policy** 控制。

添加 VGW（VPN/Direct Connect）是为混合云连通，不是让 VPC->KMS 变成内网访问的核心手段。

C. 为 AWS KMS 创建 VPC 端点并启用 private DNS。结论：正确。原因：

KMS 支持通过 **Interface VPC Endpoint (AWS PrivateLink)** 在 AWS 网络内访问服务。

启用 **Private DNS** 后，访问标准 KMS 域名会解析到该 Endpoint，减少配置/代码改动，并显著降低误用公有端点的可能。

这是满足“通信全程在 AWS 网络内、避免公有端点”的关键配置之一。

D. 使用 KMS Import Key 通过 VPN 安全传输 KMS 密钥。结论：错误。原因：

KMS Import Key（导入密钥材料）讨论的是密钥材料导入流程，不是应用/服务对 KMS API 的日常调用路径。

题目关心的是“VPC 与 KMS 通信不走公有端点”，与“是否通过 VPN 传输密钥材料”无直接对应关系。

E. 在 KMS 密钥策略中添加 "aws:SourceIp": "10.0.0.0/16"。结论：错误/不可靠。原因：

对 AWS 托管服务（KMS）而言，**SourceIp** 条件通常用于基于公网源 IP 的限制；而通过 VPC Endpoint/PrivateLink 访问时，请求到达服务端看到的“源 IP”不一定是你 VPC 的私网段 IP，策略可能无法按预期工作。

即使能匹配某些场景，也无法精确表达“必须走指定 VPC Endpoint”，而 **aws:sourceVpce** 才是更直接、可审计且符合题意的控制手段。

4) 我选择的答案

A + C

5) 官方答案

A + C

6) 与官方答案对比与复盘

对比结果：一致（A + C）。

复盘原因：

C 提供“走 AWS 内网”的网络路径（Interface VPC Endpoint + Private DNS）。

A 从权限策略层面强制“必须通过该 VPC Endpoint”，防止绕过到公有 KMS Endpoint。

两者组合最能满足“必须全程在 AWS 网络内且不使用公有服务端点”的合规要求。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #28

Topic 1

A security engineer received an Amazon GuardDuty alert indicating a finding involving the Amazon EC2 instance that hosts the company's primary website. The GuardDuty finding received read:

UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration.

The security engineer confirmed that a malicious actor used API access keys intended for the EC2 instance from a country where the company does not operate. The security engineer needs to deny access to the malicious actor.

What is the first step the security engineer should take?

一名安全工程师收到一条 Amazon GuardDuty 警报，指示一项涉及托管公司主网站的 Amazon EC2 实例的发现 (finding)。收到的 GuardDuty 发现内容如下：

UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration.

安全工程师确认，某个恶意行为者从公司不开展业务的国家/地区使用了原本用于该 EC2 实例的 API 访问密钥。安全工程师需要拒绝该恶意行为者的访问。

安全工程师应该采取的第一步是什么？

A. Open the EC2 console and remove any security groups that allow inbound traffic from 0.0.0.0/0.

打开 EC2 控制台并移除任何允许来自 0.0.0.0/0 的入站流量的安全组。

B. Install the AWS Systems Manager Agent on the EC2 instance and run an inventory report.

在 EC2 实例上安装 AWS Systems Manager Agent 并运行清单报告。

C. Install the Amazon Inspector agent on the host and run an assessment with the CVE rules package.

在主机上安装 Amazon Inspector 代理并使用 CVE 规则包运行评估。

D. Open the IAM console and revoke all IAM sessions that are associated with the instance profile.

打开 IAM 控制台并撤销与该实例配置文件关联的所有 IAM 会话。

Correct Answer: D

正确答案: D

题目解析：UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration (EC2实例角色凭证外泄)

1. 本题考察的知识点

Amazon GuardDuty Finding: UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration 的含义：EC2 实例通过实例元数据服务 (IMDS) 获得的**实例角色 (Instance Profile / IAM Role)** 临时凭证 (STS Credentials) 疑似被窃取，并在异常地理位置/网络环境中被使用。

事件响应优先级：第一步通常是**立即阻断攻击者继续使用已泄露的凭证**（让现有会话/临时凭证失效或立刻失去权限），而不是先做漏洞扫描或主机基线盘点。

IAM 会话撤销 (Revoke sessions)：通过撤销与角色相关的活动会话/会话凭证，使攻击者当前拿到的临时凭证尽快失效（比等待 STS 过期更快）。

2. 独立思考（不参考官方答案）

题干已确认攻击者在公司不运营的国家使用了“intended for the EC2 instance”的 API 访问密钥，本质上是**实例角色临时凭证被外泄并被异地滥用**。

“需要拒绝访问 (deny access)”且问“first step”，应选择**最快让攻击者手上凭证立即/尽快失效或失去权限**的操作。

四个选项里，只有**撤销与实例角色相关的 IAM 会话**是直接、针对性地阻断已泄露凭证继续使用的动作；其他选项要么不相关，要么是后续排查工作。

3. 逐个选项分析

A. 移除允许 0.0.0.0/0 入站的安全组规则 错误。原因：

GuardDuty 告警是**API 凭证被异地调用**，属于控制面（AWS API）滥用，不是网站被直接入侵的“入站流量”问题。

即便收紧 80/443 入站，也**无法阻止攻击者使用已盗取的 AWS API 临时凭证**去调用 AWS 服务。

安全组主要保护实例网络面，不能用来撤销/禁用 IAM 凭证。

B. 安装 SSM Agent 并运行 Inventory 错误。原因：

这是资产盘点/运维可视化手段，属于**取证/排查/基线**方向。

不能作为“第一步”去**立即拒绝攻击者访问**。

且若实例已被入侵，先装 Agent 也可能受阻或带来额外变更；但关键是它不解决“凭证正在被滥用”的紧急风险。

C. 安装 Amazon Inspector agent 并跑 CVE 评估 错误。原因：

这是漏洞扫描/评估，属于**事后改进或并行排查**，并不能即时阻断已泄露的 IAM 临时凭证的使用。

题干目标是“deny access to the malicious actor”，优先级应是先切断攻击者凭证权限/会话，而不是先做 CVE 扫描。

D. 撤销与实例配置文件（实例角色）关联的所有 IAM 会话 正确。原因：

该告警指向**实例角色临时凭证外泄**，撤销相关会话可以让已签发的会话/凭证尽快失效，**直接阻断攻击者继续调用 API**。

符合“first step”：这是最贴近“立即拒绝访问”的处置动作。

后续才是调查根因（是否 IMDSv1、是否 SSRF、是否主机被植入、是否需要换角色/收紧权限/轮转等）。

4. 我选择的答案

D

5. 官方答案

D

6. 与官方答案对比与复盘

一致：我选择 D，官方答案也是 D。

原因：该 GuardDuty Finding 的核心风险是**实例角色临时凭证正在被外部滥用**，第一步应优先**让现有会话/凭证失效或失去权限**，撤销与实例角色相关的 IAM 会话最符合“立即拒绝访问”的要求。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #29

Topic 1

A company wants to store all objects that contain sensitive data in an Amazon S3 bucket. The company will use server-side encryption to encrypt the S3 bucket. The company's operations team manages access to the company's S3 buckets. The company's security team manages access to encryption keys.

The company wants to separate the duties of the two teams to ensure that configuration errors by only one of these teams will not compromise the data by granting unauthorized access to plaintext data.

Which solution will meet this requirement?

一家公司希望将所有包含敏感数据的对象存储在一个 Amazon S3 存储桶中。公司将使用服务器端加密来加密该 S3 存储桶。公司的运维团队管理对公司 S3 存储桶的访问。公司的安全团队管理对加密密钥的访问。

公司希望分离这两个团队的职责，以确保仅由其中一个团队造成的配置错误不会通过授予对明文数据的未授权访问而危及数据。

哪种解决方案将满足此要求？

A. Ensure that the operations team configures default bucket encryption on the S3 bucket to use server-side encryption with Amazon S3 managed encryption keys (SSE-S3). Ensure that the security team creates an IAM policy that controls access to use the encryption keys.

确保运维团队在 S3 存储桶上配置默认存储桶加密，以使用带有 Amazon S3 托管加密密钥（SSE-S3）的服务器端加密。确保安全团队创建一个 IAM 策略，用于控制对加密密钥使用权限的访问。

B. Ensure that the operations team creates a bucket policy that requires requests to use server-side encryption with AWS KMS keys (SSE-KMS) that are customer managed. Ensure that the security team creates a key policy that controls access to the encryption keys.

确保运维团队创建一个存储桶策略，要求请求使用由客户管理的 AWS KMS 密钥（SSE-KMS）进行服务器端加密。确保安全团队创建一个密钥策略，用于控制对加密密钥的访问。

C. Ensure that the operations team creates a bucket policy that requires requests to use server-side encryption with Amazon S3 managed keys (SSE-S3). Ensure that the security team creates an IAM policy that controls access to the encryption keys.

确保运维团队创建一个存储桶策略，要求请求使用带有 Amazon S3 托管密钥（SSE-S3）的服务器端加密。确保安全团队创建一个 IAM 策略，用于控制对加密密钥的访问。

D. Ensure that the operations team creates a bucket policy that requires requests to use server-side encryption with customer-provided encryption keys (SSE-C). Ensure that the security team stores the customer-provided keys in AWS Key Management Service (AWS KMS). Ensure that the security team creates a key policy that controls access to the encryption keys.

确保运维团队创建一个存储桶策略，要求请求使用带有客户提供的加密密钥（SSE-C）的服务器端加密。确保安全团队将客户提供的密钥存储在 AWS Key Management Service (AWS KMS) 中。确保安全团队创建一个密钥策略，用于控制对加密密钥的访问。

Correct Answer: B

正确答案: B

题目解析：S3 加密与职责分离 (Separation of Duties)

1. 考察的知识点

Amazon S3 服务端加密方式差异： SSE-S3、SSE-KMS (AWS KMS 托管/客户托管 CMK)、SSE-C 的工作机制与权限控制点。

职责分离 (Separation of Duties)： 运维团队管 S3 访问与桶策略；安全团队管 KMS 密钥访问与密钥策略 (Key policy)。

防止单点配置失误导致明文泄露： 即使某一方 (运维或安全) 误配，也不能单独导致“未授权获得明文数据”。

S3 Bucket Policy 与 KMS Key Policy 的组合授权模型： 访问 SSE-KMS 加密对象需要同时具备 S3 权限与 KMS 使用权限 (Decrypt/GenerateDataKey 等)。

2. 独立思考 (不参考官方答案)

目标是：**运维团队掌管桶和访问，但不能单独让人拿到明文；安全团队掌管密钥，但不能单独让人绕过桶权限拿到明文。**

要实现这一点，最典型方案是：**S3 使用 SSE-KMS (客户托管 CMK)**，并且：运维：用 Bucket Policy 强制所有写入必须 SSE-KMS (指定 CMK)；安全：用 KMS Key Policy (或配合 IAM) 严格控制谁能 Decrypt。

因为读取 SSE-KMS 对象的明文，必须同时满足：**(1) S3 GetObject 权限 + (2) KMS Decrypt 权限**。这样任意一方的误配都不足以单独泄露明文。

3. 逐个选项分析

A 选项分析

方案内容： 运维配置默认加密为 SSE-S3；安全团队创建 IAM policy 控制“使用加密密钥”。

问题1：SSE-S3 的密钥由 S3 管理，客户无法通过 IAM/KMS Key Policy 精细控制“Decrypt 权限”。 SSE-S3 不提供像 KMS 那样可由安全团队独立管理的密钥权限边界。

问题2：安全团队所谓“控制使用加密密钥”的 IAM policy 在 SSE-S3 场景下并不成立： 没有可供安全团队控制的 KMS CMK 权限面。

结论： 无法实现题目要求的职责分离与双重控制；**错误。**

B 选项分析

方案内容： 运维：Bucket Policy 强制所有请求使用 SSE-KMS 且为客户托管的 KMS Key；安全：KMS Key Policy 控制对密钥的访问 (如 kms:Decrypt、kms:GenerateDataKey)。

为什么满足职责分离：

运维即使误把 S3 GetObject 给了某个主体，如果该主体没有 KMS Decrypt 权限，也拿不到明文 (解密会失败)。

安全即使误给了某个主体 KMS Decrypt 权限，但如果该主体没有 S3 GetObject 权限，也拿不到密文对象，更无法拿到明文。

需要两边都配对 (S3 权限 + KMS 权限) 才会泄露明文，符合“单方配置错误不会泄露明文”的要求。

补充要点： Bucket Policy 通常会用显式 Deny 强制：不带 x-amz-server-side-encryption=aws:kms 的 PutObject 拒绝；并可要求指定 kms key id，避免使用非预期密钥。

结论： 满足要求；**正确。**

C 选项分析

方案内容： 运维用 Bucket Policy 强制 SSE-S3；安全团队用 IAM policy 控制加密密钥访问。

关键问题： 同 A 类似，SSE-S3 的密钥不在 KMS 权限体系下由客户控制，安全团队无法通过“密钥权限”形成独立的控制面。

结论： 职责分离目标无法达成；**错误。**

D 选项分析

方案内容： 运维强制 SSE-C；安全团队把客户提供的密钥存入 KMS，并用 Key policy 控制访问。

关键问题1：SSE-C 的密钥是“每次请求由客户端在 HTTP 头中提供”， S3 不会把 SSE-C 密钥托管到 KMS；SSE-C 与 KMS Key Policy 没有这种集成的“由 KMS 控制 Decrypt”的模型。

关键问题2：把 SSE-C 的 key “存到 KMS”并不能让 S3 在读写对象时去 KMS 取 key； S3 不支持这种工作流。

结论： 方案描述与实际能力不符；**错误。**

4. 我选择的答案

B

5. 官方答案

B

6. 与官方答案比较与复盘

我的答案：**B**；官方答案：**B**；**一致**。

复盘确认原因：只有 SSE-KMS（客户托管 CMK）才能把“对象访问（S3）”与“解密能力（KMS）”拆成两个独立的权限域，由不同团队分别掌控，从而实现“单方误配不会导致明文泄露”。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #30

Topic 1

A company is running its application on AWS. The company has a multi-environment setup, and each environment is isolated in a separate AWS account. The company has an organization in AWS Organizations to manage the accounts. There is a single dedicated security account for the organization.

The company must create an inventory of all sensitive data that is stored in Amazon S3 buckets across the organization's accounts. The findings must be visible from a single location.

Which solution will meet these requirements?

一家公司正在 AWS 上运行其应用程序。该公司具有多环境设置，并且每个环境都在单独的 AWS 账户中隔离。该公司在 AWS Organizations 中有一个组织来管理这些账户。该组织有一个专用的单一安全账户。
公司必须创建一份清单，盘点跨该组织各账户中存储在 Amazon S3 存储桶里的所有敏感数据。调查结果必须能从单一位置可见。
哪种解决方案将满足这些要求？

A. Set the security account as the delegated administrator for Amazon Macie and AWS Security Hub. Enable and configure Macie to publish sensitive data findings to Security Hub.

将安全账户设置为 Amazon Macie 和 AWS Security Hub 的委派管理员。启用并配置 Macie，将敏感数据调查结果发布到 Security Hub。

B. Set the security account as the delegated administrator for AWS Security Hub. In each account, configure Amazon Inspector to scan the S3 buckets for sensitive data. Publish sensitive data findings to Security Hub.

将安全账户设置为 AWS Security Hub 的委派管理员。在每个账户中，配置 Amazon Inspector 扫描 S3 存储桶以查找敏感数据。将敏感数据调查结果发布到 Security Hub。

C. In each account, configure Amazon Inspector to scan the S3 buckets for sensitive data. Enable Amazon Inspector integration with AWS Trusted Advisor. Publish sensitive data findings to Trusted Advisor.

在每个账户中，配置 Amazon Inspector 扫描 S3 存储桶以查找敏感数据。启用 Amazon Inspector 与 AWS Trusted Advisor 的集成。将敏感数据调查结果发布到 Trusted Advisor。

D. In each account, enable and configure Amazon Macie to detect sensitive data. Enable Macie integration with AWS Trusted Advisor. Publish sensitive data findings to Trusted Advisor.

在每个账户中，启用并配置 Amazon Macie 以检测敏感数据。启用 Macie 与 AWS Trusted Advisor 的集成。将敏感数据调查结果发布到 Trusted Advisor。

Correct Answer: A

正确答案: A

题目解析 (SCS-C03 做题教练)

1. 考察的知识点

Amazon Macie 的能力与适用场景：用于在 Amazon S3 中自动发现与分类敏感数据（PII、凭证、财务信息等）。

AWS Organizations 多账户集中管理：使用“委派管理员（Delegated administrator）”在单一安全账户集中启用/管理安全服务（如 Macie、Security Hub）。

集中可视化与汇总：将各账号/各区域的发现集中汇聚到单一位置（常见做法是 Security Hub 作为统一看板/汇总器）。

服务集成边界：Inspector vs Macie 的职责区别；Trusted Advisor 不作为敏感数据发现的集中汇总平台。

2. 独立思考（不参考官方答案）

需求是“跨组织所有账号的 S3 敏感数据清单”并且“从单一位置可见”。

能做 S3 敏感数据发现的核心服务是 **Amazon Macie**（而不是 Inspector）。

跨账号集中可见通常用 **Security Hub** 作为统一汇总/可视化入口；Macie 也支持组织级集中管理，但题目强调“findings must be visible from a single location”，Security Hub 很契合。

因此最合理方案是：**安全账户作为 Macie 委派管理员**，启用组织级 Macie；并将发现汇总到 **Security Hub** 以单点查看。

3. 逐个选项分析

A. 安全账户作为 Macie 和 Security Hub 委派管理员；Macie 发现发布到 Security Hub

正确点 1：Macie 专门用于 S3 敏感数据发现与分类，满足“inventory of all sensitive data stored in S3”。

正确点 2：在 AWS Organizations 中可设置 **Macie 委派管理员**，由安全账户集中管理与聚合成员账号（多环境、多账号隔离场景常用）。

正确点 3：Macie 可将 findings **集成/发送到 Security Hub**，Security Hub 提供跨账号的集中可视化（作为单一位置）。

结论：满足所有要求（跨组织 S3 敏感数据发现 + 单点可见）。

B. 安全账户作为 Security Hub 委派管理员；各账号用 Inspector 扫 S3 敏感数据并发布到 Security Hub

错误点 1（关键）：Amazon Inspector 的核心是漏洞管理（EC2、ECR、Lambda 等）与暴露性评估，并不用于 S3 敏感数据内容识别/分类。

正确但无效点：Security Hub 委派管理员与集中汇总是合理的，但前提是上游产生“敏感数据发现”的服务要正确。

结论：因为 Inspector 不符合“扫描 S3 桶内敏感数据”的能力边界，该方案不满足需求。

C. 各账号用 Inspector 扫 S3；与 Trusted Advisor 集成；发布到 Trusted Advisor

错误点 1：同 B，Inspector 不做 S3 敏感数据发现。

错误点 2：Trusted Advisor 不是用于集中接收“敏感数据发现（Findings）”的主要平台；其定位是最佳实践检查与建议（成本、性能、安全、容错、服务限制等），不是敏感数据清单汇总中心。

结论：不满足。

D. 各账号启用 Macie；与 Trusted Advisor 集成；发布到 Trusted Advisor

部分正确：Macie 能检测 S3 敏感数据。

错误点 1：题干强调组织内“单一位置可见”，更标准的集中方式是 **组织级 Macie（委派管理员）** 或汇聚到 **Security Hub**；该选项没有体现组织级集中管理手段。

错误点 2：“Macie findings 发布到 Trusted Advisor”不是常规/主流能力路径，Trusted Advisor 也不是用于展示 Macie 敏感数据发现的集中平台。

结论：不满足“单一位置可见”的合理实现方式与服务集成逻辑。

4. 我选择的答案

A

5. 官方答案

A

6. 与官方答案对比与复盘

对比结果：我的答案与官方答案一致（A）。

复盘要点：本题核心是区分 **Macie（S3 敏感数据发现）** 与 **Inspector（漏洞管理）** 的边界，并理解通过 **Organizations 委派管理员 + Security Hub 集中展示** 来满足“跨账号、单点可见”的要求。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #31

Topic 1

A company has hundreds of AWS accounts in an organization in AWS Organizations. The company operates out of a single AWS Region. The company has a dedicated security tooling AWS account in the organization. The security tooling account is configured as the organization's delegated administrator for Amazon GuardDuty and AWS Security Hub. The company has configured the environment to automatically enable GuardDuty and Security Hub for existing AWS accounts and new AWS accounts. The company is performing control tests on specific GuardDuty findings to make sure that the company's security team can detect and respond to security events. The security team launched an Amazon EC2 instance and attempted to run DNS requests against a test domain, example.com, to generate a DNS finding. However, the GuardDuty finding was never created in the Security Hub delegated administrator account.

Why was the finding was not created in the Security Hub delegated administrator account?

一家公司在 AWS Organizations 的一个组织中拥有数百个 AWS 账户。该公司仅在单个 AWS 区域开展运营。该公司在组织中有一个专用的安全工具 AWS 账户。该安全工具账户被配置为该组织的 Amazon GuardDuty 和 AWS Security Hub 的委派管理员。该公司已将环境配置为对现有 AWS 账户和新的 AWS 账户自动启用 GuardDuty 和 Security Hub。

该公司正在对特定的 GuardDuty 发现执行控制测试，以确保公司的安全团队能够检测并响应安全事件。安全团队启动了一台 Amazon EC2 实例，并尝试针对测试域名 example.com 运行 DNS 请求，以生成 DNS 相关的发现。然而，GuardDuty 的发现从未在 Security Hub 委派管理员账户中创建。

为什么该发现没有在 Security Hub 委派管理员账户中创建？

A. VPC flow logs were not turned on for the VPC where the EC2 instance was launched.

未启动 EC2 实例所在的 VPC 启用 VPC 流日志。

B. The VPC where the EC2 instance was launched had the DHCP option configured for a custom OpenDNS resolver.

启动 EC2 实例所在的 VPC 的 DHCP 选项被配置为自定义 OpenDNS 解析器。

C. The GuardDuty integration with Security Hub was never activated in the AWS account where the finding was generated.

在生成该发现的 AWS 账户中，从未激活 GuardDuty 与 Security Hub 的集成。

D. Cross-Region aggregation in Security Hub was not configured.

未配置 Security Hub 的跨区域聚合。

Correct Answer: B

正确答案: B

题目解析 (SCS-C03 做题教练)

1) 本题考察的知识点

GuardDuty 数据源与检测前提: GuardDuty 主要基于 CloudTrail 事件、VPC Flow Logs (由服务侧获取/管理的网络遥测)、以及 VPC 的 DNS 查询遥测 来做威胁检测。

GuardDuty DNS 相关发现的关键条件：实例发起的 DNS 查询如果**不经过 VPC 的 AmazonProvidedDNS (Route 53 Resolver)**，GuardDuty 可能无法获得所需的 DNS 遥测，从而无法产生相应的 DNS 类发现。

Security Hub 管理员聚合机制：在同一 Region 内，Security Hub 管理员账户可汇总成员账户的发现；跨区域聚合仅在多 Region 场景需要。

2) 独立思考（不参考官方答案）

题干强调公司只在**单一 Region**运营，因此“跨区域聚合未配置”不太可能是根因。

题干说“尝试通过对 example.com 发起 DNS 请求来生成 DNS finding”，但最终在 Security Hub 委派管理员账户里没看到 GuardDuty finding。

更根本的问题通常是：**GuardDuty 根本没生成该 DNS finding**（而不是生成了但没进入 Security Hub）。在 DNS 检测场景里，最常见导致“根本不产生 DNS 相关 finding”的原因之一就是：实例使用了**自定义 DNS 解析器**（不走 VPC 的默认解析链路）。

3) 逐个选项分析

A. 未启动 EC2 实例所在的 VPC 启用 VPC 流日志 结论：错误 原因：GuardDuty 不要求客户手动开启 VPC Flow Logs 才能进行网络相关检测。GuardDuty 使用其服务侧可获取的网络遥测来分析可疑流量；“没开 VPC Flow Logs”通常不会导致 GuardDuty 完全无法产生对应类型的 finding（更不特指 DNS finding）。

B. VPC 的 DHCP 选项配置为自定义 OpenDNS 解析器 结论：正确 原因：若通过 DHCP options set 将实例的 DNS 指向 OpenDNS/自建 DNS（而不是 AmazonProvidedDNS/Route 53 Resolver），实例的 DNS 查询将直接发往自定义解析器。GuardDuty 的 DNS 相关检测依赖于 VPC 内由 Route 53 Resolver 处理/可见的 DNS 查询遥测；当 DNS 查询不经过该路径时，GuardDuty 可能无法看到这些 DNS 查询，从而**不会生成对应的 DNS 类发现**，自然也就不会出现在 Security Hub 委派管理员账户中。

C. 在生成该发现的 AWS 账户中，从未激活 GuardDuty 与 Security Hub 的集成 结论：错误（本题语境下最不符合） 原因：若仅是“未集成”，通常表现为：**GuardDuty 控制台里能看到 finding**，但 Security Hub 看不到。题干的核心是“尝试生成 DNS finding，但 finding 从未创建到 Security Hub 委派管理员账户”。结合选项与场景，最合理解释是**根本没产生该 DNS finding**（数据源不可见），而不是“产生了但没转发/没集成”。此外，题干已说明组织层面自动启用 GuardDuty 与 Security Hub，并以委派管理员集中管理，更常见问题点在数据可见性（DNS 路径）而非基础启用/成员关系。

D. 未配置 Security Hub 的跨区域聚合 结论：错误 原因：题干明确公司只在**单一 AWS Region**运营。单 Region 场景下不需要跨区域聚合也能在委派管理员账户看到成员账户发现。跨区域聚合不配置不会解释“DNS finding 不产生/不可见”。

4) 我选择的答案

B

5) 官方答案

B

6) 与官方答案对比与复盘

对比结果：一致

复盘要点：本题关键不在 Security Hub 聚合或 VPC Flow Logs，而在于 **DNS 查询是否走 VPC 默认解析链路**

(AmazonProvidedDNS / Route 53 Resolver)。使用自定义 DNS（OpenDNS）会使 GuardDuty 的 DNS 遥测不可见，从而无法产生期望的 DNS 类 finding。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #32

Topic 1

A security engineer discovers that a company's user passwords have no required minimum length. The company is using the following two identity providers (IdPs):

AWS Identity and Access Management (IAM) federated with on-premises Active Directory

Amazon Cognito user pools that contain the user database for an AWS Cloud application that the company developed

Which combination of actions should the security engineer take to implement a required minimum length for the passwords? (Choose two.)

一名安全工程师发现，公司用户密码没有要求的最小长度。公司正在使用以下两个身份提供商（IdP）：

与本地 Active Directory 联合的 AWS Identity and Access Management (IAM)

Amazon Cognito 用户池，其中包含该公司为某个 AWS 云应用程序开发的数据库

安全工程师应采取哪组操作来为密码实施要求的最小长度？（选择两个。）

A. Update the password length policy in the IAM configuration.

在 IAM 配置中更新密码长度策略。

B. Update the password length policy in the Cognito configuration.

在 Cognito 配置中更新密码长度策略。

C. Update the password length policy in the on-premises Active Directory configuration

在本地 Active Directory 配置中更新密码长度策略

D. Create an SCP in AWS Organizations. Configure the SCP to enforce a minimum password length for IAM and Cognito.

在 AWS Organizations 中创建一个 SCP。配置该 SCP 以强制为 IAM 和 Cognito 设定最小密码长度。

E. Create an IAM policy that includes a condition for minimum password length. Enforce the policy for IAM and Cognito.

创建一个包含最小密码长度条件的 IAM 策略。对 IAM 和 Cognito 强制执行该策略。

Correct Answer: BC

正确答案: BC

题目解析：为多身份源实施密码最小长度（选择两项）

1. 考察的知识点是什么？

密码策略的作用域边界：不同身份提供商（IdP）各自管理各自的用户凭据与密码策略。

IAM Password Policy 的适用对象：仅适用于 IAM Users（本地 IAM 用户），不适用于通过联合登录（Federation）的外部目录用户。

AD 联合登录（Federated with on-premises AD）：用户密码存储在本地 Active Directory，密码最小长度应在 AD 侧设置。

Amazon Cognito User Pool：用户密码存储在 Cognito user pool 中，密码复杂度/最小长度在 User Pool 的密码策略中设置。

SCP/IAM Policy 的能力边界：SCP和IAM策略用于权限控制，不能直接“强制”某个服务的密码长度策略（尤其跨Cognito/AD）。

2. 独立思考（不参考官方答案）

本题有两个IdP：**IAM+AD联合**、**Cognito User Pool**。

要实现“密码最小长度”，应分别在**实际存储与验证密码的系统**中配置：

联合到IAM的AD用户：密码策略在**本地Active Directory**里。

Cognito User Pool用户：密码策略在**Cognito User Pool**里。

3. 逐个分析每个选项为什么正确或错误

A. Update the password length policy in the IAM configuration. 错误。 IAM账号密码策略（Account password policy）只影响**IAM本地用户**的控制台密码，不会影响**通过AD联合登录的用户**（他们用的是AD密码）。题目并未描述公司使用IAM本地用户数据库作为主要IdP，而是“IAM federated with on-premises AD”。因此仅改IAM不解决根因。

B. Update the password length policy in the Cognito configuration. 正确。 Cognito User Pools存储并验证其用户密码。要对该应用用户实施最小长度，应在**User Pool Password policy**中配置最小长度要求。

C. Update the password length policy in the on-premises Active Directory configuration. 正确。 既然IAM是与本地AD联合，用户密码由AD管理。最小密码长度必须在AD的**Domain Password Policy/FGPP**中设置，才能约束这些联合用户的密码。

D. Create an SCP in AWS Organizations. Configure the SCP to enforce a minimum password length for IAM and Cognito. 错误。 SCP用于限制账户内可调用的AWS API（权限护栏），并不能直接对**AD密码策略**或**Cognito密码策略**施加“密码长度”强制要求。即使能限制某些API调用，也不是实施密码最小长度的正确机制。

E. Create an IAM policy that includes a condition for minimum password length. Enforce the policy for IAM and Cognito. 错误。 IAM策略条件不用于对“用户密码长度”做约束；IAM策略控制的是对AWS资源/API的访问授权，不是密码复杂度策略引擎。并且更无法对Cognito User Pool或本地AD的密码策略产生直接效果。

4. 我选择的答案

B + C

5. 官方答案

B + C

6. 与官方答案比较与复盘

我的答案与官方答案一致（BC）。

原因：两个用户群分别由不同IdP管理密码，必须在**Cognito User Pool**与**本地AD**各自配置密码最小长度策略；IAM密码策略不覆盖联合用户。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #33

Topic 1

A company has a web-based application that runs behind an Application Load Balancer (ALB). The application is experiencing a credential stuffing attack that is producing many failed login attempts. The attack is coming from many IP addresses. The login attempts are using a user agent string of a known mobile device emulator.

A security engineer needs to implement a solution to mitigate the credential stuffing attack. The solution must still allow legitimate logins to the application.

Which solution will meet these requirements?

一家公司的 Web 应用程序运行在 Application Load Balancer (ALB) 之后。该应用程序正在遭受凭证填充攻击, 导致大量登录失败尝试。攻击来自许多 IP 地址。登录尝试使用已知移动设备模拟器的用户代理字符串。

安全工程师需要实施一个解决方案来缓解凭证填充攻击。该解决方案仍必须允许对应用程序的合法登录。

哪种解决方案将满足这些要求?

A. Create an Amazon CloudWatch alarm that reacts to login attempts that contain the specified user agent string Add an Amazon Simple Notification Service (Amazon SNS) topic to the alarm.

创建一个 Amazon CloudWatch 告警, 用于对包含指定用户代理字符串的登录尝试做出反应。向该告警添加一个 Amazon Simple Notification Service (Amazon SNS) 主题。

B. Modify the inbound security group on the ALB to deny traffic from the IP addresses that are involved in the attack. 修改 ALB 上的入站安全组, 以拒绝来自参与攻击的 IP 地址的流量。

C. Create an AWS WAF web ACL for the ALB Create a custom rule that blocks requests that contain the user agent string of the device emulator.

为 ALB 创建一个 AWS WAF Web ACL。创建一个自定义规则来阻止包含该设备模拟器用户代理字符串的请求。

D. Create an AWS WAF web ACL for the ALB. Create a custom rule that allows requests from legitimate user agent strings.

为 ALB 创建一个 AWS WAF Web ACL。创建一个自定义规则来允许来自合法用户代理字符串的请求。

Correct Answer: C

正确答案: C

题目解析 (SCS-C03 做题教练)

1. 考察的知识点

AWS WAF 与 ALB 集成: 通过 Web ACL 在第7层 (HTTP) 基于请求特征进行拦截。

凭证填充 (Credential Stuffing) 缓解思路: 攻击来自大量 IP, 传统按 IP 封禁效果差; 更适合用应用层特征 (如 User-Agent、URI、Header、行为) 做拦截/挑战。

安全控制的“可用性”要求: 需要在阻断攻击的同时尽量不影响合法登录 (避免过度封禁)。

2. 独立思考 (不参考官方答案)

题干明确给出攻击特征：**来自很多 IP**（IP 封禁不优）且使用**已知移动设备模拟器的 User-Agent**（可作为检测/拦截信号）。

要求：**缓解攻击且仍允许合法登录**。最直接可行的是在 ALB 前使用 **AWS WAF** 对携带该已知恶意 UA 的请求进行阻断，从而最大程度保留其它正常 UA 的登录。

3. 逐个选项分析

A. CloudWatch Alarm + SNS 错误。 原因：

CloudWatch 告警 + SNS 只负责**告警/通知**，不直接对 Web 请求进行实时阻断。

即使触发告警，也缺少自动化缓解动作（题目未提供联动 Lambda/SSM/防火墙更新等），无法满足“mitigate attack”。

对正在发生的凭证填充攻击来说，告警属于检测而非防护。

B. 修改 ALB Security Group 封禁攻击 IP 错误。 原因：

题干强调攻击来自**很多 IP 地址**，用安全组逐个封禁不可扩展，且安全组规则数有限、运维成本高。

安全组在 L3/L4 层工作，无法基于**User-Agent**等 L7 特征识别。

攻击 IP 可能不断变化（Botnet），封禁会滞后且容易误伤。

C. 为 ALB 创建 AWS WAF Web ACL，自定义规则阻止包含该模拟器 User-Agent 的请求 正确。 原因：

AWS WAF 可直接挂载到 ALB，对 HTTP Header（包括 **User-Agent**）做匹配并执行 **Block** 动作。

攻击特征明确且稳定（已知模拟器 UA），用“Header match”拦截能够在不依赖 IP 的情况下削弱大规模分布式尝试。

默认只拦截带有该 UA 的请求，其它请求仍可访问登录页面，从而**仍允许合法登录**（至少在题目给定条件下）。

这是题目选项中唯一一个既能实时缓解、又能按 L7 特征精准拦截的方案。

注意：

User-Agent 可被伪造，但在本题给定信息里，“攻击使用已知模拟器 UA”意味着该信号足以作为当前缓解手段。

D. 为 ALB 创建 AWS WAF Web ACL，自定义规则只允许合法 User-Agent 错误（相对不满足“仍允许合法登录”的稳定性要求）。

原因：

“允许合法 User-Agent”实质是**UA 白名单**：真实用户的浏览器/设备 UA 多样且会变化（版本更新、不同浏览器、企业代理改写等），很容易造成大量误封，影响合法登录。

题干只提供“恶意 UA 已知”，并未给出“合法 UA 可枚举且稳定”的前提，因此白名单策略风险极高。

攻击者也可切换/伪造 UA，白名单未必能长期有效，且维护成本更高。

4. 我选择的答案

C

5. 官方答案

C

6. 与官方答案对比与复盘

我的答案：**C**；官方答案：**C**；**一致**。

复盘要点：

攻击来自很多 IP → 不适合用 Security Group 做 IP 封禁（B）。

需要“立刻缓解”而非仅告警（A）。

已知恶意 UA → WAF 基于 Header 精准拦截（C）。

UA 白名单（D）误伤风险大，不符合“仍允许合法登录”的稳健性要求。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #34

Topic 1

A company is operating an open-source software platform that is internet facing. The legacy software platform no longer receives security updates. The software platform operates using Amazon Route 53 weighted load balancing to send traffic to two Amazon EC2 instances that connect to an Amazon RDS cluster. A recent report suggests this software platform is vulnerable to SQL injection attacks, with samples of attacks provided. The company's security engineer must secure this system against SQL injection attacks within 24 hours. The security engineer's solution must involve the least amount of effort and maintain normal operations during implementation.

What should the security engineer do to meet these requirements?

一家公司正在运营一个面向互联网的开源软件平台。该遗留软件平台不再接收安全更新。该软件平台使用 Amazon Route 53 加权负载均衡将流量发送到两台连接到一个 Amazon RDS 集群的 Amazon EC2 实例。最近的一份报告表明该软件平台存在 SQL 注入攻击漏洞，并提供了攻击样本。公司的安全工程师必须在 24 小时内保护该系统免受 SQL 注入攻击。安全工程师的解决方案必须投入最少的工作量，并在实施期间保持正常运行。

安全工程师应如何做才能满足这些要求？

A. Create an Application Load Balancer with the existing EC2 instances as a target group. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the ALB. Test to ensure the vulnerability has been mitigated, then redirect the Route 53 records to point to the ALB. Update security groups on the EC2 instances to prevent direct access from the internet.

创建一个 Application Load Balancer，并将现有的 EC2 实例作为目标组。创建一个包含可保护应用免受此类攻击的规则 AWS WAF Web ACL，然后将其应用到该 ALB。进行测试以确保漏洞已得到缓解，然后将 Route 53 记录重定向为指向该 ALB。更新 EC2 实例上的安全组，以防止来自互联网的直接访问。

B. Create an Amazon CloudFront distribution specifying one EC2 instance as an origin. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the distribution. Test to ensure the vulnerability has been mitigated, then redirect the Route 53 records to point to CloudFront.

创建一个 Amazon CloudFront 分发，并指定一个 EC2 实例作为源站。创建一个包含可保护应用免受此类攻击的规则 AWS WAF Web ACL，然后将其应用到该分发。进行测试以确保漏洞已得到缓解，然后将 Route 53 记录重定向为指向 CloudFront。

C. Obtain the latest source code for the platform and make the necessary updates. Test the updated code to ensure that the vulnerability has been mitigated, then deploy the patched version of the platform to the EC2 instances.

获取该平台的最新源代码并进行必要的更新。测试更新后的代码以确保漏洞已得到缓解，然后将打过补丁的平台版本部署到 EC2 实例上。

D. Update the security group that is attached to the EC2 instances, removing access from the internet to the TCP port used by the SQL database. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the EC2 instances. Test to ensure the vulnerability has been mitigated, then restore the security group to the original setting. 更新附加到 EC2 实例的安全组，移除从互联网到 SQL 数据库所使用的 TCP 端口的访问。创建一个包含可保护应用免受此类攻击的规则 AWS WAF Web ACL，然后将其应用到 EC2 实例。进行测试以确保漏洞已得到缓解，然后将安全组恢复为原始设置。

Correct Answer: A

正确答案：A

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

SQL Injection (SQL 注入) 属于应用层 (L7) 攻击，通常需要在 HTTP/HTTPS 请求层做检测与拦截。

AWS WAF 的可挂载资源：Application Load Balancer(ALB)、Amazon CloudFront、Amazon API Gateway、AWS AppSync 等；**不能直接挂到 EC2 实例或安全组上**。

在 24 小时内、最少工作量、不中断业务的应急防护思路：在入口处加“可快速上线”的托管防护层（如 WAF）并逐步切流（Route 53/负载均衡）。

Route 53 Weighted Routing 的用途：可以平滑引入新入口（例如从“直连 EC2”逐步切换到“经 ALB/WAF”）。

2. 独立思考（不参考官方答案）

目标是**立刻降低 SQL 注入风险**，而不是长期修复代码（虽然长期应修复）。

最快且最标准的 AWS 做法是在流量入口加 **AWS WAF**，并配合托管规则（AWS Managed Rules）或自定义规则快速拦截已知 payload。

由于当前是 Route 53 直接把流量打到两台 EC2（加权），要想接入 WAF，必须引入**WAF 支持的入口**（ALB 或 CloudFront）。同时为避免绕过 WAF 直连实例，应将 EC2 安全组限制为只允许来自 ALB（或 CloudFront/边缘回源 IP 段，但更复杂）。

3. 逐个选项分析

A 选项分析

正确点 1：创建 ALB 并将现有 EC2 作为 Target Group，属于最常见、最快落地的架构改造。

正确点 2：在 ALB 上关联 AWS WAF Web ACL，可以快速部署托管规则（如 SQLi 相关托管规则）或基于样本攻击创建自定义规则进行拦截。

正确点 3：测试后再把 Route 53 记录切到 ALB，可逐步切流/快速回滚，满足“维护正常运行”。

正确点 4：更新 EC2 安全组阻止公网直连，强制所有流量必须经过 ALB/WAF，避免绕过防护。

注意：本方案主要是“应急防护”，并不等同于根治漏洞（根治仍需修代码/参数化查询等），但满足题目 24 小时与最少工作量要求。

结论：满足“最快、最少工作量、不中断”三要素，整体最优。

B 选项分析

部分正确点：CloudFront 也可绑定 AWS WAF，能在边缘拦截恶意请求。

关键问题 1：选项写的是“指定一个 EC2 实例作为源站”，这会**破坏现有两台 EC2 的加权/双实例承载**，不符合“maintain normal operations（维持正常运行）”。

关键问题 2：即便可做多源站/Origin Group，也需要额外配置健康检查、回源策略等，通常比“ALB + Target Group”更繁琐，且题干并未描述这些配置。

关键问题 3：CloudFront 回源到“公网 EC2”时，如何彻底避免绕过 WAF 直连 EC2 更麻烦（需限制仅允许 CloudFront 回源 IP 段/使用 ALB 或自定义鉴权头等）。而 A 里用安全组只允许 ALB SG 是最简洁的做法。

结论：可以做但不符合题干“最少工作量 + 维持正常运行”的表达，且选项描述本身导致单点。

C 选项分析

问题 1：题干明确“legacy 软件平台不再接收安全更新”，而“获取最新源码并更新”在现实中通常需要较长开发/测试周期，且可能涉及依赖、兼容性、回归测试。

问题 2：不满足“24 小时内”和“最少工作量”的应急要求。

结论：长期正确方向（修复漏洞根因），但不符合题目约束。

D 选项分析

错误点 1：“从互联网移除到 SQL 数据库端口的访问”与 SQL 注入本质不匹配。SQL 注入是通过 Web 请求让应用去执行恶意 SQL，而不是直接从互联网连数据库端口。

错误点 2：在合理架构中，RDS 通常不应暴露到公网；并且题干说的是 EC2 连接 RDS cluster，并未表示数据库端口对公网开放。

错误点 3 (致命)： AWS WAF **不能“应用到 EC2 实例”**。WAF 必须关联到 ALB/CloudFront/API Gateway 等受支持资源。

结论： 方案描述在技术上不成立，且防护方向也不正确。

4. 我选择的答案

答案：A

5. 官方答案

官方答案：A

6. 与官方答案对比与复盘

对比结果： 我的答案与官方答案一致，均为 **A**。

复盘原因： A 是唯一同时满足以下条件的选项：

能在 24 小时内快速上线（WAF 托管规则 + ALB 目标组复用现有 EC2）。

最少改造且易于验证与回滚（Route 53 切到 ALB）。

维持正常运行并避免绕过（安全组仅允许 ALB 访问 EC2）。

技术上正确（WAF 可绑定 ALB；WAF 不能绑定 EC2）。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #35

Topic 1

A security engineer recently rotated the host keys for an Amazon EC2 instance. The security engineer is trying to access the EC2 instance by using the EC2 Instance Connect feature. However, the security engineer receives an error for failed host key validation. Before the rotation of the host keys, EC2 Instance Connect worked correctly with this EC2 instance. What should the security engineer do to resolve this error?

一名安全工程师最近轮换了一个 Amazon EC2 实例的主机密钥。该安全工程师正尝试使用 EC2 Instance Connect 功能访问该 EC2 实例。然而，该安全工程师收到主机密钥验证失败的错误。在轮换主机密钥之前，EC2 Instance Connect 与该 EC2 实例配合使用正常。安全工程师应该做什么来解决此错误？

- A. Import the key material into AWS Key Management Service (AWS KMS).
将密钥材料导入 AWS Key Management Service (AWS KMS).
- B. Manually upload the new host key to the AWS trusted host keys database
将新的主机密钥手动上传到 AWS 受信任主机密钥数据库
- C. Ensure that the AmazonSSMManagedInstanceCore policy is attached to the EC2 instance profile.
确保 AmazonSSMManagedInstanceCore 策略已附加到 EC2 实例配置文件。
- D. Create a new SSH key pair for the EC2 instance.
为 EC2 实例创建一个新的 SSH 密钥对。

Correct Answer: B

正确答案: B

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点是什么？

EC2 Instance Connect (EIC) 的SSH连接机制： EIC不仅涉及“用户SSH公钥”的临时注入，还可能涉及**SSH Host Key (主机密钥)**验证。

Host Key Rotation (主机密钥轮换) 后的影响： 当实例上的SSH Host Key变更后，若客户端/服务端仍在旧的可信主机密钥记录，会触发**host key validation failed**。

AWS Trusted Host Keys (AWS受信任主机密钥数据库)： 用于让EIC (或相关机制) 验证目标实例的Host Key是否可信；轮换后需要更新。

2. 独立思考 (不参考官方答案)

报错是**failed host key validation**，而且“轮换前正常，轮换后失败”。这强烈指向：**实例的SSH Host Key发生变化，但可信的Host Key记录没有同步更新。**

因此应采取的动作应该是：将新的Host Key更新到用于校验的可信数据库/来源，否则验证必然失败。

3. 逐个分析每个选项为什么正确或错误

A. Import the key material into AWS KMS 错误。 KMS用于加密密钥（对称/非对称）管理、信封加密、签名等，不用于存储/分发/校验SSH Host Key。本题问题是SSH主机密钥校验失败，不是数据加密或KMS密钥材料问题。

B. Manually upload the new host key to the AWS trusted host keys database 正确。 Host Key轮换后，EIC在进行主机身份校验时仍然对照旧的可信Host Key，自然会失败。将新的Host Key上传/更新到AWS受信任主机密钥数据库，使校验与实例当前Host Key一致，即可恢复连接。

C. Ensure that the AmazonSSMManagedInstanceCore policy is attached to the EC2 instance profile 错误。 该策略用于AWS Systems Manager (SSM) 让实例托管、Run Command、Session Manager等能力。本题明确使用的是EC2 Instance Connect且错误是host key validation，与SSM实例权限无直接对应关系；即使加了该策略也不会修复SSH Host Key验证不匹配的问题。

D. Create a new SSH key pair for the EC2 instance 错误。 这里混淆了用户登录用的SSH Key Pair (authorized_keys) 与服务器端SSH Host Key (sshd host keys)。报错是host key validation failed，说明是“服务器身份密钥”不匹配，而不是用户认证密钥对需要更新。新建登录SSH key pair无法解决“主机密钥校验失败”的根因。

4. 我选择的答案

B：手动将新的主机密钥上传到AWS受信任主机密钥数据库。

5. 官方的答案

B

6. 与官方答案对比与复盘

对比结果：一致（我选B，官方也选B）。

原因：题干关键线索是“轮换host keys后出现failed host key validation”，典型修复动作就是更新可信主机密钥记录以匹配当前实例Host Key。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #36

Topic 1

A security engineer needs to implement a solution to identify any sensitive data that is stored in an Amazon S3 bucket. The solution must report on sensitive data in the S3 bucket by using an existing Amazon Simple Notification Service (Amazon SNS) topic.

Which solution will meet these requirements with the LEAST implementation effort?

一名安全工程师需要实施一个解决方案，用于识别存储在 Amazon S3 存储桶中的任何敏感数据。该解决方案必须使用现有的 Amazon Simple Notification Service (Amazon SNS) 主题，对 S3 存储桶中的敏感数据进行报告。

哪种解决方案能够以最少的实施工作量满足这些要求？

A. Enable AWS Config. Configure AWS Config to monitor for sensitive data in the S3 bucket and to send notifications to the SNS topic.

启用 AWS Config。配置 AWS Config 以监控 S3 存储桶中的敏感数据，并将通知发送到 SNS 主题。

B. Create an AWS Lambda function to scan the S3 bucket for sensitive data that matches a pattern. Program the Lambda function to send notifications to the SNS topic.

创建一个 AWS Lambda 函数，用于扫描 S3 存储桶中与某种模式匹配的敏感数据。对该 Lambda 函数进行编程，使其将通知发送到 SNS 主题。

C. Configure Amazon Macie to use managed data identifiers to identify and categorize sensitive data. Create an Amazon EventBridge rule to send notifications to the SNS topic.

配置 Amazon Macie 使用托管数据标识符来识别并分类敏感数据。创建一条 Amazon EventBridge 规则，将通知发送到 SNS 主题。

D. Enable Amazon GuardDuty. Configure AWS CloudTrail S3 data events. Create an Amazon CloudWatch alarm that reacts to GuardDuty findings and sends notifications to the SNS topic.

启用 Amazon GuardDuty。配置 AWS CloudTrail S3 数据事件。创建一个 Amazon CloudWatch 告警，使其对 GuardDuty 发现结果作出响应并将通知发送到 SNS 主题。

Correct Answer: C

正确答案: C

题目解析：在S3中识别敏感数据并通过现有SNS主题告警（最少实现工作量）

1. 考察的知识点是什么？

Amazon Macie 的核心能力：对 Amazon S3 中对象内容进行自动化/按需敏感数据发现与分类（PII、凭证、金融数据等），使用 **Managed Data Identifiers** 或自定义标识符。

Macie Findings (发现) 的事件投递与通知：通过 **Amazon EventBridge** 规则将发现结果路由到 **Amazon SNS** 等目标。

对比其他安全服务的边界：

AWS Config: 偏向配置合规与资源变更, 不做对象内容级敏感数据识别。

GuardDuty: 偏向威胁检测 (恶意行为/异常访问), 不做敏感数据内容识别。

Lambda自建扫描: 可行但实现与运维成本更高, 不满足“最少实现工作量”。

2. 独立思考 (不参考官方答案)

需求是“识别S3桶里存储的敏感数据 (内容级别) 并通过已有SNS topic上报”, 且要求“最少实现工作量”。

在AWS托管服务中, 直接用于S3敏感数据发现/分类的是 **Amazon Macie**; 它原生产出 Findings, 并可通过 **EventBridge** 转发到 SNS。

因此最佳方案应是: **Macie + EventBridge + SNS**。

3. 逐个分析每个选项为什么正确或错误

A. Enable AWS Config...监控S3桶中的敏感数据

错误点: AWS Config 主要评估资源配置是否符合规则 (如桶是否公开、加密是否开启、策略是否合规等), 并不扫描对象内容来识别“敏感数据”。

即使能发SNS通知, 也无法满足“识别敏感数据存储在S3桶中”的核心要求 (内容检查能力缺失)。

B. Lambda扫描S3并匹配模式, 发送SNS

部分可行: 自定义代码确实可以读取对象并做正则/模式匹配, 然后发SNS。

但不满足“最少实现工作量”: 需要自行处理权限、遍历策略、增量扫描、并发与超时、成本控制、对象大小限制、压缩/编码格式、误报漏报、以及持续运维。

相对托管方案 (Macie) 实现工作量明显更大。

C. 配置Amazon Macie使用托管数据标识符, EventBridge规则发送到SNS

正确: Macie 是AWS用于 **S3敏感数据发现与分类** 的托管服务, 支持 **managed data identifiers** 自动识别多种敏感数据类型。

满足通知要求: Macie 产生 Findings, 可通过 **EventBridge** 规则筛选并将事件投递到现有 **SNS topic**。

最少实现工作量: 无需自建扫描引擎与规则体系, 主要是启用Macie、创建/配置分类作业 (或自动发现)、再用EventBridge路由即可。

D. GuardDuty + CloudTrail S3 data events + CloudWatch告警 + SNS

错误点: GuardDuty 关注威胁检测 (异常API调用、可疑IP、恶意行为等)。即便开启 CloudTrail S3 data events, GuardDuty 的发现侧重访问与行为异常, 不会对对象内容做敏感数据识别与分类。

该方案能告警“可疑访问/数据外泄风险行为”, 但不能回答“桶里有哪些敏感数据”。

实现链路也更复杂 (CloudTrail数据事件成本与配置、告警条件等), 且方向不匹配。

4. 我选择的答案

C

5. 官方答案

C

6. 与官方答案对比与复盘

对比结果: 我的答案 = 官方答案 = C

原因确认: 只有 Amazon Macie 提供面向 S3 对象内容的托管敏感数据发现/分类能力, 并能以最小工作量通过 EventBridge 将 Findings 路由到现有 SNS 主题; 其他选项要么不具备内容识别能力 (Config/GuardDuty), 要么实现与运维成本更高 (Lambda自建扫描)。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #37

Topic 1

A company has a platform that is divided into 12 AWS accounts under the same organization in AWS Organizations. Many of these accounts use Amazon API Gateway to expose APIs to the company's frontend applications. The company needs to protect the existing APIs and any resources that will be deployed in the future against common SQL injection and bot attacks. Which solution will meet these requirements with the LEAST operational overhead?

一家公司的平台在 AWS Organizations 中的同一组织下划分为 12 个 AWS 账户。许多账户使用 Amazon API Gateway 向公司的前端应用程序公开 API。公司需要保护现有的 API 以及未来将要部署的任何资源，以防常见的 SQL 注入和机器人 (bot) 攻击。哪种解决方案能够以最少的运维开销满足这些要求？

A. Create an AWS WAF web ACL for each API. Include managed rules to block SQL injection and bot attacks. Use AWS Config to detect new resources that do not have a web ACL. Configure a remediation action to provision a web ACL for these resources.

为每个 API 创建一个 AWS WAF Web ACL。包含用于阻止 SQL 注入和机器人攻击的托管规则。使用 AWS Config 检测没有 Web ACL 的新资源。配置一个补救操作为这些资源预置一个 Web ACL。

B. Use AWS Firewall Manager to create an AWS WAF policy. Configure the policy to include the AWS Bot Control and SQL database managed rule groups. Set the policy scope to include the API Gateway stage as the resource type.

使用 AWS Firewall Manager 创建一个 AWS WAF 策略。将该策略配置为包含 AWS Bot Control 和 SQL 数据库托管规则组。将策略范围设置为包含 API Gateway stage 作为资源类型。

C. Create an AWS Service Catalog product for an AWS WAF web ACL that includes rules to block SQL injection and bot attacks. Use AWS Config to detect new resources that do not have this product applied. Configure a remediation action to provision a web ACL for these resources.

为包含用于阻止 SQL 注入和机器人攻击规则的 AWS WAF Web ACL 创建一个 AWS Service Catalog 产品。使用 AWS Config 检测未应用此产品的新资源。配置一个补救操作为这些资源预置一个 Web ACL。

D. Use AWS Security Hub to detect unprotected resources and to send the findings as custom action events to Amazon EventBridge. Create an AWS Lambda function for these events to provision an AWS WAF web ACL for the unprotected resources. Include managed rules to block SQL injection and bot attacks.

使用 AWS Security Hub 检测未受保护的资源，并将发现项作为自定义操作事件发送到 Amazon EventBridge。为这些事件创建一个 AWS Lambda 函数，为未受保护的资源预置一个 AWS WAF Web ACL。包含用于阻止 SQL 注入和机器人攻击的托管规则。

Correct Answer: B

正确答案: B

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

AWS WAF (WAFv2) 对 API Gateway (REST API/HTTP API) 的保护与关联方式 (以 **API Gateway stage** 作为受保护资源类型)。**AWS Firewall Manager** 在 AWS Organizations 多账号环境中, 集中式下发与强制执行 WAF 策略 (含自动应用到新资源) 的能力。使用 **AWS Managed Rules** (SQLi 规则组) 与 **AWS Bot Control** 进行常见攻击防护。
“**Least operational overhead** (最低运维开销)”在多账号、持续新增资源场景下通常对应: 集中策略、自动覆盖、最少自定义代码与最少逐资源配置。

2. 独立思考 (不参考官方答案)

题目关键: 12 个账号、同一 Organizations; 很多账号都用 API Gateway; 不仅要保护现有 API, 还要保护未来新增资源; 要防 SQL 注入与 Bot; 并且要求最低运维开销。

在多账号集中治理 WAF 并自动覆盖新增资源的最佳实践是 **AWS Firewall Manager + AWS WAF Policy**, 可跨账号统一下发, 并可自动对范围内新建的 API Gateway stage 应用策略, 运维开销最低。

3. 逐个选项分析

A 选项: 为每个 API 单独建 Web ACL + Config 检测与补救

优点: 能实现“发现未关联 WAF 的新资源并自动补救”。

问题: 1) 每个 API/账号都要单独维护 Web ACL (或至少是大量重复配置), 策略一致性与版本管理成本高; 2) 依赖 AWS Config 规则 + Remediation (通常还要 SSM Automation/Lambda 等) 来做“关联 WAF”, 实现链路更复杂; 3) 相比 Firewall Manager 的“原生集中策略下发 + 自动应用”, 运维开销更大。

结论: 功能可做, 但不满足“最低运维开销”的最优解。

B 选项: 用 Firewall Manager 创建 WAF policy, 包含 Bot Control 与 SQLi 托管规则组, 范围为 API Gateway stage

优点: 1) **多账号集中治理:** Firewall Manager 专为 Organizations 多账号统一管理安全策略设计; 2) **自动覆盖未来资源:** 可对策略范围内新创建的 API Gateway stage 自动应用 WAF; 3) **最低运维开销:** 不需要为每个 API/账号单独建/绑 Web ACL, 不需要自定义补救流程; 4) 直接使用 **AWS Managed Rules** (SQLi) 与 **AWS Bot Control** 满足防护要求。

注意点: Bot Control 是付费能力; SQL 注入规则通常对应 AWSManagedRulesSQLiRuleSet (题干“SQL database managed rule groups”措辞不严谨, 但意图明确为 SQLi 托管规则组)。

结论: 最符合需求且运维最省。

C 选项: Service Catalog 产品化 WAF Web ACL + Config 检测与补救

优点: 通过产品化模板可一定程度统一 Web ACL 配置。

问题: 1) 仍需要“检测未应用产品 + 自动补救”的机制, 链路复杂 (Config + remediation + 供应流程); 2) Service Catalog 更偏“标准化资源交付”, 不如 Firewall Manager 原生适配“跨账号强制与自动附加策略”; 3) 运维开销仍高于 Firewall Manager。

结论: 可行但不是最低运维开销。

D 选项: Security Hub 发现未保护资源 + EventBridge + Lambda 自动创建/关联 WAF

优点: 可实现自动化补救。

问题: 1) 需要自定义代码 (Lambda) 与事件编排; 2) Security Hub 的“发现未受保护资源”需要依赖检查项/标准与资源覆盖, 未必天然精准覆盖“所有 API Gateway stage 未关联 WAF”的场景; 3) 自建自动化链路运维成本最高 (版本、权限、错误处理、幂等、回滚等)。

结论: 不满足“最低运维开销”。

4. 我选择的答案

B

5. 官方答案

B

6. 与官方答案对比与复盘

对比结果: 我的答案与官方答案一致 (均为 B)。

复盘原因: 本题核心是 Organizations 多账号下对 API Gateway 进行 WAF 防护, 并自动覆盖未来资源; Firewall Manager 提供集中策略、自动应用与合规强制能力, 显著低于逐资源配置或自建检测/补救流水线的运维开销。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #38

Topic 1

A company is implementing a new application in a new AWS account. A VPC and subnets have been created for the application. The application has been peered to an existing VPC in another account in the same AWS Region for database access. Amazon EC2 instances will regularly be created and terminated in the application VPC, but only some of them will need access to the databases in the peered VPC over TCP port 1521. A security engineer must ensure that only the EC2 instances that need access to the databases can access them through the network.

How can the security engineer implement this solution?

一家公司正在一个新的 AWS 账户中实施一个新应用程序。已经为该应用程序创建了一个 VPC 和子网。该应用程序已与同一 AWS 区域中另一个账户内的现有 VPC 建立了对等连接，以便访问数据库。Amazon EC2 实例将会在应用程序 VPC 中定期创建和终止，但只有其中一部分需要通过 TCP 端口 1521 访问对等 VPC 中的数据库。一名安全工程师必须确保只有需要访问数据库的 EC2 实例才能通过网络访问这些数据库。

安全工程师如何实现该解决方案？

A. Create a new security group in the database VPC and create an inbound rule that allows all traffic from the IP address range of the application VPC. Add a new network ACL rule on the database subnets. Configure the rule to TCP port 1521 from the IP address range of the application VPC. Attach the new security group to the database instances that the application instances need to access.

在数据库 VPC 中创建一个新的安全组，并创建一条入站规则，允许来自应用程序 VPC 的 IP 地址范围的所有流量。在数据库子网上添加一条新的网络 ACL 规则。将该规则配置为允许来自应用程序 VPC 的 IP 地址范围、目标为 TCP 端口 1521 的流量。将新的安全组关联到应用程序实例需要访问的数据库实例上。

B. Create a new security group in the application VPC with an inbound rule that allows the IP address range of the database VPC over TCP port 1521. Create a new security group in the database VPC with an inbound rule that allows the IP address range of the application VPC over port 1521. Attach the new security group to the database instances and the application instances that need database access.

在应用程序 VPC 中创建一个新的安全组，并添加一条入站规则，允许来自数据库 VPC 的 IP 地址范围、通过 TCP 端口 1521 的流量。在数据库 VPC 中创建一个新的安全组，并添加一条入站规则，允许来自应用程序 VPC 的 IP 地址范围、通过端口 1521 的流量。将新的安全组关联到数据库实例以及需要数据库访问的应用程序实例上。

C. Create a new security group in the application VPC with no inbound rules. Create a new security group in the database VPC with an inbound rule that allows TCP port 1521 from the new application security group in the application VPC. Attach the application security group to the application instances that need database access and attach the database security group to the database instances.

在应用程序 VPC 中创建一个没有任何入站规则的新安全组。在数据库 VPC 中创建一个新的安全组，并添加一条入站规则，允许来自应用程序 VPC 中新建的应用程序安全组、目标为 TCP 端口 1521 的流量。将应用程序安全组关联到需要数据库访问的应用程序实例上，并将数据库安全组关联到数据库实例上。

D. Create a new security group in the application VPC with an inbound rule that allows the IP address range of the database VPC over TCP port 1521. Add a new network ACL rule on the database subnets. Configure the rule to allow all traffic from the IP address range of the application VPC. Attach the new security group to the application instances that need database access. 在应用程序 VPC 中创建一个新的安全组，并添加一条入站规则，允许来自数据库 VPC 的 IP 地址范围、通过 TCP 端口 1521 的

流量。在数据库子网上添加一条新的网络 ACL 规则。将该规则配置为允许来自应用程序 VPC 的 IP 地址范围的所有流量。将新的安全组关联到需要数据库访问的应用程序实例上。

Correct Answer: C

正确答案: C

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

VPC Peering (跨账号、同区域) 网络访问控制

Security Group (安全组) 基于“源安全组”的授权 (在同区域的对等 VPC 之间可引用对端 VPC 的安全组, 包括跨账号场景)

如何在实例频繁创建/销毁时实现最小权限网络访问: 只让“部分EC2实例”能访问对端数据库的 TCP/1521

NACL vs Security Group: NACL 是子网级、无状态; Security Group 是实例/ENI级、有状态, 更适合“只允许部分实例”

2. 独立思考 (不参考官方答案) 的结论

题目关键要求: 同一应用VPC里只有“部分”EC2需要访问对端数据库, 且实例会频繁创建/终止。

最合适做法是: 在数据库侧安全组入站规则里, 把“允许来源”精确限定为应用侧专用安全组; 只有被绑定该安全组的EC2实例才可访问数据库 TCP/1521。

基于 VPC CIDR 或 NACL 的控制, 通常只能做到“整段网段”或“整子网”的粗粒度, 无法精准到“部分实例”。

3. 逐个选项分析

A 选项: 错误

数据库安全组放行来源为应用VPC的IP地址范围 (CIDR), 这会导致应用VPC内所有实例 (只要路由可达) 都能尝试访问数据库, 不满足“只有部分实例”这一要求。

再加一层 NACL 仅限制 TCP/1521 也仍然是按网段/子网粒度控制, 无法区分同一VPC里哪些实例允许、哪些不允许。

“允许所有流量从应用VPC CIDR进数据库安全组”也过宽 (虽然NACL再收敛到1521, 但安全组层面仍不最小权限)。

B 选项: 错误

数据库侧安全组入站允许来源为应用VPC的CIDR:1521, 仍然会让应用VPC里所有实例具备到数据库的网络访问能力 (只要路由可达)。

应用侧安全组配置“入站允许来自数据库VPC CIDR:1521”并不能控制“出站访问数据库”的能力; EC2访问数据库主要依赖出站规则与数据库侧入站规则。

即便只把该安全组绑定到部分应用实例, 数据库侧仍按 CIDR 放行, 其他实例只要其自身安全组出站允许 (默认一般允许所有出站) 就仍可能访问数据库, 因此不满足题意。

C 选项: 正确

在应用VPC创建一个专用安全组 (可不配入站规则), 把它绑定到需要访问数据库的那部分EC2上。

在数据库VPC创建数据库专用安全组, 在入站规则中配置: TCP 1521 的来源 = 应用VPC里的该专用安全组。

这样只有“被绑定到该专用安全组”的EC2实例, 才能通过VPC Peering对数据库发起TCP/1521连接, 满足最小权限与实例动态变化的要求 (新建实例只要绑定该安全组即可)。

该方案不需要NACL参与 (NACL是子网级, 且无状态, 运维复杂度更高), 安全组即可精确控制。

D 选项: 错误

应用侧安全组入站允许来自数据库VPC CIDR:1521, 对“应用实例访问数据库”帮助不大 (访问数据库主要是应用实例出站 + 数据库入站)。

数据库子网NACL允许来自应用VPC CIDR的所有流量, 属于粗粒度放行, 仍无法限定“只有部分EC2”。

即使只给部分EC2绑定该安全组, NACL仍对整个应用VPC网段放通, 无法满足题意。

4. 我选择的答案

C

5. 官方答案

C

6. 与官方答案对比与复盘

我的答案：C；官方答案：C；结论：一致。

原因：只有 C 使用了“数据库安全组入站引用应用侧安全组”的方式，能精确到“哪些EC2实例”可访问数据库 TCP/1521，并且适合实例频繁创建/终止的场景。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #39

Topic 1

A company has multiple accounts in the AWS Cloud. Users in the developer account need to have access to specific resources in the production account.

What is the MOST secure way to provide this access?

一家公司在 AWS 云中拥有多个账户。开发者账户中的用户需要访问生产账户中的特定资源。
提供此访问权限的最安全方式是什么？

A. Create one IAM user in the production account. Grant the appropriate permissions to the resources that are needed. Share the password only with the users that need access.

在生产账户中创建一个 IAM 用户。向所需资源授予适当的权限。仅与需要访问的用户共享密码。

B. Create cross-account access with an IAM role in the developer account. Grant the appropriate permissions to this role. Allow users in the developer account to assume this role to access the production resources.

在开发者账户中使用 IAM 角色创建跨账户访问。向该角色授予适当的权限。允许开发者账户中的用户承担 (assume) 该角色以访问生产资源。

C. Create cross-account access with an IAM user account in the production account. Grant the appropriate permissions to this user account. Allow users in the developer account to use this user account to access the production resources.

在生产账户中使用 IAM 用户账户创建跨账户访问。向该用户账户授予适当的权限。允许开发者账户中的用户使用该用户账户来访问生产资源。

D. Create cross-account access with an IAM role in the production account. Grant the appropriate permissions to this role. Allow users in the developer account to assume this role to access the production resources.

在生产账户中使用 IAM 角色创建跨账户访问。向该角色授予适当的权限。允许开发者账户中的用户承担 (assume) 该角色以访问生产资源。

Correct Answer: D

正确答案: D

题目解析：多账号AWS环境中开发账号访问生产账号资源的最安全方式

1. 考察的知识点

AWS 跨账号访问 (Cross-account access) 最佳实践: 使用 IAM Role + STS AssumeRole 实现临时凭证访问。

最小权限原则: 在目标账号 (生产账号) 中定义可访问的资源与操作范围。

身份与权限边界的归属: 访问生产资源的授权应由生产账号控制 (资源拥有者/目标账号控制信任与权限)。

避免共享长期凭证: 不共享用户名/密码或 Access Key 等长期凭证, 优先临时凭证与可审计的会话。

2. 独立思考 (不参考官方答案)

最安全的跨账号方式通常是：在**资源所在的账号（生产账号）**创建一个IAM Role，授予访问生产资源的权限；并在该Role的Trust Policy中允许开发账号（或开发账号中的特定Role/用户）执行sts:AssumeRole。

理由：生产账号可以完全控制“谁能来、来后能做什么”，并且使用STS临时凭证，降低密钥泄露风险并增强审计。

3. 逐个选项分析

A 选项：在生产账户中创建一个IAM用户，分享密码

问题1：共享密码/长期凭证是明显的安全反模式（credential sharing），不符合安全合规与可审计性要求。

问题2：不可追踪到个人身份：多人共用一个用户，CloudTrail审计难以归因到具体开发者。

问题3：权限与生命周期管理差：人员变动/离职难以精细化撤权，容易造成权限长期残留。

结论：不安全，错误。

B 选项：在开发者账户创建IAM角色，并允许用户assume该角色访问生产资源

核心问题：角色在开发账号，权限却想作用于生产账号资源。跨账号访问的关键是：对生产账号资源的授权通常需要生产账号侧的角色信任或资源策略配合。

如果仅在开发账号创建Role并赋权限，这些权限**并不能直接授权访问生产账号资源**（除非生产资源本身有资源策略明确允许该主体访问，例如S3 bucket policy、KMS key policy、SNS/SQS等资源策略）。

题干表述为“访问生产账号特定资源”的泛化场景（并非限定为支持资源策略的服务），最通用、最安全的方式应是在**生产账号创建Role**。

结论：一般情况下不成立或不够通用，不是MOST secure/最佳实践，错误。

C 选项：在生产账户中创建IAM用户账户，让开发账号用户使用该用户访问

本质仍是共享长期凭证（Access key/密码等），与A同类问题。

审计与追责困难：多人共用同一IAM用户。

密钥泄露风险高：长期密钥一旦泄露，影响持续且难以控制。

结论：不安全，错误。

D 选项：在生产账户中创建IAM角色，授予权限，允许开发账户用户AssumeRole

符合最佳实践：跨账号访问使用STS AssumeRole，颁发临时凭证。

生产账号掌控授权：Role权限策略定义“能做什么”，信任策略定义“谁能来”。

可审计性强：CloudTrail可记录AssumeRole事件与会话信息，可结合source identity、session name等实现更强的溯源。

可叠加安全控制：可要求MFA（在信任策略中使用条件）、限制源IP、限制外部ID（如有需要）、限制只允许来自开发账号的特定Role等。

结论：最安全且最通用，正确。

4. 我选择的答案

D

5. 官方答案

D

6. 与官方答案比较与复盘

我的答案与官方答案一致：D

原因：跨账号访问的最安全通用方案是在**资源所在的生产账号创建IAM Role**，通过Trust Policy允许开发账号AssumeRole，使用STS临时凭证，避免共享长期凭证并提升审计与权限治理能力。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #40

Topic 1

A healthcare company stores more than 1 million patient records in an Amazon S3 bucket. The patient records include personally identifiable information (PII). The S3 bucket contains hundreds of terabytes of data.

A security engineer receives an alert that was triggered by an Amazon GuardDuty Exfiltration:S3/AnomalousBehavior finding. The security engineer confirms that an attacker is using temporary credentials that were obtained from a compromised Amazon EC2 instance that has s3:GetObject permissions for the S3 bucket. The attacker has begun downloading the contents of the bucket. The security engineer contacts a development team. The development team will require 4 hours to implement and deploy a fix. The security engineer must take immediate action to prevent the attacker from downloading more data from the S3 bucket. Which solution will meet this requirement?

一家医疗保健公司在 Amazon S3 存储桶中存储了超过 100 万条患者记录。患者记录包含个人身份信息 (PII)。该 S3 存储桶包含数百 TB 的数据。

一名安全工程师收到一个告警，该告警由 Amazon GuardDuty 的 Exfiltration:S3/AnomalousBehavior 发现项触发。安全工程师确认，攻击者正在使用从一台被入侵的 Amazon EC2 实例获取的临时凭证，该实例对该 S3 存储桶具有 s3:GetObject 权限。攻击者已开始下载该存储桶的内容。安全工程师联系了一个开发团队。开发团队需要 4 小时来实现并部署修复。

安全工程师必须立即采取行动，以防止攻击者从 S3 存储桶下载更多数据。

哪种解决方案将满足此要求？

- A. Revoke the temporary session that is associated with the instance profile that is attached to the EC2 instance.
撤销与附加到该 EC2 实例的实例配置文件相关联的临时会话。
- B. Quarantine the EC2 instance by replacing the existing security group with a new security group that has no rules applied.
通过将现有安全组替换为一个未应用任何规则的新安全组来隔离该 EC2 实例。
- C. Enable Amazon Macie on the S3 bucket. Configure the managed data identifiers for personally identifiable information (PII). Enable S3 Object Lock on objects that Macie flags.
在 S3 存储桶上启用 Amazon Macie。为个人身份信息 (PII) 配置托管数据标识符。对 Macie 标记的对象启用 S3 Object Lock。
- D. Apply an S3 bucket policy temporarily. Configure the policy to deny read access for all principals to block downloads while the development team address the vulnerability.
临时应用一个 S3 存储桶策略。配置该策略以拒绝所有主体的读取访问，通过阻止下载来为开发团队修复漏洞争取时间。

Correct Answer: A

正确答案: A

题目解析 (AWS Certified Security - Specialty SCS-C03)

1) 考察的知识点

GuardDuty S3 外传 (Exfiltration) 告警后的应急处置：如何在最短时间内阻断 S3 数据被继续下载。

临时凭证 (STS Temporary Credentials) 被窃取后的风险：攻击者一旦拿到临时凭证，可能不再依赖原 EC2 实例发起请求。

在资源侧 (S3 Bucket Policy) 进行强制阻断 vs 在计算侧 (隔离 EC2) 处理 的差异。

Macie/Object Lock 的用途边界：数据分类/不可篡改不等于阻止读取与下载。

2) 独立思考 (不参考官方答案)

题目核心目标是：**立刻**阻止攻击者继续从 S3 下载。

已确认攻击者使用的是从被攻陷 EC2 实例获取的**临时凭证**，并已开始下载。

在应急场景下，最“确定能立即生效”的阻断点通常是**S3 桶策略显式 Deny**（资源策略在每次请求时评估）。

3) 逐个选项分析

A. Revoke the temporary session that is associated with the instance profile

问题点：一般情况下，STS 临时凭证一旦发放，**在到期前仍可使用**；并不存在像“撤销某一组已签发的临时凭证并立刻全局失效”的常规、通用手段。

即使对实例做操作（如更换角色/移除权限/阻断 IMDS），也主要影响**后续获取新凭证**，但对攻击者已拿到的那组临时凭证，未必能做到“立刻失效”。

结论：作为“必须立即阻止下载更多数据”的确定性措施，A 描述的“撤销临时会话”在现实/考试常见能力边界下**不够可靠**，因此我不选。

B. Quarantine the EC2 instance by replacing the existing security group

隔离 EC2（收紧安全组）只能阻断**该实例的网络通信**。

但题目明确：攻击者使用临时凭证下载 S3。攻击者**可能在任意位置**使用这些凭证（本地机器、其他云主机等）对 S3 发起 GetObject；此时隔离原 EC2 并不能阻断外部使用同一组临时凭证的下载行为。

结论：不能保证立即阻止继续下载，**错误**。

C. Enable Amazon Macie... Enable S3 Object Lock on objects that Macie flags

Macie 是用来**发现/分类敏感数据**，不是即时阻断下载的控制。

S3 Object Lock 的核心是**防删除/防改写 (WORM)**，并不能阻止拥有 s3:GetObject 权限的主体读取对象。

而且“对 Macie 标记对象启用 Object Lock”也不符合 Object Lock 的典型工作方式（Object Lock 通常需要在桶级启用并在写入时/版本层面设置保留/Legal Hold），并非应急阻断手段。

结论：与“立即阻止下载更多数据”目标不匹配，**错误**。

D. Apply an S3 bucket policy temporarily to deny read access for all principals

在 S3 桶策略加入显式 **Deny**（例如 Deny s3:GetObject / s3:GetObjectVersion）会在**每次请求时**被评估，能够**立即生效**，从资源侧强制阻断下载。

即使攻击者手里已有临时凭证，只要其请求命中该桶/前缀并满足 Deny 条件，就会被拒绝。

缺点是会影响业务正常读访问，但题目场景强调“必须立即阻止更多数据被下载”，且开发团队需要 4 小时修复，临时牺牲可用性以止血是合理的应急策略。

结论：最符合“立即阻断继续下载”的要求，**正确**。

4) 我选择的答案

D

5) 官方答案

A

6) 与官方答案对比与复盘

我的答案 (D) 与官方答案 (A) **不同**。

重新思考关键点：题干要求“立即阻止更多下载”。在常见 AWS 能力与考试知识框架里，**临时凭证通常无法像访问密钥那样被直接撤销并瞬间失效**；它们更多是“到期失效”。因此 A 的表述在实操确定性上不足。

为什么仍坚持 D：S3 Bucket Policy 的显式 Deny 属于资源侧强制控制，对已泄露的临时凭证同样有效，且能立刻生效，是最稳妥的止血方案。

如果题库/官方解析将 A 视为正确，通常是把“撤销会话”理解为一种可立即使会话不可用的能力；但在多数实际与考试常规认知中，更可操作、更确定的即时阻断仍是**对 S3 施加显式 Deny (D)** 或对角色施加显式 Deny（题目未给该选项）。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #41

Topic 1

A company is investigating an increase in its AWS monthly bill. The company discovers that bad actors compromised some Amazon EC2 instances and served webpages for a large email phishing campaign.

A security engineer must implement a solution to monitor for cost increases in the future to help detect malicious activity.

Which solution will offer the company the EARLIEST detection of cost increases?

一家公司正在调查其 AWS 每月账单的增长。该公司发现，不法分子入侵了一些 Amazon EC2 实例，并为一次大规模电子邮件网络钓鱼活动提供网页服务。

一名安全工程师必须实施一个解决方案，以便在未来监控成本增长，从而帮助检测恶意活动。

哪种解决方案将为公司提供对成本增长的最早检测？

A. Create an Amazon EventBridge rule that invokes an AWS Lambda function hourly. Program the Lambda function to download an AWS usage report from AWS Data Exports about usage of all services. Program the Lambda function to analyze the report and to send a notification when anomalies are detected.

创建一条 Amazon EventBridge 规则，每小时调用一次 AWS Lambda 函数。编写 Lambda 函数，从 AWS Data Exports 的 AWS 使用情况报告中下载所有服务的使用情况报告。编写 Lambda 函数分析该报告，并在检测到异常时发送通知。

B. Create a cost monitor in AWS Cost Anomaly Detection. Configure an individual alert to notify an Amazon Simple Notification Service (Amazon SNS) topic when the percentage above the expected cost exceeds a threshold.

在 AWS Cost Anomaly Detection 中创建一个成本监控器。配置一个单独的告警，当高于预期成本的百分比超过阈值时，向一个 Amazon Simple Notification Service (Amazon SNS) 主题发送通知。

C. Review AWS Cost Explorer daily to detect anomalies in cost from prior months. Review the usage of any services that experience a significant cost increase from prior months.

每天查看 AWS Cost Explorer，以检测相对于前几个月的成本异常。查看任何相对于前几个月出现显著成本增长的服务的使用情况。

D. Capture VPC flow logs from the VPC where the EC2 instances run. Use a third-party network analysis tool to analyze the flow logs and to detect anomalies in network traffic that might increase cost.

从运行 EC2 实例的 VPC 中捕获 VPC 流日志。使用第三方网络分析工具分析这些流日志，并检测可能导致成本增加的网络流量异常。

Correct Answer: B

正确答案: B

题目解析：最早发现AWS成本异常的监控方案

1. 本题考察的知识点

AWS成本异常检测与告警能力： AWS Cost Anomaly Detection 的工作方式与告警时效。

成本数据的可用性/延迟: 成本与用量数据 (如Cost数据源、导出报表) 并非“实时”, 自建轮询也受数据刷新频率限制。

检测目标匹配: 题目要求“最早发现成本增加 (cost increases)”, 而不是最早发现网络异常或资源异常。

2. 独立思考 (不参考官方答案)

要“最早”发现成本增加, 关键在于: **谁能最快拿到可用的成本数据并自动判断异常。**

即使你每小时跑一次程序 (如选项A), 如果上游成本/用量数据本身不是每小时出一份可用于计费分析的数据, 你也无法比AWS原生异常检测更早得到“成本异常”的结论。

AWS Cost Anomaly Detection 属于专门为“尽早发现异常花费”设计的托管能力, 通常能在账单数据更新后尽快给出异常判断并通知。

3. 逐个选项分析

A. 每小时Lambda下载AWS Data Exports使用情况报告并分析告警

优点: 看起来“每小时执行”似乎能更早发现问题; 可覆盖所有服务并做自定义逻辑。

关键问题: 检测成本异常的瓶颈往往不在你轮询频率, 而在成本/用量数据导出的生成与可用延迟。即使Lambda每小时跑一次, 如果导出的可用数据不是按小时及时更新, 仍无法做到更早的“成本增加”检测。

工程复杂度高: 需要自己实现异常检测算法、阈值与去噪、按服务/账号维度归因等; 误报漏报风险更高。

结论: 不一定能比原生成本异常检测更早; 且题目问“最早检测成本增加”, 更符合托管异常检测服务的定位。倾向判错。

B. 使用AWS Cost Anomaly Detection成本监控器 + 超阈值百分比告警到SNS

优点: 这是AWS专门用于**尽早发现成本异常**的服务, 能够基于历史基线/预期成本自动识别异常并推送通知。

告警链路标准: Anomaly Detection → Alert → SNS, 自动化、低运维。

时效性: 在AWS成本数据更新可用于分析后, Cost Anomaly Detection能较快触发异常告警; 相较于人工检查 (C) 或非成本信号 (D), 更能“最早”在成本维度发现异常。

结论: 最符合题意“监控成本增加以尽早发现恶意活动”。判对。

C. 每天人工查看Cost Explorer与历史月份对比

问题: 人工每日查看是**明显滞后**的方式; 而且对比“前几个月”也不适合快速响应当前突增 (例如当天被滥用就会造成成本飙升)。

不满足“最早检测”: 无法自动化实时/准实时告警。

结论: 判错。

D. VPC Flow Logs + 第三方网络分析检测可能增加成本的流量异常

问题1: 检测目标不直接是成本。 VPC Flow Logs反映网络流量行为, 确实可能与某些成本 (如数据传输、NAT网关等) 相关, 但它不是“成本增加”的直接检测。

问题2: 覆盖面不完整: 成本增加来源可能是计算、存储、托管服务调用等, 与VPC流量并不必然相关。

问题3: 实现复杂: 第三方工具、规则、基线等都需要维护; 且即便发现流量异常, 也不等价于“最早发现成本增加”。

结论: 偏离题意 (成本异常最早检测)。判错。

4. 我选择的答案

B

5. 官方答案

B

6. 与官方答案对比与复盘

我的答案与官方答案一致 (B)。

原因总结: 题目明确要“最早发现成本增加”, 在AWS提供的原生能力里, **AWS Cost Anomaly Detection**是专门做异常成本检测与告警的服务, 能够在成本数据可用于分析后尽快告警; C是人工且滞后, D是网络侧信号且不直接等价成本异常, A即便高频执行也受制于成本/用量数据产出与可用延迟且实现复杂。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #42

Topic 1

A company uses Amazon API Gateway to present REST APIs to users. An API developer wants to analyze API access patterns without the need to parse the log files.

Which combination of steps will meet these requirements with the LEAST effort? (Choose two.)

一家公司的用户使用 Amazon API Gateway 来向用户提供 REST API。一个 API 开发人员希望在无需解析日志文件的情况下分析 API 访问模式。

哪组步骤组合将以最少的工作量满足这些要求? (选择两项。)

A. Configure access logging for the required API stage.
为所需的 API 阶段配置访问日志记录。

B. Configure an AWS CloudTrail trail destination for API Gateway events. Configure filters on the userIdentity, userAgent, and sourceIPAddress fields.

为 API Gateway 事件配置一个 AWS CloudTrail 跟踪目标。在 userIdentity、userAgent 和 sourceIPAddress 字段上配置过滤器。
C. Configure an Amazon S3 destination for API Gateway logs. Run Amazon Athena queries to analyze API access information.
为 API Gateway 日志配置一个 Amazon S3 目标。运行 Amazon Athena 查询以分析 API 访问信息。

D. Use Amazon CloudWatch Logs Insights to analyze API access information.
使用 Amazon CloudWatch Logs Insights 来分析 API 访问信息。

E. Select the Enable Detailed CloudWatch Metrics option on the required API stage.
在所需的 API 阶段上选择“启用详细的 CloudWatch 指标”选项。

Correct Answer: AD

正确答案: AD

题目解析: API Gateway 访问模式分析 (不解析日志文件、最省力)

1. 考察的知识点

Amazon API Gateway Stage 访问日志 (Access Logging): 在 Stage 级别开启访问日志, 将每次请求的关键信息 (例如路径、方法、状态码、延迟、来源 IP、User-Agent、请求 ID 等) 输出到指定目的地 (通常是 CloudWatch Logs)。

Amazon CloudWatch Logs Insights: 对 CloudWatch Logs 中的日志进行交互式查询与聚合分析, 无需自己写脚本“解析日志文件”。

“最省力”组合: 尽量避免将日志落到 S3 再用 Athena 等额外链路; 并区分“指标 (Metrics)”与“日志 (Logs)”能提供的信息粒度。

2. 独立思考 (不参考官方答案)

题干要求: 分析 API 访问模式, 且不需要解析日志文件, 并且工作量最少。

要做访问模式分析（如按路径/方法/状态码/来源IP/User-Agent/响应时间分布/Top N等），通常需要**访问日志**；仅靠指标往往只能看到聚合数据（请求数、4XX/5XX、延迟等），难以做“访问模式”中常见的维度切分（例如User-Agent、source IP）。因此最省力做法：**开启Stage访问日志到CloudWatch Logs + 用CloudWatch Logs Insights直接查询分析。**

3. 逐个选项分析

A. Configure access logging for the required API stage. 结论：正确（必要步骤之一） 原因：要在不“解析日志文件”的前提下分析访问模式，首先需要把访问日志产出到可查询的日志系统。API Gateway的Stage Access Logging可将结构化/自定义格式日志写入CloudWatch Logs（常见做法）。没有日志数据源，后续无法用Logs Insights做查询分析。

B. Configure an AWS CloudTrail trail destination for API Gateway events. Configure filters on the userIdentity, userAgent, and sourceIPAddress fields. 结论：错误/不优（不满足“最省力”的主路径） 原因：

CloudTrail主要用于记录**控制面（management events）** API调用与审计（谁创建/修改了API、谁调用了某些AWS API等）。终端用户对API Gateway的**数据面（invoke）** 请求访问模式分析，主力工具应是**Access Logs/Execution Logs + 日志分析**或WAF日志等。

即便能捕获部分相关事件，CloudTrail并不是分析“每次API请求访问模式”的最直接、最低成本/最低工作量方式。

题干目标是“无需解析日志文件分析访问模式”，CloudTrail并不能替代访问日志的典型需求维度与明细。

C. Configure an Amazon S3 destination for API Gateway logs. Run Amazon Athena queries to analyze API access information. 结论：不优（工作量更大） 原因：

把日志送到S3、建表/分区、用Athena查询，链路更长、配置更多。

相比之下，CloudWatch Logs + Logs Insights可以更快上手、步骤更少，更符合“LEAST effort”。

D. Use Amazon CloudWatch Logs Insights to analyze API access information. 结论：正确（必要步骤之一） 原因：Logs Insights提供即席查询与聚合（Top N、时间序列、按字段分组），可以在**不自己解析日志文件**的情况下完成访问模式分析。但前提是日志已进入CloudWatch Logs（通常由A提供）。

E. Select the Enable Detailed CloudWatch Metrics option on the required API stage. 结论：错误/不满足题意（不足以做访问模式分析） 原因：

Detailed Metrics属于指标层（例如请求数、延迟、4XX/5XX），用于监控与告警更合适。

“访问模式”常需要按**来源IP、User-Agent、请求路径/参数**等维度做分析，这些通常需要日志明细而不是聚合指标。

仅开启指标并不能替代对访问日志的查询分析。

4. 我选择的答案

A + D

5. 官方答案

A + D

6. 与官方答案对比与复盘

对比结果：一致（均为AD）。

复盘要点：

A提供日志数据源（Stage Access Logging到CloudWatch Logs），D提供免解析的查询分析（Logs Insights）。

相比S3+Athena（C）链路更复杂；CloudTrail（B）偏审计控制面；Detailed Metrics（E）信息粒度不足以支撑访问模式的多维分析。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #43

Topic 1

A startup company is using a single AWS account that has resources in a single AWS Region. A security engineer configures an AWS CloudTrail trail in the same Region to deliver log files to an Amazon S3 bucket by using the AWS CLI. Because of expansion, the company adds resources in multiple Regions. The security engineer notices that the logs from the new Regions are not reaching the S3 bucket.

What should the security engineer do to fix this issue with the LEAST amount of operational overhead?

一家初创公司正在使用一个单一的 AWS 账户, 该账户在单一的 AWS 区域中拥有资源。一名安全工程师在同一区域中配置了一个 AWS CloudTrail 跟踪 (trail), 使用 AWS CLI 将日志文件传送到一个 Amazon S3 存储桶。由于业务扩张, 公司在多个区域中添加了资源。安全工程师注意到, 新区域的日志没有到达该 S3 存储桶。为了以最少的运维开销修复此问题, 安全工程师应该怎么做?

A. Create a new CloudTrail trail. Select the new Regions where the company added resources.

创建一个新的 CloudTrail 跟踪。选择公司添加资源的新区域。

B. Change the S3 bucket to receive notifications to track all actions from all Regions.

更改 S3 存储桶以接收通知, 从而跟踪来自所有区域的所有操作。

C. Create a new CloudTrail trail that applies to all Regions.

创建一个适用于所有区域的新的 CloudTrail 跟踪。

D. Change the existing CloudTrail trail so that it applies to all Regions.

更改现有的 CloudTrail 跟踪, 使其适用于所有区域。

Correct Answer: D

正确答案: D

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 考察的知识点是什么?

AWS CloudTrail Trail 的范围与行为: 单区域 (single-Region trail) vs 多区域 (multi-Region trail)。

CloudTrail 日志投递机制: Trail 在哪些 Region 生效, 就只会从哪些 Region 产生并投递日志到 S3。

最小运维开销 (least operational overhead): 优先选择“修改现有配置”而不是“新增一套并维护多套”。

2. 独立思考 (不参考官方答案)

现象: 原先公司只有一个 Region, 创建的 CloudTrail trail 也在同一 Region, 能正常投递到 S3。

变化: 公司新增多个 Region 的资源。

问题: 新 Region 的日志没有进入该 S3 bucket。

根因最可能是: 现有 trail 是**单区域 trail**, 只记录创建时所在 Region 的事件; 新增 Region 没被覆盖。

目标：以最小运维开销修复——最佳是**把现有 trail 改成多区域 trail (apply to all Regions)**，继续使用同一个 S3 bucket。

3. 逐个分析每个选项为什么正确或错误

A. Create a new CloudTrail trail. Select the new Regions where the company added resources. 结论：**不推荐/错误** 原因：

需要创建并维护一个新 trail（额外配置、监控、审计与后续变更管理）。

如果未来继续新增 Region，还要再改/再加 Region 配置，运维开销更高。

不满足“LEAST amount of operational overhead”。

B. Change the S3 bucket to receive notifications to track all actions from all Regions. 结论：**错误** 原因：

S3 事件通知（Event Notifications）只是在对象创建/删除等事件时通知 SNS/SQS/Lambda，**不能让 CloudTrail 自动采集所有 Region 的日志。**

CloudTrail 是否产生日志取决于 trail 的范围设置，不是 S3 bucket 的通知设置。

该选项属于概念混淆，无法解决“新 Region 没有 CloudTrail 日志写入 S3”的根因。

C. Create a new CloudTrail trail that applies to all Regions. 结论：**可行但不是最优** 原因：

创建一个多区域 trail 确实能覆盖所有 Region，功能上能解决问题。

但题目强调**最小运维开销**：已有 trail 已在用同一 S3 bucket 投递，直接修改现有 trail 更省事。

新增 trail 可能带来：

重复采集/重复投递（如果旧 trail 仍然保留），导致日志量、成本、分析复杂度上升。

需要额外的 trail 生命周期管理与一致性配置（例如日志验证、加密、过滤、集成 SIEM 等）。

D. Change the existing CloudTrail trail so that it applies to all Regions. 结论：**正确** 原因：

直接把现有单区域 trail 改为多区域 trail，即可开始从所有 Region 记录管理事件并投递到同一 S3 bucket。

无需新增 trail，避免重复日志、减少配置与维护对象数量，符合“LEAST operational overhead”。

实现上通常是更新 trail 的设置（例如启用 multi-region trail），不需要变更日志目的地。

4. 我选择的答案

D

5. 官方答案

D

6. 与官方答案比较与复盘

我的答案：D

官方答案：D

比较结果：**一致**

复盘要点：

CloudTrail 没覆盖新 Region 的最常见原因就是 trail 不是 multi-region。

“最小运维开销”通常指：**修改现有配置优于新增资源/新增配置项。**

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #44

Topic 1

A security team manages a company's AWS Key Management Service (AWS KMS) customer managed keys. Only members of the security team can administer the KMS keys. The company's application team has a software process that needs temporary access to the keys occasionally. The security team needs to provide the application team's software process with access to the keys. Which solution will meet these requirements with the LEAST operational overhead?

一个安全团队管理公司的 AWS Key Management Service (AWS KMS) 客户托管密钥。只有安全团队的成员可以管理 KMS 密钥。公司的应用团队有一个软件流程偶尔需要对这些密钥进行临时访问。安全团队需要为应用团队的软件流程提供对这些密钥的访问权限。

哪种解决方案能够以最少的运维开销满足这些要求?

A. Export the KMS key material to an on-premises hardware security module (HSM). Give the application team access to the key material.

将 KMS 密钥材料导出到本地硬件安全模块 (HSM)。向应用团队授予对密钥材料的访问权限。

B. Edit the key policy that grants the security team access to the KMS keys by adding the application team as principals. Revert this change when the application team no longer needs access

编辑密钥策略，通过将应用团队添加为主体 (principals) 来授予安全团队对 KMS 密钥的访问权限。在应用团队不再需要访问时还原此更改

C. Create a key grant to allow the application team to use the KMS keys. Revoke the grant when the application team no longer needs access.

创建一个密钥授权 (key grant)，允许应用团队使用 KMS 密钥。在应用团队不再需要访问时撤销该授权。

D. Create a new KMS key by generating key material on premises. Import the key material to AWS KMS whenever the application team needs access. Grant the application team permissions to use the key.

通过在本地生成密钥材料来创建一个新的 KMS 密钥。每当应用团队需要访问时，将密钥材料导入到 AWS KMS。授予应用团队使用该密钥的权限。

Correct Answer: C

正确答案: C

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

AWS KMS Key Policy vs IAM Policy vs Grant: KMS 的权限控制机制与授权路径

KMS Grants (密钥授权): 用于将 KMS 密钥的“使用权限”临时委派给其他主体，且无需改 Key Policy

最小运维开销: 临时访问需求下，避免频繁变更 Key Policy 或做复杂的密钥材料导入/导出流程

管理权限与使用权限分离: 安全团队保留管理权 (admin)，应用仅需短期使用权 (encrypt/decrypt 等)

2. 独立思考（不参考官方答案）

题干要求：只有安全团队能“管理（administer）”KMS keys，但应用团队的软件进程“偶尔需要临时访问密钥”。

最符合“临时、可撤销、低运维”的机制是：**KMS Grant**（创建授权、需要时启用，不需要时撤销）。

因此更可能的最佳方案为：**C**。

3. 逐个选项分析

A. 导出 KMS 密钥材料到本地 HSM，并给应用团队访问密钥材料

错误：对大多数 KMS 对称 CMK（Customer managed key）而言，**密钥材料不可从 KMS 导出**，KMS 的设计目标之一就是让密钥材料不离开受控边界。

错误：即使理论上能让密钥材料离开 KMS，这也会显著扩大攻击面，违背“由安全团队集中管理”的意图。

错误：运维开销高（本地 HSM、访问控制、审计、密钥生命周期管理等），且不符合“临时访问”的轻量需求。

B. 修改 Key Policy 把应用团队加为 principal，用完再改回去

部分可行但不推荐：从权限角度，确实可以通过 Key Policy 增加应用团队主体获得 KMS 使用权限。

错误（不满足最小运维开销）：每次临时需要访问都要修改并回滚 Key Policy，带来持续的变更流程、审批、潜在配置错误风险。

风险：Key Policy 变更属于高风险操作，容易导致权限过大或锁死管理权限等问题。

C. 创建 KMS Grant 允许应用团队使用密钥，用完撤销 Grant

正确：Grant 专门用于将 KMS 权限（如 Encrypt/Decrypt/GenerateDataKey 等）**委派给特定主体**，且通常不需要改 Key Policy。

正确：支持**临时性与可撤销**（RevokeGrant），非常匹配“偶尔需要临时访问”。

正确：运维开销低：创建/撤销 grant 相比频繁改 Key Policy 更轻量、更不容易引入配置事故。

符合职责分离：安全团队仍然保留密钥管理权，应用仅获得所需的使用权限。

D. 本地生成密钥材料，创建新 KMS key，需要时再导入密钥材料，并授权应用使用

错误（运维开销极高）：频繁进行“创建新 key / 导入 key material / 管理生命周期”极其繁琐，不符合 least operational overhead。

不匹配题意：题干是“偶尔临时访问现有 KMS keys”，不是每次需要都新建一把 key。

复杂性与风险：导入密钥材料涉及导入令牌、到期管理、可用性与合规审计等额外负担。

4. 我选择的答案

C

5. 官方答案

C

6. 与官方答案对比与复盘

对比结果：一致（我选 C，官方也选 C）。

原因：KMS Grant 是为“临时、可撤销的密钥使用权限委派”而设计，并且避免频繁修改 Key Policy，最符合“LEAST operational overhead”。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #45

Topic 1

A company is running a new workload across accounts that are in an organization in AWS Organizations. All running resources must have a tag of CostCenter, and the tag must have one of three approved values. The company must enforce this policy and must prevent any changes of the CostCenter tag to a non-approved value.

Which solution will meet these requirements?

一家公司正在 AWS Organizations 中某个组织内的多个账户之间运行一个新的工作负载。所有正在运行的资源都必须带有一个名为 CostCenter 的标签, 并且该标签必须具有三个已批准值之一。公司必须强制执行此策略, 并且必须防止将 CostCenter 标签更改为非批准值。

哪种解决方案将满足这些要求?

A. Create an AWS Config Custom Policy rule by using AWS CloudFormation Guard. Include the tag key of CostCenter and the approved values. Create an SCP that denies the creation of resources when the value of the `aws:RequestTagCostCenter` condition key is not one of the three approved values.

使用 AWS CloudFormation Guard 创建一个 AWS Config Custom Policy 规则。包含 CostCenter 的标签键以及已批准的值。创建一个 SCP, 当 `aws:RequestTagCostCenter` 条件键的值不是三个已批准值之一时, 拒绝创建资源。

B. Create an AWS CloudTrail trail. Create an Amazon EventBridge rule that includes a rule statement that matches the creation of new resources. Configure the EventBridge rule to invoke an AWS Lambda function that checks for the CostCenter tag. Program the Lambda function to block creation in case of a noncompliant value.

创建一个 AWS CloudTrail trail。创建一个 Amazon EventBridge 规则, 其中包含匹配新资源创建的规则语句。配置 EventBridge 规则以调用一个 AWS Lambda 函数, 用于检查 CostCenter 标签。对 Lambda 函数进行编程, 以便在值不合规的情况下阻止创建。

C. Enable tag policies for the organization. Create a tag policy that specifies a tag key of CostCenter and the approved values. Configure the policy to enforce noncompliant operations. Create an SCP that denies the creation of resources when the `aws:RequestTag.CostCenter` condition key has a null value.

为组织启用标签策略。创建一个标签策略, 指定标签键为 CostCenter 以及已批准的值。配置该策略以强制执行不合规操作。创建一个 SCP, 当 `aws:RequestTag.CostCenter` 条件键具有 null 值时, 拒绝创建资源。

D. Enable tag policies for the organization. Create a tag policy that specifies a tag key of CostCenter and the approved values. Create an Amazon EventBridge rule that invokes an AWS Lambda function when a noncompliant tag is created. Program the Lambda function to block changes to the tag.

为组织启用标签策略。创建一个标签策略, 指定标签键为 CostCenter 以及已批准的值。创建一个 Amazon EventBridge 规则, 当创建不合规标签时调用一个 AWS Lambda 函数。对 Lambda 函数进行编程, 以阻止对该标签的更改。

Correct Answer: A

正确答案: A

题目考察的知识点

AWS Organizations 的 SCP (Service Control Policy)：在组织/OU/账号层面强制限制 API 行为，实现“预防性控制 (preventive control)”。

基于标签的访问控制 (Tag-based access control)：使用 IAM/SCP 全局条件键 (如 `aws:RequestTag/CostCenter`、`aws:TagKeys`、以及针对资源已有标签的 `aws:ResourceTag/CostCenter`) 限制创建/打标/改标。

AWS Config / CloudTrail / EventBridge 的定位差异：Config 与 CloudTrail+EventBridge 多为“检测/告警/事后修复”，不适合“阻止已发生的 API 调用”。

Tag Policies (标签策略) 的能力边界：主要用于规范与一致性校验/可见性 (不同服务支持度不同)，通常不作为强制阻断 API 的唯一手段。

独立思考 (不参考官方答案) 的结论

题目要求：**所有运行资源必须有 CostCenter 标签且值必须在 3 个批准值内，并且必须阻止把 CostCenter 改成非批准值。**

要满足“必须阻止/预防”，核心必须是 **SCP/IAM 条件** 对创建与改标相关 API 进行 **Deny**。

CloudTrail/EventBridge/Lambda 与 AWS Config 主要是事后发现，无法在绝大多数服务的 Create/Tag API 调用“执行前”拦截，因此不满足“prevent”。

逐项分析选项

选项 A

包含内容：AWS Config Custom Policy (CloudFormation Guard) + SCP：当 `aws:RequestTagCostCenter` 不在批准值内时拒绝创建。

优点 (为什么可能正确)：

SCP Deny + request tag 条件 是实现“预防性控制”的正确方向：可以在创建资源时要求携带 CostCenter 且值在允许列表内。

AWS Config 规则可用于持续合规检测与审计补充 (检测存量/漂移)，虽然不是“阻止”手段，但可作为监控。

问题点 (为什么可能不完整/有瑕疵)：

题干还要求：**必须防止任何把 CostCenter 改为非批准值的变更**。仅“拒绝创建资源”不足以覆盖后续的 `TagResource / CreateTags / UpdateTags` 等改标 API。

条件键写法：通常应为 `aws:RequestTag/CostCenter` (带“/”)，题干里的 `aws:RequestTagCostCenter` 并非常见标准写法 (考试题可能简化/写错，但概念是用 RequestTag 条件)。

Config 规则不能“阻止”API 调用，只能评估与触发修复；真正阻止仍要靠 SCP (或权限边界/IAM)。

小结：在四个选项里，A 是唯一真正具备“预防性阻断”的关键组件 (SCP + RequestTag 条件) 且最接近满足要求；但严格来说还应在 SCP 中同时约束“改标/更新标签”相关操作。

选项 B

包含内容：CloudTrail + EventBridge 触发 Lambda 检查 CostCenter，不合规则“阻止创建”。

为什么错误：

CloudTrail 事件是 **API 调用后** 记录，EventBridge 触发也是 **事后**；Lambda 无法回到过去阻止已经发生的 Create API。

除非采用特定服务的“前置拦截”机制 (例如某些场景的服务集成/自定义工作流)，但这里通用的 CloudTrail+EventBridge 并不提供通用的“拦截器”。

无法可靠满足“必须防止变更”的硬性要求 (最多做到发现后回滚/补救)。

选项 C

包含内容：启用 Tag Policies，定义 CostCenter 及批准值，并“配置策略以强制不合规操作”；再用 SCP 拒绝创建时 CostCenter 为空 (null)。

为什么错误/不足：

SCP 只检查 null：只能确保“创建时带 CostCenter”，但**不限制取值必须在 3 个批准值内** (题目明确要求限制值域)。

Tag Policies 在常见认知与考试语境下通常属于**规范/一致性与可见性**能力，不等同于用 SCP 那样对所有相关 API 做强制 Deny；

把“强制执行不合规操作”作为关键阻断点不够稳妥。

同样没有明确覆盖“后续改标变为非批准值”的阻止逻辑 (仍需 SCP 去 deny TagResource/相关操作)。

选项 D

包含内容：Tag Policies + EventBridge 触发 Lambda，在创建不合规标签时阻止变更。

为什么错误：

EventBridge/Lambda 仍是**事后触发**，无法通用地“阻止”已经发起的标签变更 API 调用。

Tag Policies 本身也不足以作为通用的强制阻断机制。

我选择的答案

A

官方答案

A

与官方答案比较与复盘

一致：我选 A，官方也选 A。

补充说明（重要）：

若严格实现题目“阻止任何把 CostCenter 改成非批准值”的要求，实际落地时应在 **SCP** 中不仅限制“创建资源”，还要同时对常见的“改标签”API 增加 Deny（例如 **tag:TagResources / ec2:CreateTags / iam:TagRole** 等服务各自的 Tag API），并使用 **aws:RequestTag/CostCenter** 做允许列表校验。

A 选项虽然文字只写“拒绝创建资源”，但其“用 SCP 基于 RequestTag 值做 Deny”的方向，是四个选项里唯一符合“预防性强制”的核心手段，因此仍是最佳答案。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #46

Topic 1

A company uses AWS Organizations. The company has learned that use an AWS CloudHSM hardware security module (HSM) that is hosted in a central AWS account. One of the teams creates its own new dedicated AWS account and wants to use the HSM that is hosted in the central account.

How should a security engineer share the HSM that is hosted in the central account with the new dedicated account?

一家公司使用 AWS Organizations。该公司了解到使用托管在某个中心 AWS 账户中的 AWS CloudHSM 硬件安全模块 (HSM)。其中一个团队创建了自己的新专用 AWS 账户，并希望使用托管在中心账户中的 HSM。

安全工程师应如何将托管在中心账户中的 HSM 共享给新的专用账户？

A. Use AWS Resource Access Manager (AWS RAM) to share the VPC subnet ID of the HSM that is hosted in the central account with the new dedicated account. Configure the CloudHSM security group to accept inbound traffic from the private IP addresses of client instances in the new dedicated account.

使用 AWS Resource Access Manager (AWS RAM) 将托管在中心账户中的 HSM 的 VPC 子网 ID 共享给新的专用账户。配置 CloudHSM 安全组以接受来自新专用账户中客户端实例私有 IP 地址的入站流量。

B. Use AWS Identity and Access Management (IAM) to create a cross-account role to access the CloudHSM cluster that is in the central account. Create a new IAM user in the new dedicated account. Assign the cross-account role to the new IAM user.

使用 AWS Identity and Access Management (IAM) 创建一个跨账户角色，以访问位于中心账户中的 CloudHSM 集群。在新专用账户中创建一个新的 IAM 用户。将该跨账户角色分配给新的 IAM 用户。

C. Use AWS IAM Identity Center to create an AWS Security Token Service (AWS STS) token to authenticate from the new dedicated account to the central account. Use the cross-account permissions that are assigned to the STS token to invoke an operation on the HSM in the central account.

使用 AWS IAM Identity Center 创建一个 AWS Security Token Service (AWS STS) 令牌，以便从新专用账户向中心账户进行身份验证。使用分配给该 STS 令牌的跨账户权限，调用中心账户中 HSM 上的某项操作。

D. Use AWS Resource Access Manager (AWS RAM) to share the ID of the HSM that is hosted in the central account with the new dedicated account. Configure the CloudHSM security group to accept inbound traffic from the private IP addresses of client instances in the new dedicated account.

使用 AWS Resource Access Manager (AWS RAM) 将托管在中心账户中的 HSM 的 ID 共享给新的专用账户。配置 CloudHSM 安全组以接受来自新专用账户中客户端实例私有 IP 地址的入站流量。

Correct Answer: D

正确答案: D

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

AWS CloudHSM 的跨账户共享机制：CloudHSM（准确说是 CloudHSM Cluster）如何在 AWS Organizations 内被其他账户使用。
AWS Resource Access Manager (AWS RAM)：用于在组织内跨账户共享特定资源（CloudHSM Cluster 属于可共享资源范畴）。
网络层访问控制：CloudHSM 客户端与 HSM 之间通过 VPC 网络连通性 + Security Group 放通进行通信，而不是靠 IAM/STS 直接“调用HSM”。

2. 独立思考（不参考官方答案）

CloudHSM 的“使用”本质上是：客户端实例通过网络连接到 HSM（集群中的 HSM ENI）并通过 CloudHSM 客户端/库进行加解密等操作。

跨账户“共享”通常不是靠 IAM Role/STS 去“远程调用 HSM 操作”，而是要让目标账户**获得对 CloudHSM 集群的可见/可管理权限（通过 RAM 共享）**，并确保网络可达与安全组放通。

因此最合理的方向是：**用 AWS RAM 共享 CloudHSM（准确应是 Cluster）**，并配置 CloudHSM 所在安全组允许来自新账户客户端的访问（基于网段/安全组/私网IP等）。

3. 逐个选项分析

A 选项：错误 原因：

AWS RAM 共享**子网ID**的典型用途，是让其他账户在该子网中创建某些资源（例如共享子网给其他账户创建 ENI/EC2 等），但这并不等价于“共享 CloudHSM”。

CloudHSM 的关键是共享**CloudHSM 资源本身（更准确为 Cluster）**，而不是共享子网。

另外，即使能共享子网，CloudHSM 的使用也不靠“对方账户进到我的子网”来解决；通常是通过跨VPC连通（VPC Peering / TGW / VPN 等）+ 安全组放通 + 共享 Cluster 权限来实现。

B 选项：错误 原因：

IAM Cross-account Role 能授权对 CloudHSM 的**管理类 API**（如 Describe/CreateHsm 等）操作权限，但无法仅靠 IAM 让另一个账户“使用”HSM 执行加密操作。

CloudHSM 的加密操作不是通过 IAM Role 来“调用某个 HSM API”完成的，而是通过**网络连接 + HSM 内部用户（CU/AU）认证**在 HSM 上执行。

本选项也没有解决必须的网络连通与资源共享模型（RAM 共享 Cluster）的核心问题。

C 选项：错误 原因：

IAM Identity Center 获取 STS Token 的模式用于访问 AWS API（控制平面），但 CloudHSM 的“在 HSM 上执行密码操作”不是靠 STS Token 去调用某个“对 HSM 的操作接口”。

STS Token 不能替代 CloudHSM 客户端到 HSM 的网络访问与 HSM 内部身份（HSM user）。

该选项描述的机制与 CloudHSM 实际使用路径不匹配。

D 选项：基本正确（但表述不严谨） 原因：

跨账户共享 CloudHSM 的正确方向是：**使用 AWS RAM 共享 CloudHSM 资源（通常是 CloudHSM Cluster）**给新账户，使其获得对该资源的使用/管理可见性（在 Organizations 内更常见）。

并且需要配置 CloudHSM 的安全组允许来自新账户客户端实例的访问（同时还要确保 VPC 间网络连通性存在）。

不足点（表述问题）：RAM 通常共享的是**CloudHSM Cluster**（资源/ARN），而不是“单个 HSM 的 ID”。但在给定选项里，D 最贴近正确做法与考点意图。

4. 我选择的答案

D

5. 官方答案

D

6. 与官方答案对比与复盘

我的答案与官方答案一致：D

补充复盘：

官方/选项中的“share the ID of the HSM”在措辞上不够准确；更严谨的说法应是**通过 AWS RAM 共享 CloudHSM Cluster**。

题目在考点层面更关注：**CloudHSM 跨账户共享用 RAM + 网络/安全组放通**，而不是 IAM role/STS。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #47

Topic 1

A company uses AWS Config rules to identify Amazon S3 buckets that are not compliant with the company's data protection policy. The S3 buckets are hosted in several AWS Regions and several AWS accounts. The accounts are in an organization in AWS Organizations.

The company needs a solution to remediate the organization's existing noncompliant S3 buckets and any noncompliant S3 buckets that are created in the future.

Which solution will meet these requirements?

一家公司使用 AWS Config 规则来识别不符合公司数据保护策略的 Amazon S3 存储桶。S3 存储桶托管在多个 AWS 区域和多个 AWS 账户中。这些账户位于 AWS Organizations 中的一个组织内。

公司需要一种解决方案来修复该组织中现有的不合规 S3 存储桶，以及未来创建的任何不合规 S3 存储桶。

哪种解决方案将满足这些要求？

A. Deploy an AWS Config aggregator with organization-wide resource data aggregation. Create an AWS Lambda function that responds to AWS Config findings of noncompliant S3 buckets by deleting or reconfiguring the S3 buckets.

部署一个启用组织范围资源数据聚合的 AWS Config 聚合器。创建一个 AWS Lambda 函数，当 AWS Config 发现不合规的 S3 存储桶时，删除或重新配置这些 S3 存储桶。

B. Deploy an AWS Config aggregator with organization-wide resource data aggregation. Create an SCP that contains a Deny statement that prevents the creation of new noncompliant S3 buckets. Apply the SCP to all OUs in the organization.

部署一个启用组织范围资源数据聚合的 AWS Config 聚合器。创建一个包含 Deny 语句的 SCP，用于阻止创建新的不合规 S3 存储桶。将该 SCP 应用到组织中的所有 OU。

C. Deploy an AWS Config aggregator that scopes only the accounts and Regions that the company currently uses. Create an AWS Lambda function that responds to AWS Config findings of noncompliant S3 buckets by deleting or reconfiguring the S3 buckets.

部署一个 AWS Config 聚合器，其范围仅覆盖公司当前使用的账户和区域。创建一个 AWS Lambda 函数，当 AWS Config 发现不合规的 S3 存储桶时，删除或重新配置这些 S3 存储桶。

D. Deploy an AWS Config aggregator that scopes only the accounts and Regions that the company currently uses. Create an SCP that contains a Deny statement that prevents the creation of new noncompliant S3 buckets. Apply the SCP to all OUs in the organization.

部署一个 AWS Config 聚合器，其范围仅覆盖公司当前使用的账户和区域。创建一个包含 Deny 语句的 SCP，用于阻止创建新的不合规 S3 存储桶。将该 SCP 应用到组织中的所有 OU。

Correct Answer: A

正确答案: A

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

AWS Config 在多账户、多区域 (AWS Organizations) 场景下的合规性治理：组织级别的 AWS Config 规则/聚合器 (Aggregator) 用于跨账户跨区域集中查看合规状态。

自动修复 (Remediation) 思路：对“已存在不合规资源”和“未来新建不合规资源”都要能持续修复 (事件驱动/持续评估 + 自动化修复)。

SCP (Service Control Policy) 的能力边界：SCP用于限制权限/阻止API调用，通常不擅长“确保资源配置满足复杂合规项”，也无法“修复已存在资源”。

2. 独立思考 (不依赖官方答案)

题目要求同时满足两件事：(1) 修复组织内**现有**不合规 S3 Bucket；(2) 对**未来**创建的不合规 S3 Bucket 也能自动修复。

“发现不合规”已经由 AWS Config rules 实现；关键在于“跨账户/跨区域的持续修复机制”。

SCP 的“阻止创建不合规 bucket”在现实中往往难以精确实现 (很多合规项不是在 CreateBucket 时就能强制满足)，且无法修复存量。

3. 逐个选项分析

A. 组织范围聚合器 + Lambda 响应 Config 不合规并删除/重配 优点：

组织范围 (organization-wide) 的聚合器可以跨账户跨区域集中汇总合规状态，满足“多个账户/多个区域”的可视化与统一治理诉求。

用 Lambda 对 AWS Config 的“不合规发现”进行自动化处理，理论上可同时覆盖：- **现有**不合规 bucket (Config评估到后触发修复) - **未来**新建不合规 bucket (创建后被评估为不合规，再触发修复)

注意点/潜在问题 (但不影响本题选项内最优)：

Aggregator 本身主要用于“汇总/查询”，并不会直接触发修复；真正触发通常来自各账户各区域的 Config 评估结果与事件。

跨账户修复需要在成员账户中具备执行权限 (常见做法是 AWS Config Remediation + SSM Automation，或在成员账户部署执行角色/函数)。选项未展开实现细节，但思路符合“自动修复”。

结论：能满足“存量 + 增量”的自动修复目标，是四个选项里最贴近需求的方案。

B. 组织范围聚合器 + SCP Deny 阻止创建新的不合规 bucket 问题：

无法修复现有不合规 bucket：SCP 只能限制权限，不能对已存在资源做配置修正或删除。

难以精确阻止“创建不合规 bucket”：很多 S3 合规项 (如默认加密、阻止公共访问、策略限制等) 通常是 CreateBucket 之后再配置；用 SCP 很难在“创建动作”层面可靠判定并阻止“不合规”。

结论：不满足“修复现有不合规”这一硬性要求，因此不正确。

C. 仅覆盖当前账户与区域的聚合器 + Lambda 自动修复 问题：

题目明确是“多个区域、多个账户”，且还强调 Organizations 场景并要求覆盖未来；仅聚合“当前使用的账户和区域”会带来治理盲区：- 新加入的账户/新启用的区域可能不在聚合范围内，无法保证持续治理的“组织级覆盖”。

虽然 Lambda 自动修复的思路对“存量+增量”是对的，但聚合范围不满足组织级别持续覆盖的要求。

结论：不如 A 满足“组织范围、可持续扩展”的要求。

D. 仅覆盖当前账户与区域的聚合器 + SCP Deny 问题：

同 B：无法修复现有不合规资源。

同 C：范围仅限当前账户/区域，未来扩展可能失控。

同 B：用 SCP 精确阻止“不合规 bucket 创建”不可靠。

结论：不满足题意。

4. 我选择的答案

A

5. 官方答案

A

6. 与官方答案比较与复盘

我的答案：A

官方答案：A

比较结果：一致。

复盘要点：本题核心是“存量+增量的自动修复”与“组织级跨账户跨区域治理”。在给定选项中，只有 A/C 具备自动修复存量与增量的机制；其中 A 采用组织范围聚合更符合 Organizations 的长期治理要求，因此选 A。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #48

Topic 1

A company has contracted with a third party to audit several AWS accounts. To enable the audit, cross-account IAM roles have been created in each account targeted for audit. The auditor is having trouble accessing some of the accounts. Which of the following may be causing this problem? (Choose three.)

一家公司已与第三方签约，对多个 AWS 账户进行审计。为启用审计，已在每个需要审计的目标账户中创建了跨账户 IAM 角色。审计人员在访问其中一些账户时遇到了问题。
以下哪项可能导致此问题？（选择三项。）

A. The external ID used by the auditor is missing or incorrect.
审计人员使用的外部 ID 缺失或不正确。

B. The auditor is using the incorrect password.
审计人员使用了不正确的密码。

C. The auditor has not been granted sts:AssumeRole for the role in the destination account.
审计人员未被授予对目标账户中该角色执行 sts:AssumeRole 的权限。

D. The Amazon EC2 role used by the auditor must be set to the destination account role.
审计人员使用的 Amazon EC2 角色必须设置为目标账户角色。

E. The secret key used by the auditor is missing or incorrect.
审计人员使用的密钥 (secret key) 缺失或不正确。

F. The role ARN used by the auditor is missing or incorrect.
审计人员使用的角色 ARN 缺失或不正确。

Correct Answer: ACF

正确答案: ACF

题目解析：Cross-account 角色假设 (AssumeRole) 审计访问失败原因 (选三)

1. 本题考察的知识点

AWS STS 跨账号访问机制：第三方审计方如何通过 **sts:AssumeRole** 假设目标账号中的 IAM Role。

AssumeRole 成功的关键要素：

调用方（审计方）必须具备对目标 Role 的 **sts:AssumeRole** 权限 (Identity-based policy)。

目标账号 Role 的 **信任策略 (Trust policy)** 必须允许审计方主体 (Principal) 假设该角色。

如果使用第三方 (External) 访问模式，通常需要 **ExternalId** 匹配以防止 confused deputy。

审计方必须使用正确的 **Role ARN** 发起 AssumeRole 请求。

“部分账号无法访问”通常暗示问题是“按账号/按角色配置差异”导致，而不是审计方整体凭证完全不可用。

2. 独立思考（不参考官方答案）

跨账号 AssumeRole 出问题，最常见且会导致“部分账号失败”的原因包括：**ExternalId 不匹配、Role ARN 写错、审计方对某些 Role 未被授权 sts:AssumeRole**（例如审计方策略只允许假设部分 Role）。

密码/密钥错误更像是“完全无法登录/完全无法调用 API”，通常不会表现为“只有部分账号访问不了”（除非审计方对不同账号使用不同凭证，但题干未暗示）。

3. 逐个选项分析

A. The external ID used by the auditor is missing or incorrect.

可能正确。如果目标角色信任策略中使用了 **Condition: sts:ExternalId**，审计方在调用 AssumeRole 时必须提供匹配的 ExternalId；缺失或不匹配会导致 AssumeRole 被拒绝。不同账号的 ExternalId 配置可能不同，因此会出现“部分账号访问失败”。

B. The auditor is using the incorrect password.

错误（不太可能是本题原因）。跨账号审计通常通过 AssumeRole（API/CLI/Console 切换角色）完成；即使是控制台切换角色，也不是靠“目标账号密码”。密码错误通常导致审计方自身无法登录其原始身份，从而应表现为“全部无法访问”，与“部分账号有问题”不匹配。

C. The auditor has not been granted sts:AssumeRole for the role in the destination account.

可能正确。审计方的 IAM 身份策略必须允许对特定 Role ARN 执行 **sts:AssumeRole**。如果审计方策略只允许假设部分角色（例如列表遗漏某些目标 Role ARN），就会造成“部分账号访问失败”。

D. The Amazon EC2 role used by the auditor must be set to the destination account role.

错误。EC2 instance profile role 与第三方审计跨账号 AssumeRole 没有必然关系。审计方可以使用 IAM User / IAM Role / 联邦身份来调用 STS AssumeRole，并不要求“EC2 角色必须设置为目标账号角色”。

E. The secret key used by the auditor is missing or incorrect.

通常错误（就题干语境不优先）。Secret key 错误会导致审计方无法对 AWS API 进行任何签名调用（包括 AssumeRole），通常会影响到所有账号/所有角色，而非“部分账号”。题干没有表明审计方对不同账号使用不同访问密钥，因此不作为最可能原因。

F. The role ARN used by the auditor is missing or incorrect.

可能正确。AssumeRole 必须指定正确的 **RoleArn**。如果某些账号的 Role ARN 填错、角色名不一致、或账号号写错，将导致只对部分账号失败，非常符合题干现象。

4. 我的答案（选三）

A

C

F

5. 官方答案

A、C、F

6. 与官方答案对比与复盘

对比结果：我的答案与官方答案一致（A、C、F）。

复盘要点：

A/F 都是“按账号/按角色配置差异”很容易出现的问题，能自然解释“部分账号无法访问”。

C 体现 AssumeRole 的双向要求之一：调用方必须被授权执行 sts:AssumeRole（否则即便信任策略允许也不行）。

E（secret key 错）更像整体凭证故障，通常会导致全部失败，因此在“选三”中优先级低于 C。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #49

Topic 1

A company uses AWS Organizations to manage its AWS accounts. The company has a development account and a production account. An auditor has requested evidence that the production account workloads are resilient to disruption. The company needs a solution that improves the resilience of each production account workload.

Which solution will meet these requirements?

一家公司使用 AWS Organizations 来管理其 AWS 账户。该公司有一个开发账户和一个生产账户。一名审计员请求提供证据，证明生产账户工作负载对中断具有弹性。公司需要一种解决方案，以提高每个生产账户工作负载的弹性。

哪个解决方案将满足这些要求？

A. Use AWS Audit Manager to create a new assessment based on AWS Operational Best Practices in the production account. After the assessments are finished, provide the auditor with direct access to the reports.

使用 AWS Audit Manager 在生产账户中基于 AWS 运营最佳实践创建一项新的评估。评估完成后，向审计员提供对报告的直接访问权限。

B. Review the architecture by using the AWS Well-Architected Tool. Use the Well-Architected Framework and focus on the Operational Excellence, Security, and Reliability pillars. Document and implement mitigations for the identified risks. Provide the documentation to the auditor.

使用 AWS Well-Architected Tool 评审架构。使用 Well-Architected Framework，并重点关注卓越运营（Operational Excellence）、安全性（Security）和可靠性（Reliability）支柱。记录并实施针对已识别风险的缓解措施。将文档提供给审计员。

C. Use Amazon Inspector with a multi-account environment to assess the production account workloads for vulnerabilities. Create a CIS scan in Amazon Inspector. Configure the CIS scan as a one time scan with Benchmark Level 2. After the scan is finished, download the PDF report and provide the report to the auditor.

在多账户环境中使用 Amazon Inspector 评估生产账户工作负载的漏洞。在 Amazon Inspector 中创建一次 CIS 扫描。将 CIS 扫描配置为一次性扫描，并使用基准级别 2（Benchmark Level 2）。扫描完成后，下载 PDF 报告并将报告提供给审计员。

D. Use the AWS Fault Injection Service to create experiments in the development account for each workload. Adjust the configuration and architecture of the workloads to improve resilience. Run the experiments again. Download the PDF reports and provide the reports to the auditor.

使用 AWS Fault Injection Service 在开发账户中为每个工作负载创建实验。调整工作负载的配置和架构以提高弹性。再次运行实验。下载 PDF 报告并将报告提供给审计员。

Correct Answer: B

正确答案: B

题目解析：生产账户工作负载对“中断/故障”的弹性与证据

1. 考察的知识点

AWS Well-Architected Framework / Well-Architected Tool在“可靠性（Reliability）”与“运营卓越（Operational Excellence）”等支柱下，用系统化方法识别与整改弹性风险，并能产出可审计的材料。

“弹性（resilient to disruption）”强调**架构设计与运行机制**（冗余、故障隔离、自动恢复、变更管理、监控告警、容量与故障演练等），而不仅是漏洞/合规扫描。

区分：**合规证据**（Audit Manager）、**漏洞与基线**（Inspector/CIS）、**故障演练**（FIS）与**架构最佳实践整改**（Well-Architected）。

2. 独立思考（不参考官方答案）

审计员要的是“生产工作负载对中断有韧性”的证据，并且公司需要一个能**提升每个生产工作负载韧性**的方案。

最能系统性提升韧性、并提供可审计文档的做法通常是：对生产工作负载进行**Well-Architected 评审**，重点在可靠性（以及与可靠性强相关的运营卓越/安全），并将发现与整改形成证据。

FIS 可以作为“验证韧性”的手段，但题目要求“提升每个生产工作负载韧性”的通用方案，并且选项把实验放在开发账户，证据与生产韧性之间存在断层。

3. 逐个选项分析

A. AWS Audit Manager + Operational Best Practices assessment 结论：不优/不满足核心诉求

问题点1：Audit Manager主要用于**合规与审计取证**（收集证据、映射控制项），并不等同于对“抗中断韧性”的架构改进方法。

问题点2：“Operational Best Practices”评估更偏控制项/流程证据，不能直接、全面地覆盖可靠性架构改进（多AZ、多Region策略、故障域隔离、自动恢复等）。

问题点3：“给审计员直接访问报告”也可能带来权限与数据暴露风险（虽然不一定是本题重点）。

B. Well-Architected Tool评审，聚焦Operational Excellence/Security/Reliability并整改 结论：满足要求（最佳）

为什么能提升韧性：Well-Architected的**Reliability pillar**系统覆盖弹性关键点：故障恢复、工作负载架构冗余、变更管理、监控与事件响应、容量管理、自动化恢复等。

为什么能给出证据：评审输出的风险项、改进计划与整改记录可以形成**可审计文档**，用于向审计员证明已识别并缓解导致中断的风险。

为什么选择同时关注OE/Security：运营卓越与安全与可靠性强相关（例如可观测性、变更与发布流程、权限边界与误操作风险控制），能提升整体抗扰动能力。

C. Amazon Inspector + CIS Level 2一次性扫描并给PDF 结论：不满足

问题点1：Inspector重点在**漏洞管理**（CVE、包漏洞、配置暴露等）与部分基线检查；CIS是**安全配置基线**，并非“工作负载对中断的可靠性/韧性”。

问题点2：一次性扫描无法体现持续韧性改进与架构整改闭环，也不能覆盖多AZ容灾、故障切换、恢复演练等可靠性要点。

问题点3：即使扫描结果很好，也只能说明“较安全/较符合基线”，不能证明“抗中断韧性”。

D. 在开发账户用AWS Fault Injection Service做实验并提供PDF 结论：部分相关但整体不满足题意（尤其是“生产账户工作负载韧性证据”）

优点：FIS属于混沌工程/故障注入，确实能帮助发现系统在故障条件下的薄弱点，从而改进韧性。

问题点1（关键）：题目审计员要的是**生产账户工作负载韧性**证据；选项明确在**开发账户**做实验，无法严格证明生产环境同等配置与控制下的韧性。

问题点2：并非对“每个生产工作负载”的通用治理框架；而且很多韧性要求是架构与运维机制层面的系统性整改，通常需要与可靠性最佳实践框架结合。

补充：如果选项是“在生产或与生产等价的预生产环境、以与生产一致的IaC/配置进行FIS演练并形成整改闭环”，会更接近满足，但本选项的“开发账户”削弱了证据有效性。

4. 我选择的答案

B

5. 官方答案

B

6. 与官方答案对比与复盘

对比结果：我的答案与官方答案一致，都是B。

原因总结：B是唯一同时满足“提升每个生产工作负载韧性（通过可靠性支柱识别并整改风险）”与“向审计员提供可接受的证据（评审与整改文档）”的选项；A/C偏合规/安全扫描，D虽与韧性演练相关但在开发账户进行，难以作为生产韧性的直接证据。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #50

Topic 1

A company is migrating one of its legacy systems from an on-premises data center to AWS. The application server will run on AWS, but the database must remain in the on-premises data center for compliance reasons. The database is sensitive to network latency. Additionally, the data that travels between the on-premises data center and AWS must have IPsec encryption. Which combination of AWS solutions will meet these requirements? (Choose two.)

一家公司正在将其某个遗留系统从本地数据中心迁移到 AWS。应用程序服务器将在 AWS 上运行，但由于合规性原因，数据库必须保留在本地数据中心。该数据库对网络延迟非常敏感。此外，在本地数据中心与 AWS 之间传输的数据必须具有 IPsec 加密。哪种 AWS 解决方案组合将满足这些要求？（选择两项。）

A. AWS Site-to-Site VPN
AWS Site-to-Site VPN

B. AWS Direct Connect
AWS Direct Connect

C. AWS VPN CloudHub
AWS VPN CloudHub

D. VPC peering
VPC 对等连接

E. NAT gateway
NAT 网关

Correct Answer: AB

正确答案: AB

题目解析：混合云连接（低延迟 + IPsec 加密）

1. 本题考察的知识点

AWS 混合云网络连接方案选型：在应用在 AWS、数据库在本地的数据中心场景下，如何可靠连接两端网络。

低延迟链路：数据库对网络延迟敏感，需要相对稳定、低抖动的连接方式。

IPsec 加密要求：跨公网/跨链路传输数据必须使用 IPsec 加密。

Direct Connect 与 VPN 叠加 (VPN over Direct Connect)：Direct Connect 提供专线质量，VPN 提供 IPsec 加密。

2. 独立思考（不参考官方答案）

需求拆解：1) AWS 应用服务器与本地数据库通信；2) 数据库对延迟敏感 ⇒ 优先考虑 **AWS Direct Connect**；3) 传输必须 **IPsec 加密** ⇒ 需要 **AWS Site-to-Site VPN** (IPsec VPN)。

Direct Connect 本身不提供 IPsec；要满足“必须 IPsec 加密”，通常做法是在 Direct Connect 之上建立 Site-to-Site VPN（或使用第三方加密设备，但题目限定“组合 AWS 方案”）。

3. 逐个选项分析

A. AWS Site-to-Site VPN 正确（但单独不够）：

提供 IPsec 加密，满足“必须 IPsec”这一硬性要求。

但单独使用通常是走公网隧道，延迟与抖动不可控；对“数据库对延迟敏感”的要求可能不够理想。

与 Direct Connect 组合（VPN over DX）可以同时满足“低延迟/稳定性”与“IPsec 加密”。

B. AWS Direct Connect 正确（但单独不够）：

提供专线/专用网络路径，通常带来 **更低延迟、更稳定的吞吐与更少抖动**，满足“数据库对延迟敏感”。

但 **Direct Connect 默认不提供 IPsec 加密**；题目明确要求“必须有 IPsec 加密”，因此需要叠加 VPN。

C. AWS VPN CloudHub 错误：

VPN CloudHub 主要用于通过 AWS 作为 hub 来连接 **多个站点**（多分支互联）场景。

题目是单一数据中心到 AWS 的迁移与连接需求，不需要多站点 hub-and-spoke 架构。

即使可提供 IPsec，它也无法比“Direct Connect + VPN”更好地解决低延迟诉求。

D. VPC peering（VPC 对等连接）错误：

VPC Peering 仅用于 **AWS 内部**（VPC 与 VPC）互联，不用于连接到本地数据中心。

无法满足“本地数据中心 ↔ AWS”的连接，更谈不上 IPsec。

E. NAT gateway（NAT 网关）错误：

NAT Gateway 用于让私有子网实例进行 **出站访问互联网**（源地址转换）。

不提供站点到站点专线/隧道能力，也不提供 IPsec 加密，更无法满足低延迟专线需求。

4. 我选择的答案

A + B（AWS Site-to-Site VPN + AWS Direct Connect）

5. 官方答案

A + B

6. 与官方答案比较与复盘

结论：与官方答案一致（AB）。

原因：

Direct Connect 解决低延迟与稳定性；

Site-to-Site VPN 提供 IPsec 加密；

两者组合（VPN over Direct Connect）同时满足题目两个硬性要求。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #51

Topic 1

A company has enabled AWS Config for its organization in AWS Organizations. The company has deployed hundreds of Amazon S3 buckets across the organization.

A security engineer needs to identify any S3 buckets that are not encrypted with AWS Key Management Service (AWS KMS). The security engineer also must prevent objects that are not encrypted with AWS KMS from being uploaded to the S3 buckets. Which solution will meet these requirements?

一家公司已在 AWS Organizations 中为其组织启用了 AWS Config。该公司已在整个组织中部署了数百个 Amazon S3 存储桶。一名安全工程师需要识别任何未使用 AWS Key Management Service (AWS KMS) 加密的 S3 存储桶。该安全工程师还必须阻止未使用 AWS KMS 加密的对象被上传到这些 S3 存储桶。哪种解决方案将满足这些要求?

A. Use the s3-default-encryption-kms AWS Config managed rule to identify unencrypted S3 buckets. Create an SCP to allow the s3:PutObject action only when the object is encrypted with AWS KMS.

使用 s3-default-encryption-kms AWS Config 托管规则来识别未加密的 S3 存储桶。创建一个 SCP，仅当对象使用 AWS KMS 加密时才允许执行 s3:PutObject 操作。

B. Use the s3-default-encryption-kms AWS Config managed rule to identify unencrypted S3 buckets. Create bucket policies for each S3 bucket to deny the s3:PutObject action only when the object has server-side encryption with S3 managed keys (SSE-S3).

使用 s3-default-encryption-kms AWS Config 托管规则来识别未加密的 S3 存储桶。为每个 S3 存储桶创建存储桶策略，仅当对象具有使用 S3 托管密钥的服务器端加密 (SSE-S3) 时才拒绝 s3:PutObject 操作。

C. Use the s3-bucket-ssl-requests-only AWS Config managed rule to identify unencrypted S3 buckets. Create an SCP to allow the s3:PutObject action only when the object is encrypted with AWS KMS.

使用 s3-bucket-ssl-requests-only AWS Config 托管规则来识别未加密的 S3 存储桶。创建一个 SCP，仅当对象使用 AWS KMS 加密时才允许执行 s3:PutObject 操作。

D. Use the s3-bucket-ssl-requests-only AWS Config managed rule to identify unencrypted S3 buckets. Create bucket policies for each S3 bucket to allow the s3:PutObject action only when the object is encrypted with AWS KMS.

使用 s3-bucket-ssl-requests-only AWS Config 托管规则来识别未加密的 S3 存储桶。为每个 S3 存储桶创建存储桶策略，仅当对象使用 AWS KMS 加密时才允许执行 s3:PutObject 操作。

Correct Answer: A

正确答案: A

题目解析 (AWS Certified Security – Specialty SCS-C03)

1. 本题考察的知识点

AWS Config 组织级 (Organization) 启用后的合规审计能力：使用 AWS Config 托管规则在全组织范围识别不合规资源 (S3 默认加密是否为 SSE-KMS)。

S3 加密强制 (SSE-KMS)：如何强制上传对象必须使用 AWS KMS (SSE-KMS)。

Organizations SCP 的使用边界：用 SCP 在组织/OU/账号层面限制成员账号主体 (IAM 用户/角色) 可执行的 API 行为 (例如 PutObject 必须带特定加密条件)。

2. 独立思考 (不参考官方答案)

需求分两部分：

- (1) 识别哪些 S3 bucket **未使用 AWS KMS 做默认加密** (bucket-level default encryption)。
- (2) 防止上传不使用 **SSE-KMS** 加密的对象。

识别层面最贴切的托管规则是 **s3-default-encryption-kms** (注意题干/选项里可能有拼写错误)。

阻止不合规上传，通常可以用 **Bucket Policy 显式 Deny** 或用 **SCP 在组织层面做强制**。本题强调“已为组织启用 AWS Config”且“有数百个 bucket”，因此更倾向于用 **组织级可规模化的控制 (SCP)** 来避免逐桶维护策略。

3. 逐个选项分析

A. 使用 s3-default-encryption-kms 识别；用 SCP 仅允许 SSE-KMS 的 PutObject

识别部分：正确

AWS Config 托管规则 s3-default-encryption-kms用于检查 S3 bucket 是否把默认加密设置为 **SSE-KMS** (AWS KMS)。

题干要求“identify any S3 buckets that are not encrypted with AWS KMS”，对应的就是 bucket 默认加密未启用 SSE-KMS。

防止不合规上传部分：总体正确 (概念正确，表述略不严谨)

SCP 可用于在组织/OU/账号层面限制 **s3:PutObject**，通过条件键要求请求必须声明 SSE-KMS (例如基于 **s3:x-amz-server-side-encryption** 等条件)。

严格来说，SCP 实际上是“设置权限上限”，常见写法是通过 **显式 Deny** 实现“除非满足条件否则拒绝”，而不是字面“allow only when”。但在考试语境中，该选项表达的控制目标是可实现的。

优点：**组织级一次性下发**，适合数百 bucket 的规模；不需要逐桶维护 bucket policy。

结论：满足题意

B. 使用 s3-default-encryption-kms 识别；每个 bucket policy 在对象为 SSE-S3 时才 deny PutObject

识别部分：正确

防止不合规上传部分：错误

题目要求必须使用 **AWS KMS (SSE-KMS)**，而该选项写的是“对象使用 **SSE-S3** 时才拒绝”。这与目标完全相反且逻辑也不完整：

正确的 bucket policy 思路应是：**Deny** 当请求未指定 SSE-KMS (例如未带 SSE 头或指定了 AES256/SSE-S3)。

此外，“为每个 bucket 创建策略”在规模上也较繁琐，但即便不谈规模，该选项的加密类型要求就已不满足题意。

结论：不满足

C. 使用 s3-bucket-ssl-requests-only 识别；用 SCP 强制 SSE-KMS

识别部分：错误

s3-bucket-ssl-requests-only检查的是是否只允许 SSL/TLS (HTTPS) 访问 S3，而不是检查是否启用 SSE-KMS 默认加密。

防止不合规上传部分：方向正确 (SCP 可用于组织级限制 PutObject 加密条件)

结论：由于识别用错规则，不满足

D. 使用 s3-bucket-ssl-requests-only 识别；每个 bucket policy 仅当 SSE-KMS 才 allow PutObject

识别部分：错误 (同 C，SSL 规则不等于 KMS 加密合规检查)

防止不合规上传部分：不严谨/有风险

在 S3 权限模型中，最佳实践通常是用 **显式 Deny** 来强制 (例如 deny 未使用 aws:kms 的 PutObject)，而不是依赖“只写 allow”。

因为可能仍存在其他允许来源导致绕过 (例如其他语句允许、ACL/其他策略组合等)。

并且该选项要求“为每个 bucket 创建 policy”，在数百 bucket 规模下运维成本高。

结论：不满足

4. 我选择的答案

A

5. 官方答案

A

6. 与官方答案对比与复盘

我的答案与官方答案一致：A

A 的 Config 托管规则与需求（识别未启用 SSE-KMS 默认加密的 bucket）直接匹配。

A 使用 SCP 做组织级强制控制，符合“组织内数百 bucket”的规模化治理思路。

需要注意的是：SCP 实现时通常用**显式 Deny + 条件**来表达“除非使用 SSE-KMS 否则拒绝 PutObject”，选项文字用“allow only when”在措辞上不够严谨，但不影响其作为正确解的考试意图。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #52

Topic 1

A company runs an application on a fleet of Amazon EC2 instances. The company can remove instances from the fleet without risk to the application. All EC2 instances use the same security group named ProdFleet. Amazon GuardDuty and AWS Config are active in the company's AWS account.

A security engineer needs to provide a solution that will prevent an EC2 instance from sending outbound traffic if GuardDuty generates a cryptocurrency finding event. The security engineer creates a new security group named isolate that contains no outbound rules. The security engineer configures an AWS Lambda function to remove an EC2 instance from the ProdFleet security group and add it to the isolate security group.

Which additional step will meet this requirement?

一家公司在—组 Amazon EC2 实例上运行一个应用程序。公司可以在不对应用程序造成风险的情况下，从该实例组中移除实例。所有 EC2 实例都使用同一个名为 ProdFleet 的安全组。Amazon GuardDuty 和 AWS Config 在公司的 AWS 账户中处于启用状态。一名安全工程师需要提供一种解决方案，用于在 GuardDuty 生成加密货币相关的发现事件时，阻止某个 EC2 实例发送出站流量。该安全工程师创建了一个名为 isolate 的新安全组，该安全组不包含任何出站规则。该安全工程师配置了一个 AWS Lambda 函数，用于将某个 EC2 实例从 ProdFleet 安全组中移除，并将其添加到 isolate 安全组中。还需要执行哪一项附加步骤才能满足此要求？

A. Configure GuardDuty to directly invoke the Lambda function if GuardDuty generates a CryptoCurrency:EC2/* finding event.
配置 GuardDuty 在 GuardDuty 生成 CryptoCurrency:EC2/* 发现事件时直接调用该 Lambda 函数。

B. Configure an AWS Config rule that invokes the Lambda function if a CryptoCurrency:EC2/* configuration change event occurs for an EC2 instance.
配置一个 AWS Config 规则，在某个 EC2 实例发生 CryptoCurrency:EC2/* 配置更改事件时调用该 Lambda 函数。

C. Configure an Amazon EventBridge rule that invokes the Lambda function if GuardDuty generates a CryptoCurrency:EC2/* finding event.
配置一条 Amazon EventBridge 规则，在 GuardDuty 生成 CryptoCurrency:EC2/* 发现事件时调用该 Lambda 函数。

D. Configure an Amazon EventBridge rule that invokes the Lambda function if AWS Config detects a CryptoCurrency:EC2/* configuration change event for an EC2 instance.
配置一条 Amazon EventBridge 规则，在 AWS Config 检测到某个 EC2 实例发生 CryptoCurrency:EC2/* 配置更改事件时调用该 Lambda 函数。

Correct Answer: C

正确答案: C

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

Amazon GuardDuty Finding 事件的触发与自动化响应：GuardDuty 产生某类 Finding（如 CryptoCurrency:EC2/*）后，如何自动触发处置动作。

Amazon EventBridge 与 GuardDuty 的集成：GuardDuty Finding 会发布到 EventBridge（默认事件总线），可用 EventBridge 规则匹配并触发 Lambda。

隔离受感染 EC2 的网络策略：通过调整安全组（从 ProdFleet 移除并加入无出站规则的 isolate）实现“阻断出站流量”。

识别错误信号源（AWS Config）：AWS Config 主要用于资源配置合规/变更记录，不会产生“CryptoCurrency:EC2/* Finding”。

2. 独立思考（不参考官方答案）

要“在 GuardDuty 生成 cryptocurrency finding 事件时”自动调用 Lambda，最标准的做法是：

GuardDuty Finding → 发送到 EventBridge → EventBridge Rule 匹配 finding type → 触发 Lambda → Lambda 修改安全组。

GuardDuty 本身不属于“直接调用 Lambda”的服务形态；AWS Config 也不会生成 GuardDuty Finding 类型事件。

因此需要补充的关键一步应是：**创建 EventBridge 规则来捕获 GuardDuty Finding 并触发 Lambda。**

3. 逐个分析选项

A. 配置 GuardDuty 直接调用 Lambda 结论：错误 原因：GuardDuty 的 Finding 会被发布到 **Amazon EventBridge**（以及可选导出到 S3 等），常见模式是“EventBridge 规则触发 Lambda”。GuardDuty 并没有“直接把 Finding 作为触发器调用某个 Lambda”的原生配置项（不像某些服务提供直接目标集成那样）。

B. 配置 AWS Config rule，出现 CryptoCurrency:EC2/* configuration change 时调用 Lambda 结论：错误 原因：

“CryptoCurrency:EC2/*”是 **GuardDuty Finding Type**，不是 AWS Config 的“配置变更事件”。

AWS Config rule 的触发基于资源配置快照/变更或周期评估，并不理解/产生 GuardDuty Finding 类型。

C. 配置 EventBridge rule，在 GuardDuty 生成 CryptoCurrency:EC2/* finding 时调用 Lambda 结论：正确 原因：GuardDuty Finding 会发到 **Amazon EventBridge**，可用事件模式（event pattern）匹配：

source: aws.guarddduty

detail-type: GuardDuty Finding

detail.type: CryptoCurrency:EC2/*（或匹配前缀）

然后将 Lambda 作为规则 Target，从而在检测到挖矿相关 Finding 时自动隔离实例（修改安全组以阻止出站）。

D. 配置 EventBridge rule，在 AWS Config 检测到 CryptoCurrency:EC2/* configuration change 时调用 Lambda 结论：错误 原因：

AWS Config 不会“检测到 CryptoCurrency:EC2/*”这种类型；这是 GuardDuty Finding 的命名体系。

即使 EventBridge 能接收 Config 事件，其事件也不会以 GuardDuty Finding type 的方式表达。

4. 我选择的答案

C

5. 官方答案

C

6. 与官方答案对比与复盘

对比结果：一致（都选 C）

复盘原因：满足“GuardDuty 生成特定 Finding 事件即触发自动化动作”的正确事件驱动链路是 GuardDuty → EventBridge → Lambda；AWS Config 不产生该类 Finding，GuardDuty 也不以“直接调用 Lambda”作为主要集成方式。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #53

Topic 1

A company uses Amazon EC2 instances to host frontend services behind an Application Load Balancer. Amazon Elastic Block Store (Amazon EBS) volumes are attached to the EC2 instances. The company uses Amazon S3 buckets to store large files for images and music.

The company has implemented a security architecture on AWS to prevent, identify, and isolate potential ransomware attacks. The company now wants to further reduce risk.

A security engineer must develop a disaster recovery solution that can recover to normal operations if an attacker bypasses preventive and detective controls. The solution must meet an RPO of 1 hour.

Which solution will meet these requirements?

一家公司使用 Amazon EC2 实例在 Application Load Balancer 后面托管前端服务。Amazon Elastic Block Store (Amazon EBS) 卷已挂载到 EC2 实例。该公司使用 Amazon S3 存储桶来存储用于图像和音乐的大文件。

该公司已在 AWS 上实施了一种安全架构，用于防止、识别并隔离潜在的勒索软件攻击。该公司现在希望进一步降低风险。

安全工程师必须制定一个灾难恢复解决方案，如果攻击者绕过预防性和侦测性控制，该解决方案能够恢复到正常运行。该解决方案必须满足 1 小时的 RPO。

哪个解决方案将满足这些要求？

A. Use AWS Backup to create backups of the EC2 instances and S3 buckets every hour. Create AWS CloudFormation templates that replicate existing architecture components. Use AWS CodeCommit to store the CloudFormation templates alongside application configuration code.

使用 AWS Backup 每小时为 EC2 实例和 S3 存储桶创建备份。创建 AWS CloudFormation 模板以复制现有架构组件。使用 AWS CodeCommit 将 CloudFormation 模板与应用程序配置代码一起存储。

B. Use AWS Backup to create backups of the EBS volumes and S3 objects every day. Use Amazon Security Lake to create a centralized data lake for AWS CloudTrail logs and VPC flow logs. Use the logs for automated response.

使用 AWS Backup 每天为 EBS 卷和 S3 对象创建备份。使用 Amazon Security Lake 为 AWS CloudTrail 日志和 VPC 流日志创建一个集中式数据湖。使用这些日志进行自动化响应。

C. Use Amazon Security Lake to create a centralized data lake for AWS CloudTrail logs and VPC flow logs. Use the logs for automated response. Enable AWS Security Hub to establish a single location for recovery procedures. Create AWS CloudFormation templates that replicate existing architecture components. Use AWS CodeCommit to store the CloudFormation templates alongside application configuration code.

使用 Amazon Security Lake 为 AWS CloudTrail 日志和 VPC 流日志创建一个集中式数据湖。使用这些日志进行自动化响应。启用 AWS Security Hub 以建立一个用于恢复过程的单一位置。创建 AWS CloudFormation 模板以复制现有架构组件。使用 AWS CodeCommit 将 CloudFormation 模板与应用程序配置代码一起存储。

D. Create EBS snapshots every 4 hours. Enable Amazon GuardDuty Malware Protection. Create automation to immediately restore the most recent snapshot for any EC2 instances that produce an Execution:EC2/MaliciousFile finding in GuardDuty. 每 4 小时创建一次 EBS 快照。启用 Amazon GuardDuty 恶意软件防护。创建自动化流程，以便对在 GuardDuty 中产生 Execution:EC2/MaliciousFile 发现的任何 EC2 实例立即还原最近的快照。

Correct Answer: A

正确答案：A

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

勒索软件 (Ransomware) 场景下的灾难恢复 (Disaster Recovery, DR)：当预防与检测都被绕过时，如何恢复业务到“正常运行”。

RPO (Recovery Point Objective)：允许的数据丢失窗口。本题要求RPO=1小时，意味着至少需要每小时可用的可恢复点。

备份范围覆盖：题干包含 EC2 (含EBS卷)、以及 S3 (图片/音乐大文件)。DR方案应同时覆盖**计算数据 (EBS/EC2) + 对象数据 (S3)**。

基础设施可重建能力 (IaC)：恢复不仅是“恢复数据”，还要能快速重建架构组件 (如ALB/EC2等)。

2. 独立思考 (不参考官方答案)

要满足RPO 1小时，备份频率至少要做到**每小时** (或提供接近小时级别的恢复点)。

方案需要从勒索软件破坏中恢复：至少要有可用备份 (EBS/EC2 与 S3)，并能重建基础设施。

在给定选项中，只有包含**每小时备份**且同时覆盖**EC2/EBS + S3**并提到**重建架构**的方案，才可能满足要求。

3. 逐个分析选项

A. 每小时用 AWS Backup 备份 EC2 和 S3；用 CloudFormation 复制架构；CodeCommit 存模板与配置

正确点 (满足RPO)：每小时备份 => 恢复点间隔≤1小时，符合RPO=1小时。

覆盖面完整：

EC2备份通常会落到其相关的EBS快照/AMI等恢复能力 (具体取决于AWS Backup策略与资源类型支持)，可用于恢复实例数据。

S3也被纳入备份范围，可从对象被加密/删除/篡改中恢复到小时级恢复点。

可恢复到“正常运行”：CloudFormation 模板用于快速重建 ALB/EC2/网络/安全组等架构组件；CodeCommit保存模板与配置代码，便于版本化与快速回滚。

潜在不足 (但选项中已是最佳)：题目未要求但现实中常见的强化点包括跨账户/跨区域备份、Backup Vault Lock/WORM、与最小权限隔离等；不过在给定选项里，A已最符合题意。

结论：该选项满足RPO并提供端到端恢复能力，**正确**。

B. 每天备份 EBS 与 S3；Security Lake集中日志用于自动响应

错误点 (不满足RPO)：每天备份 => 最坏情况下可能丢失接近24小时数据，**不满足RPO=1小时**。

侧重点偏检测/响应：Security Lake 主要是日志集中与分析，不是备份/恢复手段；即使能自动响应，也不能替代小时级恢复点。

结论：错误 (RPO直接失败)。

C. Security Lake + 自动响应；Security Hub作为恢复流程单一位置；CloudFormation+CodeCommit

错误点 (没有备份)：没有提供任何EC2/EBS/S3的数据备份或可恢复点，无法在“攻击者绕过预防与检测控制”后保证数据可恢复。

Security Hub 不用于“建立恢复程序单一位置”：Security Hub是安全发现聚合与合规检查，不是DR编排与恢复介质；即便有IaC，没有数据也无法恢复业务数据完整性。

结论：错误 (缺少满足RPO的备份与恢复点)。

D. 每4小时EBS快照；GuardDuty Malware Protection；发现恶意文件立即回滚最近快照

错误点 (不满足RPO)：每4小时快照 => 最坏情况丢失4小时数据，**不满足RPO=1小时**。

覆盖范围不足：仅提EBS快照，没有涵盖题干明确提到的**S3大文件** (图片/音乐对象数据同样可能被加密/删除)。

恢复策略风险：检测到恶意文件就“立即恢复最近快照”并不总能保证回到“正常运行”：

最近快照可能已包含加密后的数据或潜伏恶意内容 (取决于感染时间与快照周期)。

仅凭单一发现类型触发恢复，容易误触发或无法覆盖所有加密/破坏路径。

结论：错误 (RPO失败且未覆盖S3)。

4. 我选择的答案

A

5. 官方答案

A

6. 与官方答案对比与复盘

我的答案：A

官方答案：A

一致。原因：A是唯一同时满足RPO=1小时（每小时备份）、同时覆盖EC2/EBS与S3，并提供基础设施可重建（CloudFormation）的选项。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #54

Topic 1

A company uses AWS IAM Identity Center to manage access to its AWS accounts. The accounts are in an organization in AWS Organizations.

A security engineer needs to set up delegated administration of IAM Identity Center in the organization's management account. Which combination of steps should the security engineer perform in IAM Identity Center before configuring delegated administration? (Choose three.)

一家公司使用 AWS IAM Identity Center 来管理对其 AWS 账户的访问。这些账户位于 AWS Organizations 中的一个组织内。一名安全工程师需要在该组织的管理账户中设置 IAM Identity Center 的委派管理。在配置委派管理之前，安全工程师应在 IAM Identity Center 中执行以下哪些步骤组合？（选择三项。）

A. Grant least privilege access to the organization's management account.
向组织的管理账户授予最小权限访问。

B. Create a new IAM Identity Center directory in the organization's management account.
在组织的管理账户中创建一个新的 IAM Identity Center 目录。

C. Set up a second AWS Region in the organization's management account.
在组织的管理账户中设置第二个 AWS 区域。

D. Create permission sets for use only in the organization's management account.
创建仅用于组织的管理账户的权限集。

E. Create IAM users for use only in the organization's management account.
创建仅用于组织的管理账户的 IAM 用户。

F. Create user assignments only in the organization's management account.
仅在组织的管理账户中创建用户分配。

Correct Answer: BDF

正确答案: BDF

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点是什么？

AWS IAM Identity Center (原 AWS SSO) 与 AWS Organizations 的集成: 在组织 (Organization) 中启用与管理 IAM Identity Center。

Delegated administration (委派管理) 前置条件: 在管理账户 (management account) 中需要先完成哪些 IAM Identity Center 内的基础配置，才能将管理能力委派给成员账户 (delegated administrator account)。

管理账户的特殊限制：委派后，某些与管理账户相关的 IAM Identity Center 配置（尤其是对管理账户本身的分配）通常仍需要在管理账户侧完成。

2. 独立思考（不参考官方答案）

题干强调：“在配置 delegated administration 之前，在 IAM Identity Center 里需要做哪些步骤”，因此应选择那些属于 IAM Identity Center 内的配置动作，并且与“管理账户在委派后不能/不便被委派管理员管理的内容”相关。

一般需要先在管理账户所在区域完成 IAM Identity Center 的启用与基础对象创建（例如目录/身份源、权限集、以及对管理账户的分配），再去做委派管理员注册。

3. 逐个选项分析（为什么对/错）

A. Grant least privilege access to the organization's management account. 结论：**错误** 原因：这是 IAM 权限/访问控制层面的最佳实践描述，但题目问的是“在 IAM Identity Center 中”要做的步骤；该选项并不是 IAM Identity Center 内的特定前置配置步骤，且表述过于泛化，无法作为委派管理的必要前置条件。

B. Create a new IAM Identity Center directory in the organization's management account. 结论：**正确** 原因：在组织中进行 IAM Identity Center 委派管理前，管理账户需要先**启用/初始化 IAM Identity Center**并确定身份源（常见是默认的 IAM Identity Center directory，或外部身份源）。没有目录/身份源与实例的基础配置，后续无法进行组织级的委派管理配置。

C. Set up a second AWS Region in the organization's management account. 结论：**错误** 原因：IAM Identity Center 是**区域级 (Regional)** 服务，但“配置第二个区域”不是委派管理的必要前置条件；委派管理关注的是组织集成与管理权限委派，而不是多区域部署。

D. Create permission sets for use only in the organization's management account. 结论：**正确** 原因：委派管理后，委派管理员通常可以管理成员账户范围内的权限集与分配，但**管理账户 (management account) 相关的访问往往需要管理账户侧先行准备**。为确保管理账户可通过 IAM Identity Center 正常被授权访问（例如给安全团队/管理员访问管理账户的控制台权限），应在委派前先准备好供管理账户使用的 permission sets。

E. Create IAM users for use only in the organization's management account. 结论：**错误** 原因：IAM Identity Center 的目标是集中式身份与访问管理，通常不建议为此再创建 IAM users；且该动作不属于“在 IAM Identity Center 中”的前置步骤，也不是配置委派管理的必要条件。

F. Create user assignments only in the organization's management account. 结论：**正确** 原因：管理账户在委派管理场景下通常存在管理边界：**对管理账户本身的用户/组到 AWS 账户的分配 (assignments) 往往需要在管理账户侧完成**，委派管理员主要面向成员账户进行集中管理。因此，在委派前先把“管理账户需要的访问分配”配置好，是符合服务行为与运维可行性的关键前置步骤。

4. 我选择的答案

B、D、F

5. 官方答案

B、D、F

6. 与官方答案对比与复盘

我的答案：**BDF**

官方答案：**BDF**

对比结论：**一致**

复盘要点：本题核心在于识别“委派前必须在管理账户的 IAM Identity Center 中先完成的基础配置”，尤其是**管理账户自身的 permission set 与 assignment**需要先准备好，避免委派后因管理边界导致对管理账户授权管理受限。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #55

Topic 1

A company finds that one of its Amazon EC2 instances suddenly has a high CPU usage. The company does not know whether the EC2 instance is compromised or whether the operating system is performing background cleanup.

Which combination of steps should a security engineer take before investigating the issue? (Choose three.)

一家公司发现其一台 Amazon EC2 实例突然出现高 CPU 使用率。公司不知道该 EC2 实例是否已被入侵，或者是否是操作系统正在执行后台清理。

在调查该问题之前，安全工程师应采取哪些步骤组合？（选择三个。）

A. Disable termination protection for the EC2 instance if termination protection has not been disabled.
如果尚未禁用终止保护，则为该 EC2 实例禁用终止保护。

B. Enable termination protection for the EC2 instance if termination protection has not been enabled.
如果尚未启用终止保护，则为该 EC2 实例启用终止保护。

C. Take snapshots of the Amazon Elastic Block Store (Amazon EBS) data volumes that are attached to the EC2 instance.
对附加到该 EC2 实例的 Amazon Elastic Block Store (Amazon EBS) 数据卷进行快照。

D. Remove all snapshots of the Amazon Elastic Block Store (Amazon EBS) data volumes that are attached to the EC2 instance.
删除附加到该 EC2 实例的 Amazon Elastic Block Store (Amazon EBS) 数据卷的所有快照。

E. Capture the EC2 instance metadata, and then tag the EC2 instance as under quarantine.
捕获 EC2 实例元数据，然后将该 EC2 实例标记为处于隔离状态。

F. Immediately remove any entries in the EC2 instance metadata that contain sensitive information.
立即删除 EC2 实例元数据中包含敏感信息的任何条目。

Correct Answer: BCE

正确答案: BCE

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

EC2疑似入侵事件的处置流程 (Incident Response)：在开始深入调查前，先做证据保全与防止证据被破坏。

证据保全 (Forensics Readiness)：对磁盘做EBS快照、记录实例上下文（实例元数据/实例信息）以便后续取证与还原。

防止误操作导致证据丢失：启用终止保护 (termination protection) 避免实例被误删。

隔离/标记流程：对可疑实例进行“隔离中/待隔离”的标记，便于协同响应与自动化流程（例如基于标签触发隔离Runbook）。

2. 独立思考（不依赖官方答案）

在“不确定是被入侵还是系统后台任务”的情况下，调查前最重要的是：**先保全现场（磁盘快照/关键信息记录），并降低人为误删风险（终止保护）。**

题目问“before investigating”，因此选择应偏向：**先做不可逆损失的预防与取证准备**，而不是清理或删除任何内容。

3. 逐个选项分析

A. Disable termination protection（禁用终止保护） 错误。原因：在事件响应早期，禁用终止保护会增加实例被误终止的风险，从而导致证据丢失；与“调查前先保全证据”的目标相反。

B. Enable termination protection（启用终止保护） 正确。原因：防止调查期间/处置期间实例被误终止或被自动化误删，降低证据丢失风险。终止保护是典型的“先把现场锁住”的动作之一。

C. Take snapshots of EBS volumes（对EBS卷做快照） 正确。原因：EBS快照是核心证据保全手段，可用于后续离线取证（挂载到隔离取证实例分析日志、恶意文件、持久化机制等）。调查前先快照可以避免后续操作改变磁盘状态导致证据污染。

D. Remove all snapshots（删除所有快照） 错误。原因：删除快照是破坏证据的行为，与取证和审计相冲突；也会降低恢复能力。

E. Capture instance metadata and tag as under quarantine（捕获元数据并打隔离标签） 正确。原因：记录实例的关键信息（例如实例ID、AMI、IAM实例角色、私有IP/公有IP、SG、子网、路由、挂载卷、启动时间等）有助于后续关联调查与时间线还原；“隔离”标签利于团队协作与自动化响应（例如触发Lambda/SSM流程进行网络隔离），属于调查前的准备动作。

F. Immediately remove sensitive entries in instance metadata（立即删除元数据中的敏感条目） 错误。原因：EC2 Instance Metadata Service（IMDS）不是一个让你“删除条目”的配置存储；且“立即删除/清理”会破坏证据链并改变现场状态。正确做法通常是先保全，再评估隔离与修复（例如强制IMDSv2、限制SSRF路径、轮换凭证等），而不是在未取证前进行“删除”这种不可审计/不可还原的动作。

4. 我选择的答案

B、C、E

5. 官方答案

B、C、E

6. 与官方答案比较与复盘

我的答案：**BCE**

官方答案：**BCE**

结论：**一致。**

原因总结：调查前优先做三件事——**防误删（终止保护）、保全磁盘证据（EBS快照）、记录上下文并标记隔离状态以便响应流程。**

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430>  wechat

微信: "Examtopics"



Question #56

Topic 1

A company's security engineer is designing an isolation procedure for Amazon EC2 instances as part of an incident response plan. The security engineer needs to isolate a target instance to block any traffic to and from the target instance, except for traffic from the company's forensics team. Each of the company's EC2 instances has its own dedicated security group. The EC2 instances are deployed in subnets of a VPC. A subnet can contain multiple instances.

The security engineer is testing the procedure for EC2 isolation and opens an SSH session to the target instance. The procedure starts to simulate access to the target instance by an attacker. The security engineer removes the existing security group rules and adds security group rules to give the forensics team access to the target instance on port 22.

After these changes, the security engineer notices that the SSH connection is still active and usable. When the security engineer runs a ping command to the public IP address of the target instance, the ping command is blocked.

What should the security engineer do to isolate the target instance?

一家公司的安全工程师正在设计一个针对 Amazon EC2 实例的隔离流程，作为事件响应计划的一部分。安全工程师需要隔离一个目标实例，以阻止与该目标实例之间的所有进出流量，但公司的取证团队发起的流量除外。公司的每个 EC2 实例都有其各自专用的安全组。EC2 实例部署在一个 VPC 的子网中。一个子网可以包含多个实例。

安全工程师正在测试用于 EC2 隔离的流程，并打开了到目标实例的一个 SSH 会话。该流程开始模拟攻击者对目标实例的访问。安全工程师移除了现有的安全组规则，并添加了安全组规则，使取证团队能够通过 22 端口访问目标实例。

完成这些更改后，安全工程师注意到 SSH 连接仍然处于活动状态且可用。当安全工程师对目标实例的公网 IP 地址运行 ping 命令时，ping 命令被阻止了。

安全工程师应该怎么做来隔离目标实例？

A. Add an inbound rule to the security group to allow traffic from 0.0.0.0/0 for all ports. Add an outbound rule to the security group to allow traffic to 0.0.0.0/0 for all ports. Then immediately delete these rules.

向安全组添加一条入站规则，允许来自 0.0.0.0/0 的所有端口流量。向安全组添加一条出站规则，允许发往 0.0.0.0/0 的所有端口流量。然后立即删除这些规则。

B. Remove the port 22 security group rule. Attach an instance role policy that allows AWS Systems Manager Session Manager connections so that the forensics team can access the target instance.

移除 22 端口的安全组规则。附加一个实例角色策略，允许 AWS Systems Manager Session Manager 连接，以便取证团队可以访问目标实例。

C. Create a network ACL that is associated with the target instance's subnet. Add a rule at the top of the inbound rule set to deny all traffic from 0.0.0.0/0. Add a rule at the top of the outbound rule set to deny all traffic to 0.0.0.0/0.

创建一个与目标实例所在子网关联的网络 ACL。在入站规则集的最顶部添加一条规则，拒绝来自 0.0.0.0/0 的所有流量。在出站规则集的最顶部添加一条规则，拒绝发往 0.0.0.0/0 的所有流量。

D. Create an AWS Systems Manager document that adds a host-level firewall rule to block all inbound traffic and outbound traffic. Run the document on the target instance.

创建一个 AWS Systems Manager 文档，该文档添加一条主机级防火墙规则以阻止所有入站和出站流量。在目标实例上运行该文档。

Correct Answer: B

正确答案：B

题目解析：EC2 实例隔离（Incident Response Isolation）

1. 本题考察的知识点

Security Group（安全组）是有状态（stateful）：规则变更会立即影响“新建连接/新流量”，但**不会强制中断已建立的连接**（例如已经建立的 SSH 会话）。

NACL（网络ACL）是无状态（stateless）：对每个数据包独立评估；规则变更可对现有连接立刻生效，但作用范围是**子网级别**。

隔离目标实例的最佳实践思路：尽量不依赖开放入站端口（如 22），改用 **AWS Systems Manager Session Manager** 在不开放入站的前提下进行取证访问。

隔离范围控制：题目强调“一个子网可包含多个实例”，因此对子网做“全拒绝”会波及到其他实例，通常不符合“仅隔离目标实例”。

2. 独立思考（不参考官方答案）

题目现象：修改安全组后，**已建立的 SSH 仍可用**；但对公网 IP 的 **ping 被阻止**。

解释：这正是**安全组有状态**的典型表现——现有连接不会被安全组规则变更“踢掉”，但新发起的流量（如新的 ICMP Echo）会被阻止。

目标：阻断目标实例与外界的所有流量，仅允许取证团队访问。

约束：每个实例有独立安全组（好，适合按实例隔离）；但子网可能有多台实例（不适合对子网级 NACL 做 deny all）。

3. 逐个选项分析

A 选项：先放通全部再删除

为什么不正确：这不会解决“已建立 SSH 连接不会被中断”的问题；反而在短暂窗口内允许 0.0.0.0/0 全端口进出，扩大风险面。

与题意冲突：隔离应最小化暴露面，而不是短暂全开放。

B 选项：移除 22 规则，改用 SSM Session Manager 让取证团队访问

为什么可能正确：隔离时不应保留入站 SSH（22）；使用 **Session Manager** 可以在**无需开放入站端口**的情况下让取证团队进入实例进行处置与取证。

能解决什么核心问题：避免继续依赖 SSH 入站访问，从网络层面更接近“只允许取证访问”。

局限/注意点：仅“移除 22 规则”本身不一定能立刻中断现有 SSH（安全组不强制断开已有连接）。但在本题给定选项中，B 是唯一提供“隔离后仍可由取证团队访问”的合理机制（不靠开放入站）。

结论：在四个选项中，B 最符合 AWS 隔离最佳实践方向（用 SSM 替代 SSH）。

C 选项：对目标实例所在子网关联 NACL，入站/出站 top rule deny all

为什么不正确：NACL 作用于**子网**，题目强调“一个子网可包含多个实例”，这样会把同子网的其他实例也一起隔离/断网，通常不符合“隔离目标实例”的要求。

虽然技术上能做到：NACL 无状态，确实能立刻阻断现有连接，但代价是影响整个子网，违背题目场景约束。

D 选项：用 SSM 文档下发主机防火墙规则，阻止所有入站与出站

为什么不正确：题目要求“除取证团队外，阻断所有进出流量”。该选项是**阻止所有入站和出站**，会把取证团队也一并阻断（不满足“except for forensics team”）。

额外不确定性：题目未说明实例已具备可用的 SSM Agent 与必要 IAM 权限/连通性；且即便能执行，也会把取证通道一并封死。

4. 我选择的答案

B

5. 官方答案

B

6. 与官方答案比较与复盘

我的答案与官方答案一致：B

复盘要点：题干的关键陷阱是“安全组规则变更不会中断已建立连接”，因此单纯改安全组无法保证踢掉已存在的 SSH 会话；在给定选项里，最符合隔离最佳实践且能保留取证可访问性的，是**改用 SSM Session Manager 替代 SSH**。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #57

Topic 1

A company that uses AWS Organizations is using AWS IAM Identity Center (AWS Single Sign-On) to administer access to AWS accounts. A security engineer is creating a custom permission set in IAM Identity Center. The company will use the permission set across multiple accounts. An AWS managed policy and a customer managed policy are attached to the permission set. The security engineer has full administrative permissions and is operating in the management account.

When the security engineer attempts to assign the permission set to an IAM Identity Center user who has access to multiple accounts, the assignment fails.

What should the security engineer do to resolve this failure?

一家使用 AWS Organizations 的公司正在使用 AWS IAM Identity Center (AWS Single Sign-On) 来管理对 AWS 账户的访问。某安全工程师正在 IAM Identity Center 中创建一个自定义权限集。公司将在多个账户中使用该权限集。一个 AWS 托管策略和一个客户托管策略已附加到该权限集。该安全工程师具有完整的管理员权限，并且正在管理账户中操作。

当安全工程师尝试将该权限集分配给一个可访问多个账户的 IAM Identity Center 用户时，分配失败。

安全工程师应采取什么措施来解决此失败？

A. Create the customer managed policy in every account where the permission set is assigned. Give the customer managed policy the same name and same permissions in each account.

在权限集被分配到的每个账户中创建该客户托管策略。在每个账户中为该客户托管策略赋予相同的名称和相同的权限。

B. Remove either the AWS managed policy or the customer managed policy from the permission set. Create a second permission set that includes the removed policy. Apply the permission sets separately to the user.

从权限集中移除 AWS 托管策略或客户托管策略中的任意一个。创建第二个权限集并包含被移除的策略。分别将这些权限集应用到该用户。

C. Evaluate the logic of the AWS managed policy and the customer managed policy. Resolve any policy conflicts in the permission set before deployment.

评估 AWS 托管策略和客户托管策略的逻辑。在部署前解决权限集中的任何策略冲突。

D. Do not add the new permission set to the user. Instead, edit the user's existing permission set to include the AWS managed policy and the customer managed policy.

不要将新的权限集添加到该用户。相反，编辑该用户现有的权限集以包含该 AWS 托管策略和该客户托管策略。

Correct Answer: A

正确答案: A

题目解析 (AWS Certified Security - Specialty SCS-C03 做题教练)

1. 考察的知识点

AWS IAM Identity Center (原 AWS SSO) Permission Set 的策略来源与部署机制：Permission Set 可以附加 AWS managed policy，也可以附加 customer managed policy。

Customer managed policy 的关键限制：当 Permission Set 引用“客户托管策略 (customer managed policy)”时，IAM Identity Center 实际上是按“策略名称/路径”在**每个目标成员账号**内查找该 IAM policy；Identity Center 不会自动把该 IAM policy 复制到所有账号。

跨多账号分配失败的典型原因：在要分配的某些账号中不存在同名的 customer managed policy（或路径不一致），导致 Permission Set provisioning/assignment 失败。

2. 独立思考（不参考官方答案）

题干说明该 Permission Set 同时附加了 AWS managed policy 与 customer managed policy，并且要跨多个账号使用。

分配给“可访问多个账号”的用户时失败，最常见且最符合机制的原因是：**customer managed policy 只在某个账号（例如管理账号）存在，但在其他被分配的目标账号里不存在**，因此在为那些账号进行 provisioning 时失败。

解决思路应当是：**确保每个要应用该 Permission Set 的账号里都存在同名、同路径（如适用）的 customer managed policy。**

3. 逐个选项分析

A. 在权限集被分配到的每个账户中创建该客户托管策略，并保持相同名称和相同权限正确。

原因：Permission Set 引用 customer managed policy 时，需要目标账号本地存在该 IAM policy；跨账号使用时必须在每个目标账号都创建同名（以及一致的 path/名称）策略，否则 provisioning/assignment 会失败。

此做法正好消除“某些账号找不到 customer managed policy”的根因。

B. 移除其中一个策略，创建第二个 Permission Set 分别应用错误。

原因：失败的根因不是“一个 Permission Set 里不能同时有 AWS managed policy 和 customer managed policy”。这两类策略可以同时附加。

即使拆成两个 Permission Set，只要其中仍引用了目标账号不存在的 customer managed policy，分配仍会失败。

C. 检查策略逻辑并解决冲突错误（不符合题目现象）。

原因：IAM 策略评估不存在“冲突导致无法分配”的概念；显式拒绝（Deny）只会影响授权结果，不会导致 Permission Set assignment/provisioning 失败。

assignment 失败更典型是“依赖资源不存在/无法读取/无法创建”等配置性问题，例如引用的 customer managed policy 不存在。

D. 不要新增 Permission Set，改编用户现有 Permission Set 加入这些策略错误。

原因：是否“新增 Permission Set”与“编辑现有 Permission Set”不改变 customer managed policy 必须在每个目标账号存在这一事实。

如果现有 Permission Set 也引用同一个 customer managed policy，而该策略在部分账号不存在，仍然会失败。

4. 我选择的答案

A

5. 官方答案

A

6. 与官方答案比较与复盘

结论：一致（我选 A，官方也为 A）。

原因：IAM Identity Center 的 customer managed policy 属于“目标账号本地资源引用”，不会被自动复制；跨账号使用必须在每个目标账号预先创建同名同权限策略，否则 assignment/provisioning 会失败。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #58

Topic 1

An IAM user receives an Access Denied message when the user attempts to access objects in an Amazon S3 bucket. The user and the S3 bucket are in the same AWS account. The S3 bucket is configured to use server-side encryption with AWS KMS keys (SSE-KMS) to encrypt all of its objects at rest by using a customer managed key from the same AWS account. The S3 bucket has no bucket policy defined. The IAM user has been granted permissions through an IAM policy that allows the kms:Decrypt permission to the customer managed key. The IAM policy also allows the s3:List* and s3:Get* permissions for the S3 bucket and its objects. Which of the following is a possible reason that the IAM user cannot access the objects in the S3 bucket?

当某个 IAM 用户尝试访问 Amazon S3 存储桶中的对象时，该用户收到一条 Access Denied（访问被拒绝）消息。该用户与 S3 存储桶位于同一个 AWS 账户中。该 S3 存储桶被配置为使用带有 AWS KMS 密钥的服务器端加密（SSE-KMS），通过使用同一 AWS 账户中的客户管理型密钥，对其所有静态对象进行加密。该 S3 存储桶未定义任何存储桶策略。该 IAM 用户通过一个 IAM 策略被授予权限，该策略允许对该客户管理型密钥执行 kms:Decrypt 权限。该 IAM 策略还允许对该 S3 存储桶及其对象执行 s3:List* 和 s3:Get* 权限。

以下哪项可能是该 IAM 用户无法访问 S3 存储桶中对象的原因？

- A. The IAM policy needs to allow the kms:DescribeKey permission.
该 IAM 策略需要允许 kms:DescribeKey 权限。
- B. The S3 bucket has been changed to use the AWS managed key to encrypt objects at rest.
该 S3 存储桶已被更改为使用 AWS 托管型密钥对静态对象进行加密。
- C. An S3 bucket policy needs to be added to allow the IAM user to access the objects.
需要添加一个 S3 存储桶策略来允许该 IAM 用户访问这些对象。
- D. The KMS key policy has been edited to remove the ability for the AWS account to have full access to the key.
KMS 密钥策略已被编辑，移除了让该 AWS 账户对该密钥拥有完全访问权限的能力。

Correct Answer: D

正确答案: D

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

S3 使用 SSE-KMS 加密时的授权链路：访问对象不仅需要 S3 权限（s3:GetObject 等），还需要对对应 KMS Key 的使用权限（kms:Decrypt 等）。

KMS 的双层权限模型：同时需要

IAM Policy 允许（例如 kms:Decrypt）

并且 **KMS Key Policy** 也必须允许该主体（或允许账户内通过 IAM 授权生效）

同账号场景下，S3 无 Bucket Policy 并不必然导致拒绝（若 IAM 已授权且无显式拒绝）。

2. 独立思考（不参考官方答案）

题干说明：IAM 用户已具备 S3 读取/列举权限，并且对“该客户托管 CMK”有 kms:Decrypt 权限。

仍然 Access Denied 的高频原因是：**KMS Key Policy 不允许该用户（或不允许账户通过 IAM 来授予权限）**，导致即使 IAM 允许也无法使用密钥解密。

3. 逐个分析选项

A. The IAM policy needs to allow the kms:DescribeKey permission. 结论：**错误** 原因：读取 SSE-KMS 加密对象时，关键是 KMS 的 **kms:Decrypt**（有时也涉及 GenerateDataKey 等取决于操作类型），并不要求必须具备 **kms:DescribeKey** 才能解密。缺少 DescribeKey 通常不会导致 S3 GetObject 直接 AccessDenied（除非应用/流程显式调用 DescribeKey）。

B. The S3 bucket has been changed to use the AWS managed key to encrypt objects at rest. 结论：**错误（在本题语境下）** 原因：题干已明确存储桶“使用同账号的 customer managed key”。该选项等于否定题干前提。补充：即便真的改成 AWS managed key (aws/s3)，也可能因 IAM 未授予对应密钥 ARN 的权限而出问题，但这与题干描述不一致，因此不作为本题合理原因。

C. An S3 bucket policy needs to be added to allow the IAM user to access the objects. 结论：**错误** 原因：在“同一 AWS 账户”内，且 IAM policy 已允许 s3:Get*/List* 的情况下，**不一定需要** bucket policy 才能访问。真正缺口在 KMS 授权：没有 bucket policy 并不会阻止 KMS 解密；相反，即使加了 bucket policy，如果 KMS key policy 不允许，依然会失败。

D. The KMS key policy has been edited to remove the ability for the AWS account to have full access to the key. 结论：**正确** 原因：KMS 的最终授权由 **Key Policy** 控制。常见最佳实践是在 key policy 中保留类似“允许账户根（或账户）管理/使用密钥”的语句，使得账户内的 IAM 授权能生效。若 key policy 被编辑，移除了“账户拥有完全访问/或允许通过 IAM 授权使用密钥”的能力，则会出现：**即使 IAM policy 允许 kms:Decrypt，仍然无法解密，从而 S3 GetObject AccessDenied。**

4. 我选择的答案

D

5. 官方答案

D

6. 与官方答案对比与复盘

我的答案：D

官方答案：D

对比结果：**一致**

原因总结：SSE-KMS 访问失败最典型根因是 **KMS Key Policy** 不允许（或不再允许）该账户/主体使用密钥；仅有 IAM 的 kms:Decrypt 不足以保证成功。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #59

Topic 1

A company runs workloads in the us-east-1 Region. The company has never deployed resources to other AWS Regions and does not have any multi-Region resources. The company needs to replicate its workloads and infrastructure to the us-west-1 Region. A security engineer must implement a solution that uses AWS Secrets Manager to store secrets in both Regions. The solution must use AWS Key Management Service (AWS KMS) to encrypt the secrets. The solution must minimize latency and must be able to work if only one Region is available.

The security engineer uses Secrets Manager to create the secrets in us-east-1.

What should the security engineer do next to meet the requirements?

一家公司的工作负载运行在 us-east-1 区域。该公司从未将资源部署到其他 AWS 区域，并且没有任何多区域资源。该公司需要将其工作负载和基础设施复制到 us-west-1 区域。

一名安全工程师必须实施一种解决方案，该解决方案使用 AWS Secrets Manager 在两个区域中存储机密。该解决方案必须使用 AWS Key Management Service (AWS KMS) 来加密机密。该解决方案必须将延迟降到最低，并且必须能够在仅有一个区域可用时仍能工作。

安全工程师使用 Secrets Manager 在 us-east-1 中创建机密。

为了满足要求，安全工程师下一步应该怎么做？

A. Encrypt the secrets in us-east-1 by using an AWS managed KMS key. Replicate the secrets to us-west-1. Encrypt the secrets in us-west-1 by using a new AWS managed KMS key in us-west-1.

在 us-east-1 中使用 AWS 托管的 KMS 密钥加密机密。将机密复制到 us-west-1。在 us-west-1 中使用 us-west-1 的新 AWS 托管 KMS 密钥加密机密。

B. Encrypt the secrets in us-east-1 by using an AWS managed KMS key. Configure resources in us-west-1 to call the Secrets Manager endpoint in us-east-1.

在 us-east-1 中使用 AWS 托管的 KMS 密钥加密机密。将 us-west-1 中的资源配置为调用 us-east-1 中的 Secrets Manager 端点。

C. Encrypt the secrets in us-east-1 by using a customer managed KMS key. Configure resources in us-west-1 to call the Secrets Manager endpoint in us-east-1.

在 us-east-1 中使用客户托管的 KMS 密钥加密机密。将 us-west-1 中的资源配置为调用 us-east-1 中的 Secrets Manager 端点。

D. Encrypt the secrets in us-east-1 by using a customer managed KMS key. Replicate the secrets to us-west-1. Encrypt the secrets in us-west-1 by using the customer managed KMS key from us-east-1.

在 us-east-1 中使用客户托管的 KMS 密钥加密机密。将机密复制到 us-west-1。在 us-west-1 中使用来自 us-east-1 的客户托管 KMS 密钥加密机密。

Correct Answer: A

正确答案: A

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

AWS Secrets Manager 多区域 (Multi-Region) 复制：将同一个 secret 复制到另一个 Region，以支持跨区域容灾与就近访问。

KMS 与 Secrets Manager 的加密关系：Secrets Manager 中的 secret 使用 KMS key 进行静态加密；每个 Region 的 secret（主/副本）都需要在其所在 Region 具备可用的 KMS key。

区域级可用性与低延迟设计：要求“最小化延迟”通常意味着每个 Region 读取本 Region 的 Secrets Manager；要求“仅一个 Region 可用也能工作”意味着需要跨区域复制，而不是跨区域调用单一区域端点。

KMS Key 的区域属性：普通 KMS key 是区域级资源，不能直接在另一个 Region 使用（除非使用 Multi-Region KMS Keys，但选项未提及）。

2. 独立思考（不参考官方答案）

题目明确需要：在 us-east-1 与 us-west-1 都存储 secrets（即两地都有副本），并且要 **最小化延迟**、且 **单一区域可用也能工作**。因此应选择：**启用 Secrets Manager 跨区域复制**，让 us-west-1 访问本地副本，从而降低延迟并提升区域级可用性。

加密方面：每个 Region 的 secret 必须使用该 Region 可用的 KMS key（AWS 托管或客户托管均可）。

3. 逐个选项分析

A：在 us-east-1 使用 AWS 托管 KMS key 加密；复制到 us-west-1；在 us-west-1 使用新的 AWS 托管 KMS key 加密。

为什么正确：

满足“**在两个 Region 都存储 secrets**”：通过复制实现。

满足“**最小化延迟**”：us-west-1 的工作负载可读取 us-west-1 的副本，而不是跨区访问 us-east-1。

满足“**单一区域可用也能工作**”：若 us-east-1 不可用，us-west-1 仍有副本可用（反之亦然，取决于业务部署方式/复制配置）。

满足“**使用 KMS 加密**”：AWS 托管 key 也是 KMS key；副本 Region 使用本 Region 的 key 合理且常见。

符合 KMS 区域特性：在每个 Region 使用各自的 KMS key（而不是跨 Region 复用同一把普通 key）。

B：us-east-1 用 AWS 托管 key 加密；us-west-1 资源调用 us-east-1 的 Secrets Manager endpoint。

为什么错误：

不满足“**在两个 Region 都存储 secrets**”：没有把 secret 复制到 us-west-1，仅是跨区访问。

不满足“**最小化延迟**”：us-west-1 每次取 secret 都跨区访问 us-east-1，延迟更高且受跨区网络影响。

不满足“**单一区域可用也能工作**”：若 us-east-1 不可用，us-west-1 将无法获取 secret。

C：us-east-1 用客户托管 key 加密；us-west-1 资源调用 us-east-1 的 Secrets Manager endpoint。

为什么错误：

与 B 同样的核心问题：**不复制**导致不满足双区域存储、低延迟、单区域可用性要求。

仅将 AWS 托管 key 换成客户托管 key，**无法解决跨区访问带来的可用性与延迟问题**。

D：us-east-1 用客户托管 key 加密；复制到 us-west-1；us-west-1 使用来自 us-east-1 的客户托管 KMS key 加密。

为什么错误：

KMS key 默认是区域级资源：us-east-1 的 KMS key 不能直接在 us-west-1 使用。

只有在使用 **Multi-Region KMS Keys** 时，才会在另一个 Region 有对应的“复制 key”（不是“直接用同一把 us-east-1 的 key”）。但该选项描述为“使用来自 us-east-1 的 key”，表述不符合 KMS 区域机制。

因此该方案在实现层面通常不可行/不正确。

4. 我选择的答案

A

5. 官方答案

A

6. 与官方答案对比与复盘

我的答案：A；官方答案：A；一致。

复盘要点：本题关键是“**跨区域复制 secret + 每个 Region 使用本 Region 可用的 KMS key**”，以同时满足**低延迟**与**单区域可用性**。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #60

Topic 1

A company runs workloads in an AWS account. A security engineer observes some unusual findings in Amazon GuardDuty. The security engineer wants to investigate a specific IAM role and generate an investigation report. The report must contain details about anomalous behavior and any indicators of compromise.

Which solution will meet these requirements?

一家公司在 AWS 账户中运行工作负载。一名安全工程师在 Amazon GuardDuty 中观察到一些异常发现。安全工程师想要调查一个特定的 IAM 角色并生成一份调查报告。该报告必须包含有关异常行为的详细信息以及任何入侵指标。哪个解决方案将满足这些要求？

- A. Use Amazon Detective to perform an investigation on the IAM role.
使用 Amazon Detective 对该 IAM 角色执行调查。
- B. Use AWS Audit Manager to create an assessment. Specify the IAM role. Run an assessment report.
使用 AWS Audit Manager 创建评估。指定 IAM 角色。运行评估报告。
- C. Use Amazon Inspector to create an assessment. Specify the IAM role. Run an assessment report.
使用 Amazon Inspector 创建评估。指定 IAM 角色。运行评估报告。
- D. Use Amazon Inspector to run an on-demand scan of the IAM role.
使用 Amazon Inspector 对该 IAM 角色运行按需扫描。

Correct Answer: A

正确答案: A

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

Amazon GuardDuty 发现 (findings) 后的调查与取证流程: 如何对可疑活动进行深入分析 (who/what/when/where)。

Amazon Detective 的用途: 面向安全调查 (security investigation), 可将 GuardDuty 等信号关联分析并生成调查结果/报告, 聚焦异常行为与潜在入侵指标 (IOC)。

AWS Audit Manager 与 **Amazon Inspector** 的边界: Audit Manager 偏合规审计证据收集; Inspector 偏漏洞/暴露面扫描 (如 EC2/ECR/Lambda 等), 不用于“调查某个 IAM Role 的异常行为与 IOC 报告”。

2. 独立思考 (不参考官方答案)

题干关键要求: 已在 **GuardDuty** 中看到异常; 要调查 **特定 IAM role**; 并要生成包含 **异常行为细节** 与 **IOC** 的调查报告。

在 AWS 原生服务中, 与 GuardDuty 调查闭环最匹配的是 **Amazon Detective**: 可对与 IAM 实体相关的活动进行关联分析 (例如 API 调用、资源访问模式、相关事件时间线), 帮助输出调查结论。

Inspector/Audit Manager 都不以“基于 GuardDuty 的异常调查与 IOC 报告”为核心能力, 因此不满足题意。

3. 逐个选项分析（为什么正确/错误）

A. Use Amazon Detective to perform an investigation on the IAM role. 正确。 理由：Detective 用于对安全发现进行交互式调查与关联分析，能够围绕特定实体（如 IAM role/用户、相关资源）查看行为时间线、关联证据与异常模式，从而形成调查结论，满足“调查 + 报告（异常行为与 IOC 细节）”的要求，并且与 GuardDuty findings 的调查场景高度匹配。

B. Use AWS Audit Manager to create an assessment. Specify the IAM role. Run an assessment report. 错误。 理由：Audit Manager 主要用于合规框架（如 CIS、ISO、SOC 等）的证据收集与审计准备，输出的是“合规评估报告/证据包”，不是针对 GuardDuty 异常告警的取证调查，也不聚焦 IOC（Indicators of Compromise）与异常行为关联分析。并且“指定某个 IAM role 做 assessment”不符合其典型工作方式与目标产出。

C. Use Amazon Inspector to create an assessment. Specify the IAM role. Run an assessment report. 错误。 理由：Inspector 的核心是漏洞管理/持续扫描（例如 EC2、ECR 镜像、Lambda 等的漏洞与配置风险），不用于对“某个 IAM role 的异常行为”进行调查，更不擅长输出与 GuardDuty findings 对应的 IOC 调查报告；而且 Inspector 并不以“对 IAM role 创建评估”为主要模型。

D. Use Amazon Inspector to run an on-demand scan of the IAM role. 错误。 理由：同 C，Inspector 的扫描目标不是“IAM role 的异常行为/IOC”。即使做按需扫描，也无法满足“基于 GuardDuty 异常发现对 IAM role 进行调查并生成包含异常行为与 IOC 的调查报告”的要求。

4. 我选择的答案

A

5. 官方答案

A

6. 与官方答案对比与复盘

对比结果：我的答案（A）与官方答案（A）一致。

复盘原因：题目强调 GuardDuty 异常后的“调查 + 报告（异常行为 + IOC）”，这正是 Amazon Detective 的定位；Audit Manager 偏合规，Inspector 偏漏洞扫描，均不匹配调查 GuardDuty 异常的需求。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #61

Topic 1

A company recently set up Amazon GuardDuty and is receiving a high number of findings from IP addresses within the company. A security engineer has verified that these IP addresses are trusted and allowed. Which combination of steps should the security engineer take to configure GuardDuty so that it does not produce findings for these IP addresses? (Choose two.)

一家公司最近设置了 Amazon GuardDuty，并且正在接收来自公司内部 IP 地址的大量调查结果（findings）。一名安全工程师已经验证这些 IP 地址是受信任且被允许的。安全工程师应采取哪种步骤组合来配置 GuardDuty，使其不会针对这些 IP 地址生成调查结果？（选择两项。）

A. Create a plaintext configuration file that contains the trusted IP addresses.

创建一个包含受信任 IP 地址的纯文本配置文件。

B. Create a JSON configuration file that contains the trusted IP addresses.

创建一个包含受信任 IP 地址的 JSON 配置文件。

C. Upload the configuration file directly to GuardDuty.

将配置文件直接上传到 GuardDuty。

D. Upload the configuration file to Amazon S3. Add a new trusted IP list to GuardDuty that points to the file.

将配置文件上传到 Amazon S3。在 GuardDuty 中添加一个新的受信任 IP 列表（trusted IP list），并指向该文件。

E. Manually copy and paste the configuration file data into the trusted IP list in GuardDuty.

将配置文件数据手动复制并粘贴到 GuardDuty 的受信任 IP 列表中。

Correct Answer: AD

正确答案: AD

题目解析：GuardDuty Trusted IP List（受信任IP列表）抑制告警

1. 本题考察的知识点

Amazon GuardDuty 的 Trusted IP list（受信任IP列表）功能：用于将特定IP/CIDR标记为“可信”，从而避免GuardDuty针对这些来源IP产生相关Finding。

Trusted IP list 的文件格式：需要使用**纯文本（plain text）**文件，每行一个IP地址或CIDR段。

Trusted IP list 的交付方式：文件必须存放在**Amazon S3**，然后在GuardDuty里创建Trusted IP list并指向该S3对象。

2. 独立思考（不参考官方答案）

要让GuardDuty不再对公司内部可信IP产生Finding，需要配置 **Trusted IP list**。

该功能要求：**准备纯文本IP列表文件 + 上传到S3并在GuardDuty中引用。**

因此应选择：A + D。

3. 逐个选项分析

A. Create a plaintext configuration file that contains the trusted IP addresses. 正确。 GuardDuty的Trusted IP list要求使用纯文本文件（每行一个IP或CIDR）。该步骤是必需的前置准备。

B. Create a JSON configuration file that contains the trusted IP addresses. 错误。 Trusted IP list不是JSON格式输入；若上传JSON，GuardDuty不会按预期解析为IP白名单。

C. Upload the configuration file directly to GuardDuty. 错误。 GuardDuty不支持“直接上传文件到GuardDuty”的方式配置Trusted IP list；必须通过S3对象引用。

D. Upload the configuration file to Amazon S3. Add a new trusted IP list to GuardDuty that points to the file. 正确。 这是GuardDuty配置Trusted IP list的标准做法：把文件放到S3，然后在GuardDuty里创建Trusted IP list并指向该S3位置。

E. Manually copy and paste the configuration file data into the trusted IP list in GuardDuty. 错误。 GuardDuty Trusted IP list不支持在控制台里手工粘贴IP列表内容；它是以S3对象作为数据源。

4. 我选择的答案

A 和 D

5. 官方答案

AD

6. 与官方答案比较与复盘

我的答案：AD

官方答案：AD

结论：一致。原因：GuardDuty Trusted IP list要求使用纯文本文件并存放在S3中，由GuardDuty引用该S3对象来生效。

AWS Certified Security - Specialty SCS-C03 (2026/03/11)

淘宝: "IT认证轻松过" <https://shop542998714.m.taobao.com>

咸鱼: "IT认证轻松过" <https://www.goofish.com/personal?userId=2645260430> 

微信: "Examtopics"



Question #62

Topic 1

A development team is creating an open source toolset to manage a company's software as a service (SaaS) application. The company stores the code in a public repository so that anyone can view and download the toolset's code. The company discovers that the code contains an IAM access key and secret key that provide access to internal resources in the company's AWS environment. A security engineer must implement a solution to identify whether unauthorized usage of the exposed credentials has occurred. The solution also must prevent any additional usage of the exposed credentials. Which combination of steps will meet these requirements? (Choose two.)

一个开发团队正在创建一个开源工具集，用于管理一家公司的软件即服务（SaaS）应用程序。该公司将代码存储在公共代码仓库中，以便任何人都可以查看和下载该工具集的代码。

公司发现代码中包含一个 IAM 访问密钥和秘密密钥，这些密钥可用于访问公司 AWS 环境中的内部资源

一名安全工程师必须实施一个解决方案，以识别是否发生了对已暴露凭证的未授权使用。该解决方案还必须防止对已暴露凭证的任何进一步使用。

哪种步骤组合将满足这些要求？（选择两个。）

A. Use AWS Identity and Access Management Access Analyzer to determine which resources the exposed credentials accessed and who used them.

使用 AWS Identity and Access Management Access Analyzer 来确定已暴露凭证访问了哪些资源以及是谁使用了它们。

B. Deactivate the exposed IAM access key from the user's IAM account.

从用户的 IAM 账户中停用已暴露的 IAM 访问密钥。

C. Create a rule in Amazon GuardDuty to block the access key in the source code from being used.

在 Amazon GuardDuty 中创建一条规则，以阻止源代码中的访问密钥被使用。

D. Create a new IAM access key and secret key for the user whose credentials were exposed.

为凭证已暴露的用户创建一个新的 IAM 访问密钥和秘密密钥。

E. Generate an IAM credential report. Check the report to determine when the user that owns the access key last logged in.

生成一份 IAM 凭证报告。检查该报告以确定拥有该访问密钥的用户上次登录的时间。

Correct Answer: BE

正确答案: BE

题目解析 (AWS Certified Security - Specialty SCS-C03)

1. 本题考察的知识点

IAM 访问密钥 (Access Key/Secret Key) 泄露后的应急处置：如何立即阻断泄露密钥的继续使用（撤销/停用/删除）。

凭证使用情况审计：如何判断泄露凭证是否已经被使用（例如通过 IAM Credential Report 的“access key last used”等字段，或更理想情况下通过 CloudTrail）。

理解各安全服务能力边界：Access Analyzer、GuardDuty 是否具备“追溯谁用过某个 Access Key/阻断该 Key”的能力。

2. 独立思考（不依赖官方答案）

题目要求同时满足两个目标：（1）**识别是否发生过未授权使用**（需要审计/追踪使用情况）；（2）**阻止泄露凭证的进一步使用**（需要立即让该 Access Key 失效）。

在选项中，能直接“阻止进一步使用”的最明确动作是：**停用该 Access Key（B）**。

能用于“判断是否使用过”的选项里，最贴近的是：**生成 IAM credential report 并查看 access key 的 last used 信息（E）**。尽管选项文字写“last logged in”，但 credential report 里确实包含 Access Key 的 last used 字段，可用来判断该 Key 是否被调用过（至少能做初步判断）。

3. 逐个选项分析

A. 使用 IAM Access Analyzer 确定暴露凭证访问了哪些资源以及是谁使用了它们 结论：**错误** 原因：

IAM Access Analyzer 主要用于分析资源策略（S3/KMS/IAM Role 信任策略等）是否允许外部访问、以及跨账号共享路径。

它不是“基于 Access Key 的行为审计工具”，不能回答“这个 Access Key 访问了哪些资源/是谁用的”。

此类审计通常依赖 AWS CloudTrail（题目未提供对应选项）。

B. 从用户的 IAM 账户中停用已暴露的 IAM 访问密钥 结论：**正确** 原因：

停用（Deactivate）Access Key 会立即使该 Key 的 API 调用失败，从而**阻止进一步使用**。

符合题目“必须防止额外使用泄露凭证”的硬性要求。

实务上也常见做法是先停用以止血，确认影响后再删除并轮换。

C. 在 Amazon GuardDuty 中创建规则阻止源代码中的访问密钥被使用 结论：**错误** 原因：

GuardDuty 是**威胁检测服务**（告警/发现），不是访问控制面，不能直接“阻断某个 Access Key 的使用”。

GuardDuty 可以检测异常（例如来自异常地理位置的 API 调用、可疑行为），但**不能充当防火墙**去封禁某个 Key。

要阻断，还是需要 IAM 层面停用/删除 Key，或用 SCP/权限边界等限制（但也不是“针对某个 Key”精确阻断）。

D. 为凭证已暴露的用户创建一个新的 IAM 访问密钥和秘密密钥 结论：**错误（单独做不满足题意）** 原因：

创建新 Key **并不会让旧 Key 失效**，泄露的旧 Key 仍可继续被使用，不满足“防止额外使用泄露凭证”。

正确做法应是：先停用/删除旧 Key，再创建新 Key 并完成轮换（本题在“二选二”约束下，D 本身不如 B 关键）。

E. 生成 IAM 凭证报告，检查报告以确定拥有该访问密钥的用户上次登录时间 结论：**有条件正确（在本题选项中用于“判断是否被使用过”的最贴近手段）** 原因：

IAM credential report 包含多种字段，不仅有控制台登录相关信息（password/console），还包含 **access_key_1_last_used_date / region / service** 等信息。

因此它可以帮助你**初步判断该 Access Key 最近是否被使用过**、以及大致使用的区域/服务。

局限：

它通常**不能精确回答“访问了哪些具体资源/是谁使用”**；精确溯源应看 CloudTrail 事件并按 AccessKeyId 过滤。

选项描述“last logged in”偏向控制台登录，不如“access key last used”准确，但基于 credential report 的实际内容，仍可满足“是否发生使用”的判断需求（至少在题目给定选项里最合理）。

4. 我选择的答案

B + E

5. 官方答案

B + E

6. 与官方答案对比及复盘

对比结果：**一致**（我选择 B+E，官方也是 B+E）。

复盘说明：

B 是唯一明确能“立即阻止额外使用”的选项。

E 虽然文字表述偏“登录”，但 credential report 的确能提供 Access Key last used 信息，是题目给定选项中最接近“判断是否存在未授权使用”的手段。

如果题目提供 CloudTrail 相关选项，通常会用 CloudTrail 来精确确认哪些 API 调用发生、来源 IP、调用的资源与时间线；但在本题选项限制下，E 是可用的审计替代。

